

AZ-500: Azure Security Engineer Associate

Cheat Sheet

Quick Bytes for you before the exam!

The information provided in the cheat sheet is for educational purposes only; created in our efforts to help aspirants prepare for the **Exam AZ-500 certification**. Though references have been taken from **Microsoft documentation**, it's not intended as a substitute for the official docs. The document can be reused, reproduced, and printed in any form; ensure that appropriate sources are credited and required permissions are received.

Are you Ready for **Microsoft Azure Security Engineer Associate**
"AZ-500" Certification?



Self-assess yourself with

[Whizlabs FREE TEST](#)



800+ Hands-on-Labs

[Hands-on Labs](#)



Cloud Sandbox

[Cloud Sandbox environments](#)

AZ-500 Whizcard Index

Topics Names	Page No
Secure Identity and Access Management	
Introduction to Microsoft Entra	4
What is Microsoft Entra ID?	5
Secure Microsoft Entra users	7
Secure Microsoft Entra groups	9
Microsoft Entra External Identities	11
Microsoft Entra Authorization	16
Microsoft Entra Application Access	25
Secure compute, storage, and databases	
Plan and implement security for virtual networks	28
Azure Virtual Network Manager (AVNM)	30
Plan and implement Virtual Network Peering/VPN gateway	31
Plan and implement Virtual WAN, including a secured virtual hub	33
Implement encryption over ExpressRoute	35
Plan and implement Security for private access to Azure resources	36
Plan and implement Private Link services	40
Network integration for Azure App Service and Azure Functions	42
Plan and implement security for public access to Azure resources	45
Plan, implement, and manage an Azure Firewall	46
Plan and implement an Azure Application Gateway	47
Plan and implement a Web Application Firewall (WAF)	50
Secure compute, storage, and databases	
Plan and implement advanced security for compute	53
Secure and Monitor AKS	54
Configure security for Azure Container Apps (ACAs)	58
Manage access to Azure Container Registry (ACR)	59
Disk Encryption	62
Plan and implement dynamic masking	80

Secure Azure using Microsoft Defender for Cloud & Sentinel	
Plan, implement, and manage governance for security	83
Implementing Security Controls for Asset Management	85
Create and configure an Azure Key Vault	86
Configure backup and recovery of certificates, secrets, and keys	90
Manage security posture by using Microsoft Defender for Cloud	92
Microsoft Defender External Attack Surface Management - External assets	104
Microsoft Defender for Cloud - Threat protection	106
Configure and manage security monitoring and automation solutions	110
Configure automation in Microsoft Sentinel	113
Configuring Workflow Automation in Microsoft Defender for Cloud	117

Secure Identity and Access Management

Introduction to Microsoft Entra

Microsoft Entra is a comprehensive identity and access management solution designed to enhance organizational security through a Zero Trust strategy. It seamlessly integrates various identity and access components to provide secure and efficient access management across different environments. Here is a detailed overview:

Microsoft Entra Components Overview

Component	Description
Microsoft Entra ID	Provides identity, authentication, policy, and protection for employees, devices, and resources.
Microsoft Entra Domain Services	Managed domain services supporting traditional authentication methods like Kerberos and NTLM.
Microsoft Entra Private Access	Secures access to private apps and resources without needing a VPN.
Microsoft Entra Internet Access	Secures access to internet resources with real-time monitoring and adjustments.
Microsoft Entra ID Governance	Automates access requests, assignments, and reviews.
Microsoft Entra ID Protection	Detects and reports identity-based risks, enhancing security measures.

Key Benefits:

- **Enhanced Security:** Implements Zero Trust principles to verify identities and validate access conditions.
- **Simplified Management:** Automates access requests and reviews, reducing administrative burden.
- **Comprehensive Coverage:** Manages both on-premises and cloud-based resources, ensuring consistent security.
- **Real-Time Monitoring:** Continuously monitors access activities and adjusts permissions in real-time.

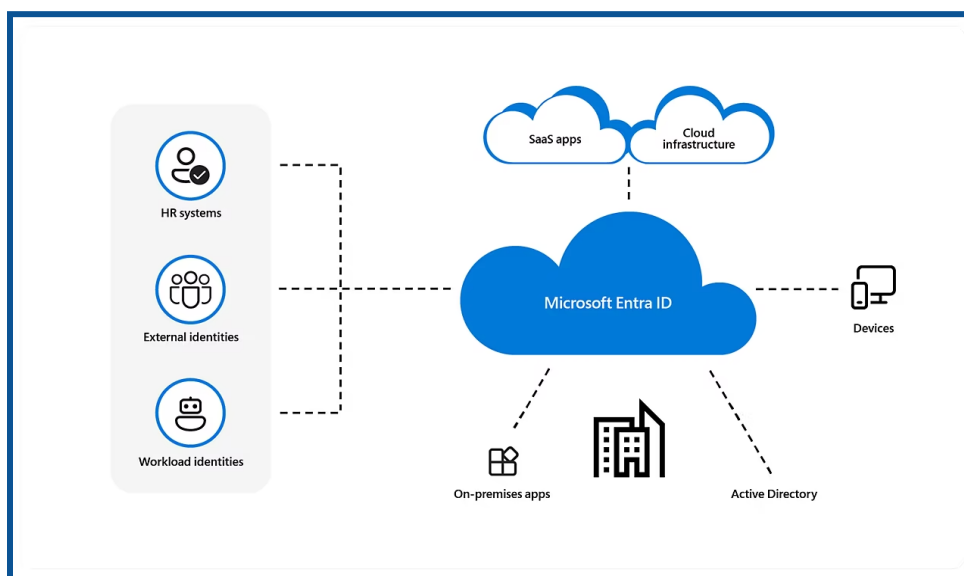
Use Cases:

1. **Remote Work:** Securely connects remote users to internal resources without the need for a VPN.
2. **Legacy Applications:** Supports applications requiring traditional authentication methods.
3. **SaaS Applications:** Ensures secure access to SaaS applications and Microsoft 365.
4. **Identity Governance:** Streamlines identity management and compliance processes.

What is Microsoft Entra ID?

Microsoft Entra ID is a cloud-based identity and access management solution that lets your employees access external resources like Microsoft 365, the Azure portal, and hundreds of other SaaS applications.

- It's a suite of tools of identity and access management (IAM) solutions from Microsoft.
- Microsoft's cloud-based identity and access management service.
- It helps organizations manage and secure access to their applications, data, and resources.



[Source: Microsoft Documentation]

Microsoft Entra Capabilities:

- App integrations and single sign-on (SSO)
- Passwordless and multifactor authentication (MFA)
- Conditional access and Identity protection
- Privileged identity management
- End-user self-service, and Unified admin center

Microsoft Entra ID Licenses

- **Microsoft Entra ID Free:** Offers self-service password changes for cloud users, group and user management, basic reporting, on-premises directory synchronization, and single sign-on for Azure, Microsoft 365, and numerous well-known SaaS apps.
- **Microsoft Entra ID P1:** P1 provides hybrid users with access to both on-premises and cloud resources, in addition to the free features. It also supports advanced administration features, including dynamic groups, self-service group management, Microsoft Identity Manager, and cloud write-back capabilities that enable on-premises users to reset their passwords themselves.

- **Microsoft Entra ID P2:** In addition to the Free and P1 features, P2 includes Microsoft Entra ID Protection, which helps provide risk-based Conditional Access to your apps and critical company data, and Privileged Identity Management, which helps discover, restrict, and monitor administrators and their access to resources, as well as provide just-in-time access when necessary.
- **"Pay as you go" feature licenses:** Additionally, licenses for features like Microsoft Entra Business-to-Customer (B2C) are available. You can give your customer-facing apps identity and access management solutions with the assistance of B2C.

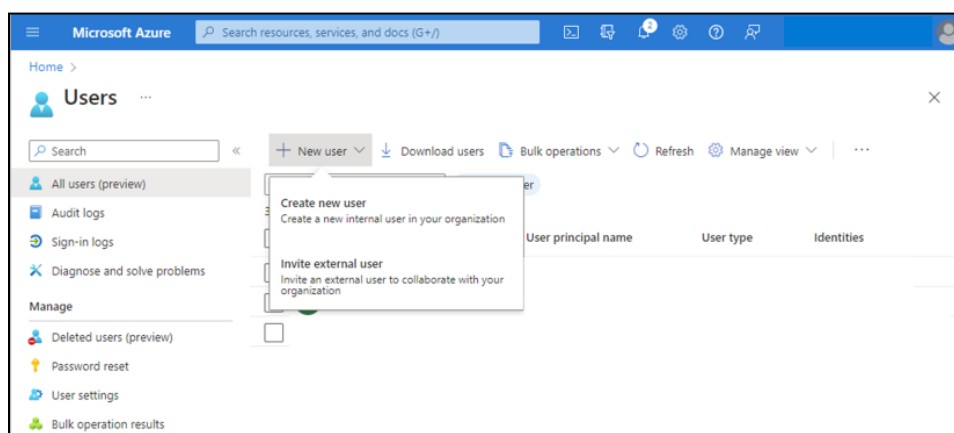
Secure Microsoft Entra users

- We can add new users or delete existing users from Microsoft Entra ID Tenant.
- Only the User Administrator or Global Administrator is authorized to add or delete users

How to add a new user?

We can create a new user for your organization or invite an external user.

1. Sign in to the Azure portal with the user administrator role.
2. Microsoft Entra ID > Users.
3. Select Create New User or Invite External User from the menu.



[Source: Microsoft Documentation]

4. New User page → provide the new user's information:
5. Copy the auto generated password provided in the Password box. You must provide this password to the user to sign in for the first time.
6. Then Select Create.

The user is created and added to your Microsoft Entra ID organization.

MS Source: [Secure users in Microsoft Entra ID - Training | Microsoft Learn](#)

Add a new guest user

You can also invite a new guest user to collaborate with your organization by selecting the Invite User option from the New User page. If your organization's external collaboration settings are configured to allow guests, an invitation is emailed that the user must accept to start collaboration.

Add other users

There may be times when you want to manually create user accounts in your Microsoft Entra B2B directory. If you have an environment with Microsoft Entra ID (cloud) and Windows Server Active Directory (on-premises), you can add new users by synchronizing existing user account data.

Delete the users: We can delete an existing user using the Microsoft Entra ID portal.

- You must have a Global Administrator, Privileged Authentication Administrator, or User Administrator role assignment to delete users in your organization.
- Global Admins and Privileged Authentication Admins can delete any users, including other admins.
- User Administrators can delete any non-admin users, Helpdesk Administrators, and other User Administrators.

1. Sign in to the **Azure portal** using one of the appropriate roles listed above.
2. Go to **Microsoft Entra ID > Users**.
3. Search for and select the user you want to delete from your Microsoft Entra ID tenant.
4. Select **Delete user**.

[Source: Microsoft Documentation]

Secure Microsoft Entra groups

What are Microsoft Entra groups?

Microsoft Entra groups manage users who all need the same access and permissions to resources, such as potentially restricted apps and services. Instead of adding special permissions to individual users, you create a group that applies the special permissions to every group member.

Using groups also enables the following management features:

- Attribute-based dynamic groups
- External groups synced from on-premises Active Directory
- Administrator-managed or self-service-managed groups

Microsoft Entra ID allows you to use groups to control access to applications, data, and resources. The resources can be:

- Microsoft Entra ID that grants access to manage objects
- Outside the company, like in the case of Software as a Service (SaaS) applications
- Azure Services
- SharePoint websites
- On-premises resources.

The Azure portal is unable to manage the following groups:

- Only on-premises Active Directory is used to manage groups synchronized with it.
- The only places to manage distribution lists and mail-enabled security groups are the Microsoft 365 admin center and the Exchange admin center. To manage these groups, you need to log in to the Microsoft 365 admin center or the Exchange admin center.

Types of groups:

Security: Controls how computers and users access shared resources. To ensure that each member of the group has the same set of security permissions, for instance, you can create a security group. Users, devices, service principals, and other groups (also called nested groups) that specify permissions and access policies can all be members of a security group. Users and service principals are examples of who can own a security group.

Microsoft 365: Members of a group can collaborate by using Microsoft 365, which grants access to a shared calendar, files, mailbox, SharePoint sites, and more.

Types of membership:

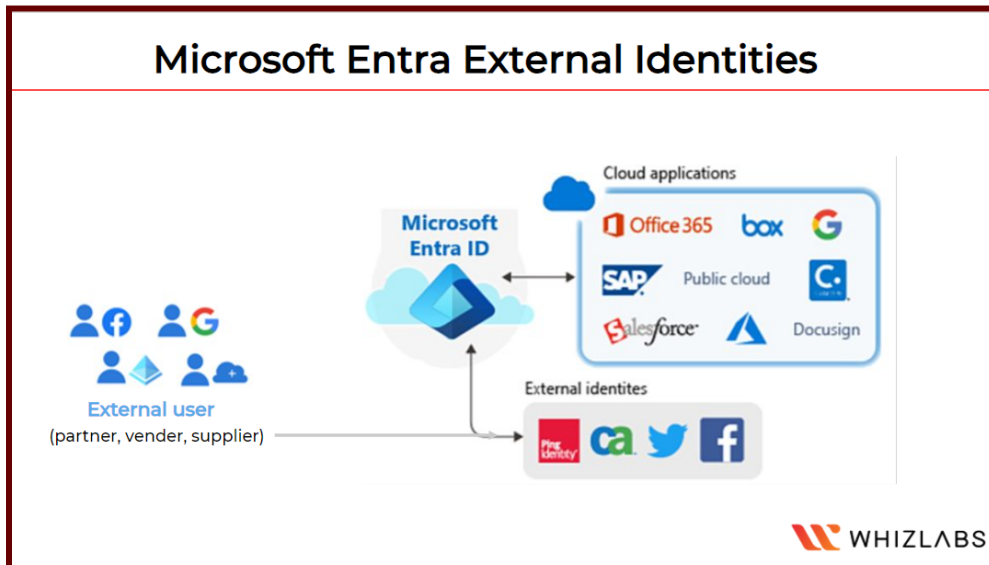
- **Assigned:** This allows you to give particular users special permissions to join a group.
- **Dynamic user:** This allows you to automatically add and remove members based on dynamic membership rules. When a member's attributes change, the system examines

your dynamic group rules for the directory to determine whether the member is added or removed based on whether they still meet the requirements of the rule.

- **Dynamic device:** This enables automatic device addition and removal using dynamic group rules. When a device's attributes change, the system checks your dynamic group rules for the directory to determine whether the device should be added to the rule or removed based on whether it still meets the requirements.

Microsoft Entra External Identities

The term "Microsoft Entra External ID" describes all of the secure methods through which you can communicate with users outside of your company. If you want to collaborate with distributors, suppliers, vendors, or partners, you can define resource sharing and how internal users can access external organizations. As a developer building apps for users, you can control the identity experiences of your clients.



External users can "bring their own identities" by using External ID. They can use their credentials to log in regardless of whether they have an unmanaged social identity like Google or Facebook or a digital identity issued by a company or government.

External identities are made up of the following capabilities:

B2B collaboration: Allow external users to sign in to your Microsoft or other enterprise applications (SaaS apps, custom-developed apps, etc.) using their preferred identity. This will allow you to collaborate with them.

B2B direct connect - Create a mutual, two-way trust with another Microsoft Entra organization to enable seamless collaboration. B2B direct connect currently supports Teams shared channels, which allow external users to access your resources from within their own Teams instances.

B2C - Use this B2C for identity and access management when publishing contemporary SaaS apps or custom-developed apps (apart from Microsoft apps) to users and clients.

Microsoft Entra multi-tenant organization - Collaborate with multiple tenants in a single Microsoft Entra organization using cross-tenant synchronization.

Secure external identities

When to Use External Identities:

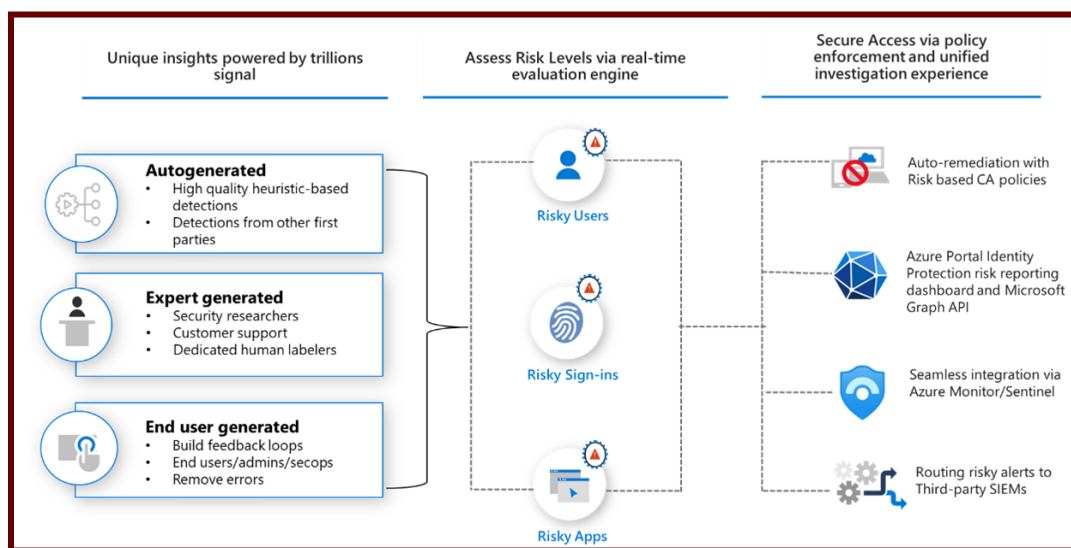
[Secure external identities - Training | Microsoft Learn](#)

- External Identities are especially useful in situations where collaboration extends beyond the organization's boundaries.
- If you want to collaborate with entities like partners or developers to create consumer-facing applications, External Identities are a strategic solution.
- It provides a framework for users from other organizations to bring their own identities, whether they have a corporate, government-issued digital identity or use unmanaged social identities such as those from Google and Facebook.

[Secure external identities - Training | Microsoft Learn](#)

Implement Microsoft Entra ID Protection

Microsoft Entra ID Protection is a tool that enables organizations to automate the detection and remediation of identity-based risks, conduct risk investigations using portal data, and export risk detection results to third-party utilities for further analysis.



[Source: Microsoft Documentation]

Microsoft Entra ID Protection is a tool that allows organizations to accomplish three key tasks:

- Automate the detection and remediation of identity-based risks.
- Investigate risks using data in the portal.
- Export risk detection data to third-party utilities for further analysis.
- ★ Microsoft Entra ID Protection enables businesses to detect, investigate, and mitigate identity-based risks.
- ★ These identity-based risks can then be fed into tools such as Conditional Access to make access decisions or back into a security information and event management (SIEM) tool for further investigation and correlation.

Types of Risks:

- Anonymous IP address usage
- Password spray attacks
- Leaked credentials

Investigate:

Any risks detected on an identity are tracked with reporting. Identity Protection provides three key reports for administrators to investigate risks and take action:

- Risk detections: Each risk detected is reported as a risk detection.
- Risky sign-ins: A risky sign-in is reported when there are one or more risk detections reported for that sign-in.
- Risky users: A Risky user is reported when either or both of the following are true:
 - ◆ The user has one or more Risky sign-ins.
 - ◆ One or more risk detections have been reported.

Manage Microsoft Entra authentication

Microsoft Entra authentication includes the following components:

- Self-service password reset
- Microsoft Entra multifactor authentication
- Hybrid integration to write password changes back to on-premises environment
- Hybrid integration to enforce password protection policies for an on-premises environment
- Passwordless authentication

1. Self-service password reset

Self-service password reset enables users to change or reset their passwords without the involvement of an administrator or help desk. If a user's account is locked or they forget their password, they can use the prompts to unblock themselves and return to work. This ability reduces help desk calls and productivity loss when a user is unable to sign in to their device or application.

Self-service password reset works in the following scenarios:

- Password change occurs when a user knows their password but wishes to change it to something new.
- Password reset occurs when a user is unable to sign in, such as when they have forgotten their password and wish to reset it.
- Account unlocking occurs when a user is unable to sign in because their account has been locked and wishes to unlock their account.

A self-service password reset also writes the password back to an on-premises Active Directory when a user changes or resets their password.

Ensuring that a user can use their updated credentials with on-premises devices and applications right away is ensured by password writeback.

2. Microsoft Entra multifactor authentication

Multifactor authentication is a sign-in process in which a user is prompted for an additional form of identification, such as entering a code on their phone or providing a fingerprint scan.



Microsoft Entra multifactor authentication uses a few authentication methods [as follows]

- Typically a password [Something you know]
- Trusted device that is not easily duplicated, like a phone or key [Something you have]
- Biometrics like a fingerprint or face scan [Something you are]

Users can register for both self-service password reset and Microsoft Entra multifactor authentication in a single step, making the onboarding process easier. Administrators can specify which types of secondary authentication can be used. To further secure the self-service password reset process, users may be required to use Microsoft Entra multifactor authentication.

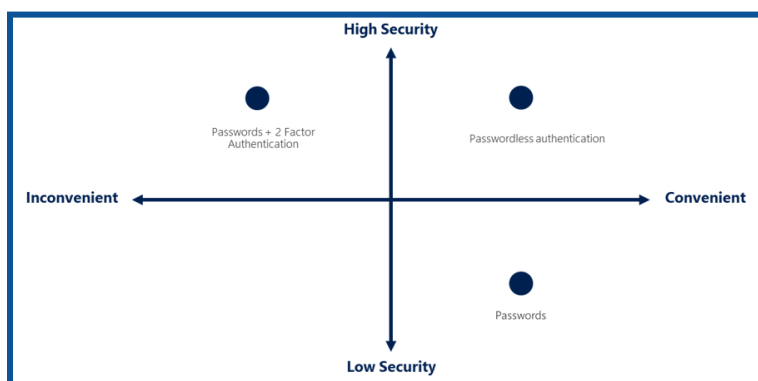
3. Password protection

Microsoft Entra ID by default prevents weak passwords like Password1. A global list of prohibited passwords that are enforced and updated automatically contains known weak passwords. If a Microsoft Entra user attempts to set their password to one of these weak passwords, they are prompted to select a more secure password.

You can set up custom password protection policies to improve security.

4. Passwordless authentication

Eliminating the need for passwords during sign-in procedures is the ultimate objective for numerous settings. A username and password are still weak forms of authentication that can be exposed or brute-forced but features like Azure password protection or Microsoft Entra multi-factor authentication help improve security.



[Source: Microsoft Documentation]

Credentials are supplied using techniques like biometrics with Windows Hello for Business or a FIDO2 security key when you log in without a password. An attacker cannot easily replicate these authentication methods.

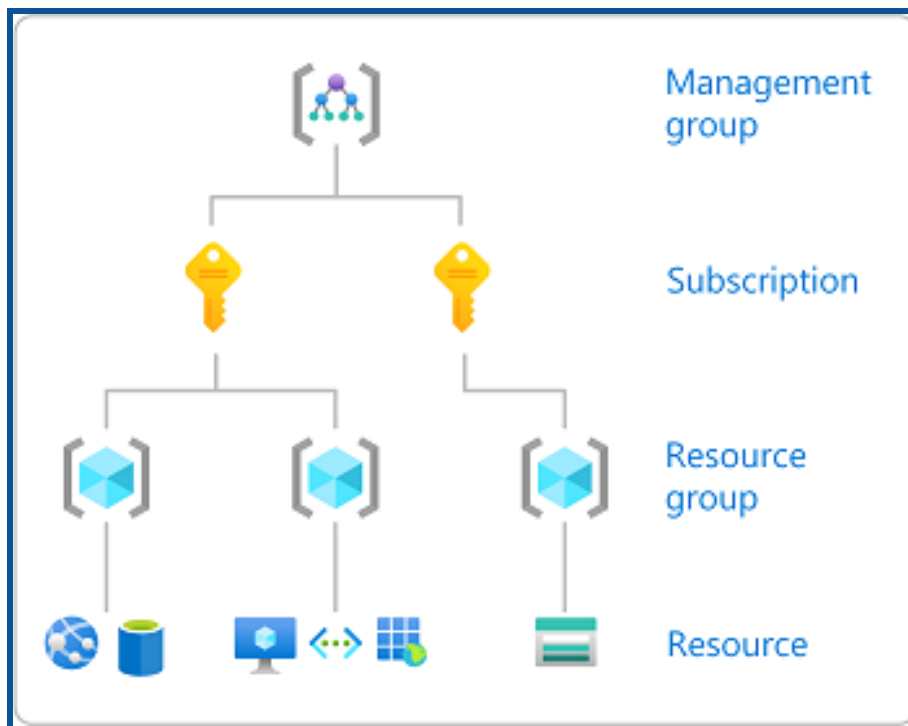
Microsoft Entra ID makes it easier for users to sign in and lowers the risk of attacks by offering native authentication through passwordless methods.

Microsoft Entra Authorization

Azure Role-Based Access Control (RBAC):

Azure RBAC is a fundamental concept that governs access to Azure resources. It operates based on assigning roles to entities (users, groups, or applications) at various levels within the Azure hierarchy.

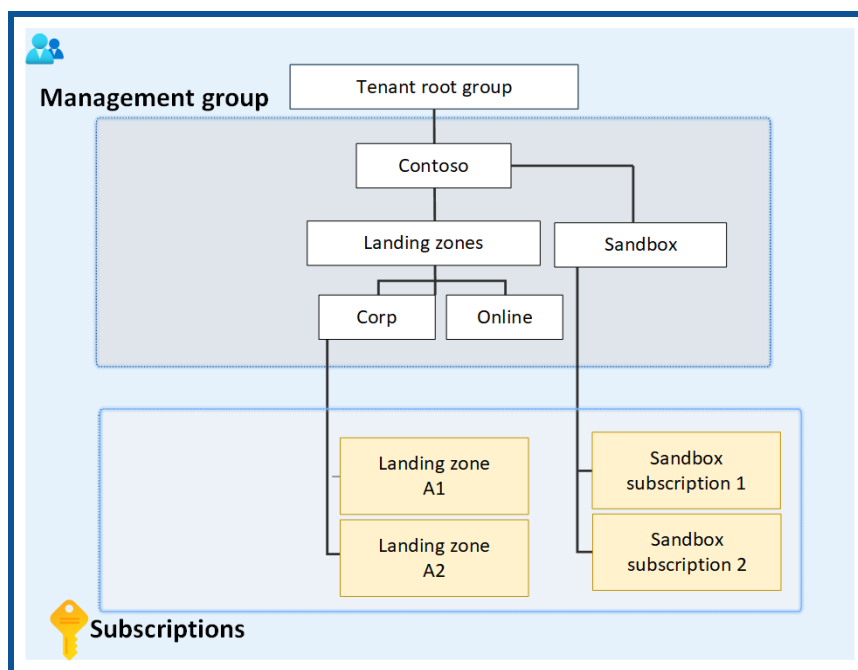
Scopes in Azure RBAC:



[Source: Microsoft Documentation]

RBAC operates at different scopes, each serving a distinct purpose:

1. **Management Groups:** Management groups provide a way to manage access, policies, and compliance across multiple subscriptions. Configuring role permissions at this level ensures consistent governance throughout your Azure hierarchy.
2. **Subscriptions:** Subscriptions represent agreements with Microsoft to use Azure services. Role assignments at the subscription level help delegate responsibilities and control actions within a specific subscription.
3. **Resource Groups:** Resource groups are logical containers for resources deployed within a subscription. Configuring role permissions at the resource group level allows granular control over access to specific sets of resources.



[Source: Microsoft Documentation]

4. **Resources:** Resources include various Azure services like virtual machines, databases, or storage accounts. Configuring role permissions at the resource level provides fine-tuned control over who can interact with a particular resource.

RBAC Roles:

Azure provides several built-in roles catering to different levels of access.

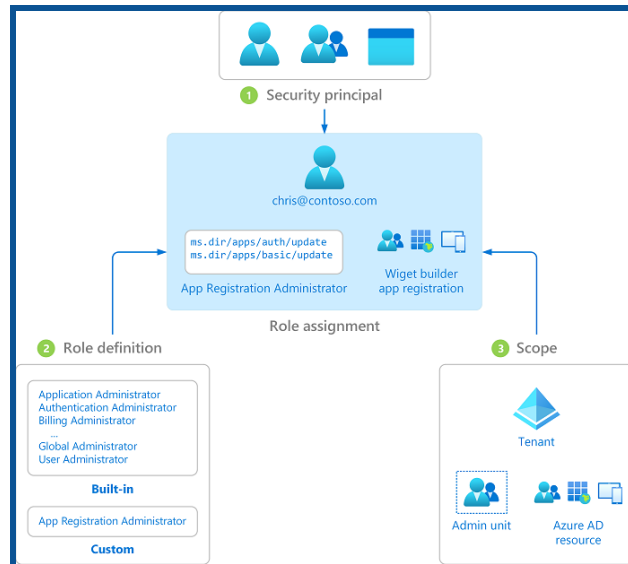
Below are some key roles that included in RBAC:

- **Owner:** Have full access to all resources and can delegate access to others.
- **Contributor:** can create & manage all types of Azure resources, but can't grant access to others.
- **Reader:** Readers can view resources but cannot make any changes.
- **Custom Roles:** Azure allows the creation of custom roles to meet specific business needs, providing flexibility in access control.

Assign Microsoft Entra built-in roles

Microsoft Entra ID supports two types of role definitions: Built-in roles & Custom roles.

Microsoft Entra roles are used to manage Microsoft Entra resources in a directory, such as creating or editing users, delegating administrative roles, resetting user passwords, managing user licenses, and managing domains.



[Source: Microsoft Documentation]

Assign Azure built-in roles

You can assign various Azure built-in roles to users, groups, service principals, and managed identities through Azure role-based access control, or Azure RBAC. You can manage who has access to Azure resources by assigning roles.



[Source: Microsoft Documentation]

Create and assign custom roles [Azure roles and Microsoft Entra roles]

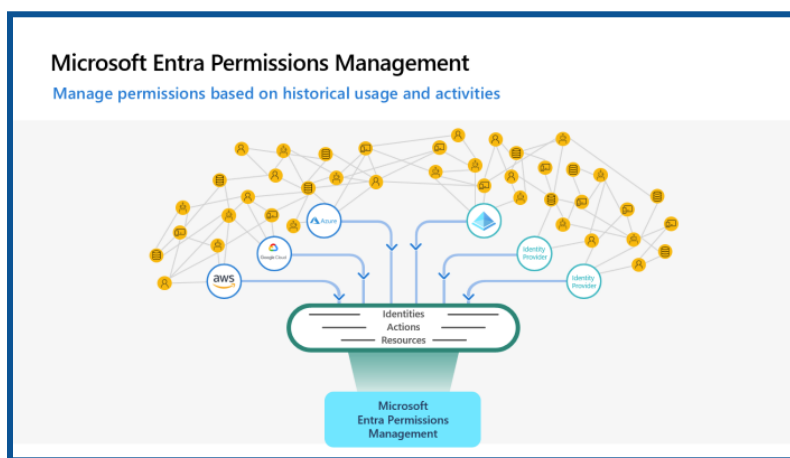
- **Azure Roles:** Azure uses role-based access control (RBAC) to manage access to resources. Roles define permissions, and assigning those roles to users or groups grants them the associated permissions.
 - **Microsoft Entra Roles:** Microsoft Entra roles allow you to grant granular permissions to your administrators, adhering to the principle of least privilege. Microsoft Entra's built-in and custom roles operate on concepts similar to those you find in the role-based access control system for Azure resources (Azure Roles).
 - **Built-in Azure Roles:** Owner, Contributor, and Reader.
 - Owner:** Full access to all resources, including the right to delegate access to others.
 - Contributor:** Can create and manage resources, but cannot grant permissions to others.
 - Reader:** View-only access to resources.
 - **Custom Azure Roles:** Organizations often have specific needs not covered by built-in roles. Custom roles allow the definition of fine-grained permissions tailored to specific tasks. Components of a custom role include actions, notations, and assignableScopes.
- Source Links:

[Create custom roles in Microsoft Entra role-based access control](#)

[Create or update Azure custom roles using the Azure portal - Azure RBAC](#)

Implement and manage Microsoft Entra Permissions Management

Microsoft Entra Permissions Management is a crucial component in ensuring secure and controlled access to resources within the cloud ecosystem.



[Source: Microsoft Documentation]

With Microsoft Entra Permissions Management, your organization can adopt a new, dynamic approach to managing identities and permissions in multi-cloud environments.

Permissions Management allows you to address three key use cases in securing and managing identity permissions in cloud environments: discover, remediate, and monitor.



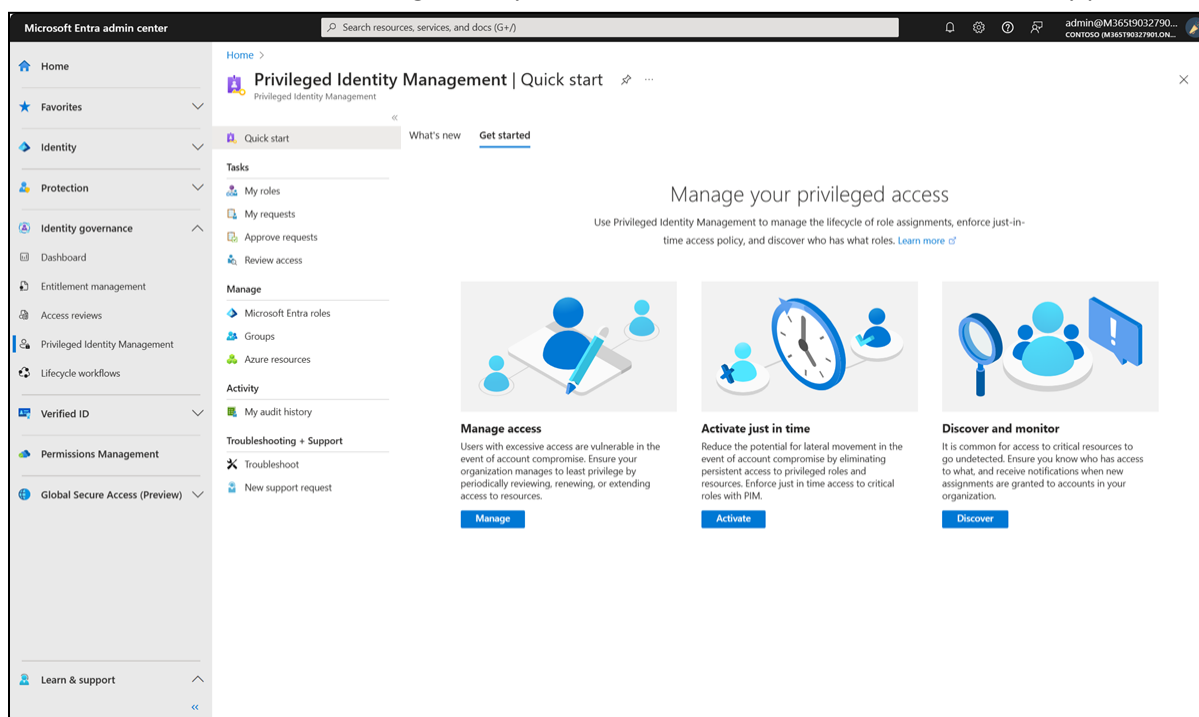
[Source: Microsoft Documentation]

Configure Microsoft Entra Privileged Identity Management

Privileged Identity Management:

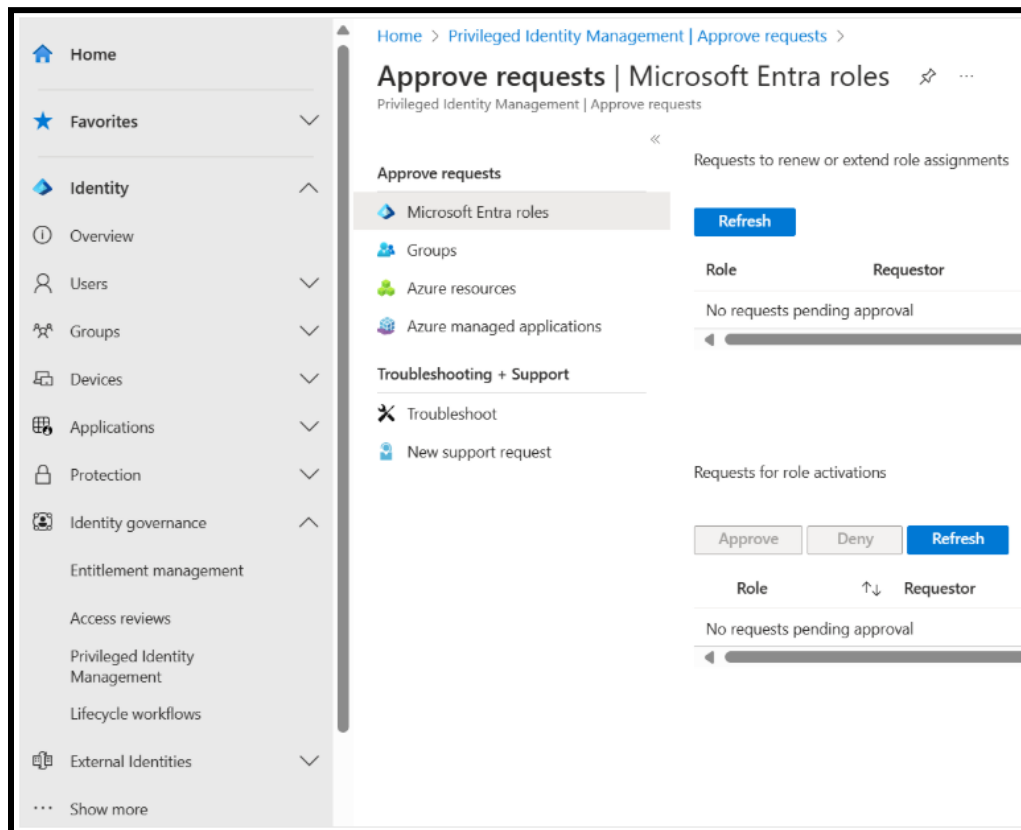
Privileged Identity Management (PIM) is a service in Microsoft Entra ID that enables you to manage, control, and monitor access to critical resources in your organization. These resources include resources from Microsoft Entra ID, Azure, and other Microsoft online services such as Microsoft 365 or Microsoft Intune.

Privileged Identity Management (PIM) helps organizations manage, control, and monitor privileged access to Azure resources, reducing security risks associated with excessive or unnecessary permissions.



1. Overview of Microsoft Entra PIM

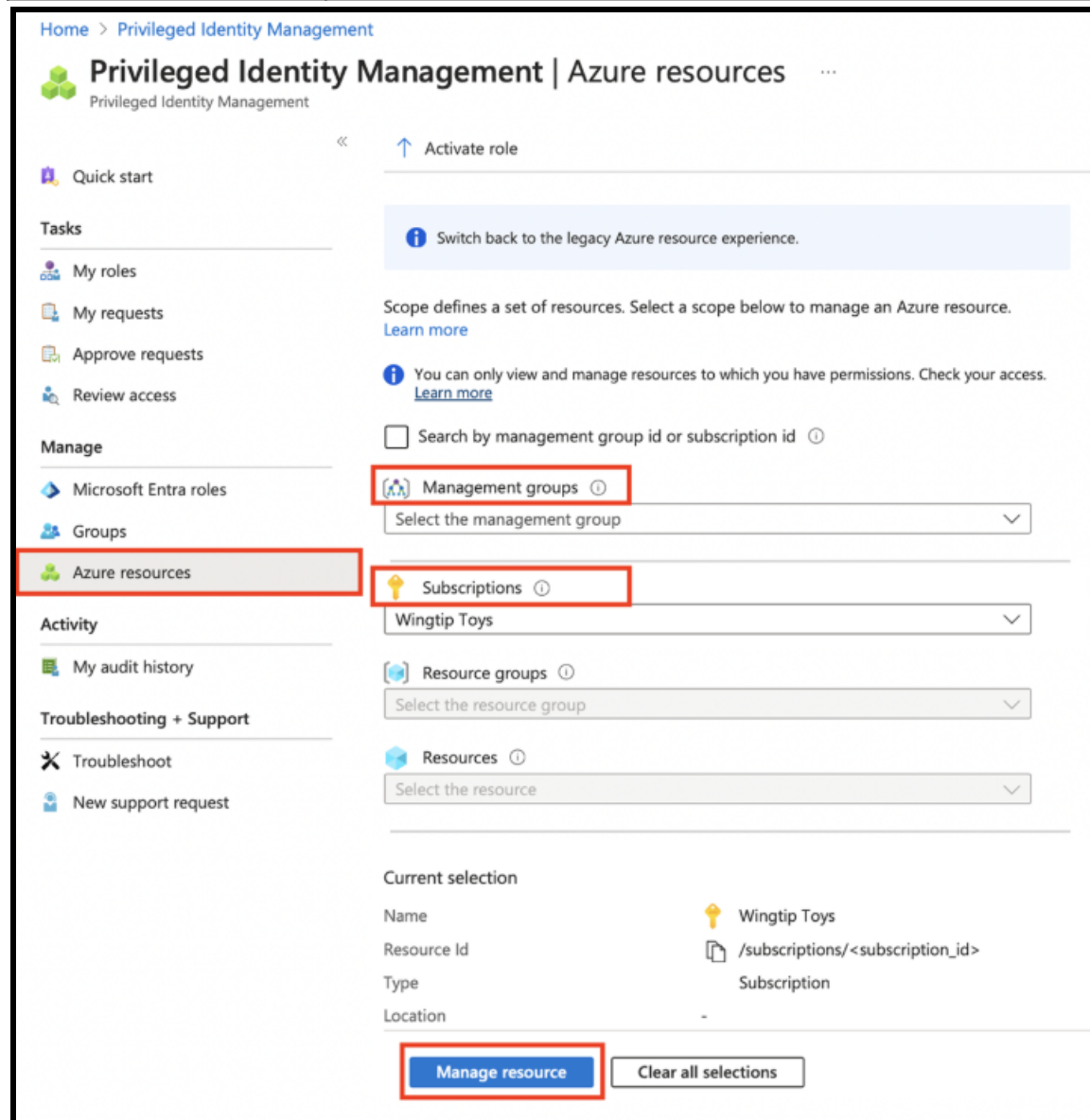
Feature	Description
Just-in-Time (JIT) Access	Users can activate privileged roles only when needed, reducing standing permissions.
Role Assignments	Assign eligible or active roles with time-bound access.
Approval Workflows	Require approval before activating certain privileged roles.
Multi-Factor Authentication (MFA)	Enforce MFA for role activation to enhance security.
Access Reviews	Periodically review role assignments to ensure the least privileged access.
Audit & Monitoring	Track activations and generate logs for compliance.



2. Steps to Plan and Manage Azure Resources in PIM

Step 1: Configure PIM Settings

Setting	Description
Role Activation Policy	Define conditions for role activation, such as requiring justification or MFA.
Approval Requirements	Specify whether role activation requires approval from an administrator.
Notification Settings	Enable alerts for role activations to track usage.



Home > Privileged Identity Management

Privileged Identity Management | Azure resources

Privileged Identity Management

Quick start

Tasks

- My roles
- My requests
- Approve requests
- Review access

Manage

- Microsoft Entra roles
- Groups
- Azure resources**

Activity

- My audit history

Troubleshooting + Support

- Troubleshoot
- New support request

Activate role

Switch back to the legacy Azure resource experience.

Scope defines a set of resources. Select a scope below to manage an Azure resource. [Learn more](#)

You can only view and manage resources to which you have permissions. Check your access. [Learn more](#)

☐ Search by management group id or subscription id ⓘ

Management groups ⓘ

Select the management group

Subscriptions ⓘ

Wingtip Toys

Resource groups ⓘ

Select the resource group

Resources ⓘ

Select the resource

Current selection

Name	Wingtip Toys
Resource Id	/subscriptions/<subscription_id>
Type	Subscription
Location	-

Manage resource Clear all selections

Step 2: Assign and Manage Role Eligibility

Role Type	Purpose
Eligible Role	User can activate the role when needed but does not have standing access.
Permanent Active Role	User has continuous access to the role without activation.
Time-Bound Role	Role is assigned for a specific duration and automatically expires.

Step 3: Implement Just-in-Time (JIT) Access

Feature	Functionality
Time-Limited Access	Users can activate roles for a set duration.
Approval Workflows	Require admin approval for high-privilege roles.
MFA Enforcement	Enforce multi-factor authentication for security.

Step 4: Monitor and Review Access

Monitoring Tool	Purpose
Access Reviews	Schedule periodic reviews of privileged roles.
Audit Logs	Track role activations and access patterns.
Alerts & Notifications	Get alerts for unusual role activations.

→ Features of Privileged Identity Management

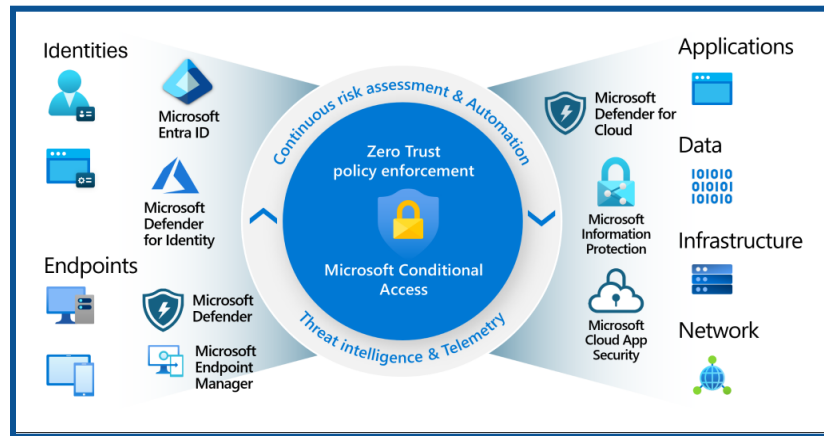
- ◆ Provides timely privileged access to Microsoft Entra ID and Azure resources
- ◆ Specify timed access to resources using start and end dates
- ◆ Approval is required to activate privileged roles
- ◆ Enforce multi-factor authentication to activate any role
- ◆ Use rationale to understand why users are active
- ◆ Receive notifications when privileged roles are activated
- ◆ Conduct access reviews to make sure users still need the roles
- ◆ Download audit history for internal or external audits

Implement Conditional Access Policies

What is Conditional Access?

- Conditional Access is a security technique that limits access to resources or information based on specific conditions or criteria.
- Rather than giving unrestricted access to everyone, this method enables organizations to establish certain rules or standards that individuals must follow before being admitted.
- These conditions may include user roles, device compliance, location, or access time.

- Conditional access improves security by adjusting permissions based on established conditions, ensuring that only authorized users can access critical data or systems under specified circumstances.



Source: [What is Conditional Access in Microsoft Entra ID?](#)

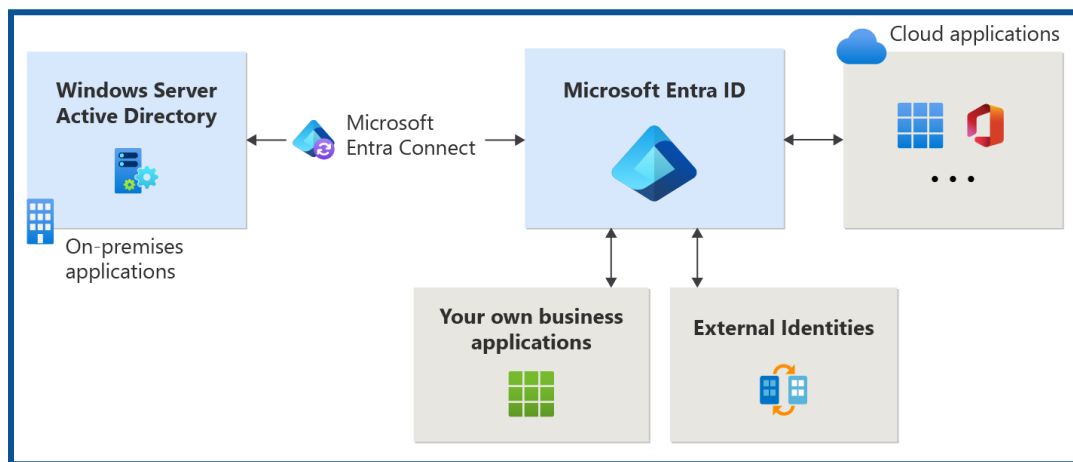
- ❖ Conditional Access is found in the Microsoft Entra admin center under **Protection > Conditional Access**.

Microsoft Entra Application Access

Manage access to enterprise applications in Microsoft Entra ID, includes OAuth permission grants

What is Application Management?

- Application management in Microsoft Entra ID refers to the creation, configuration, management, and monitoring of cloud-based applications.
- Authorized users can access an application securely if it is registered with a Microsoft Entra tenant.
- Many different types of applications can be registered in Microsoft Entra ID.

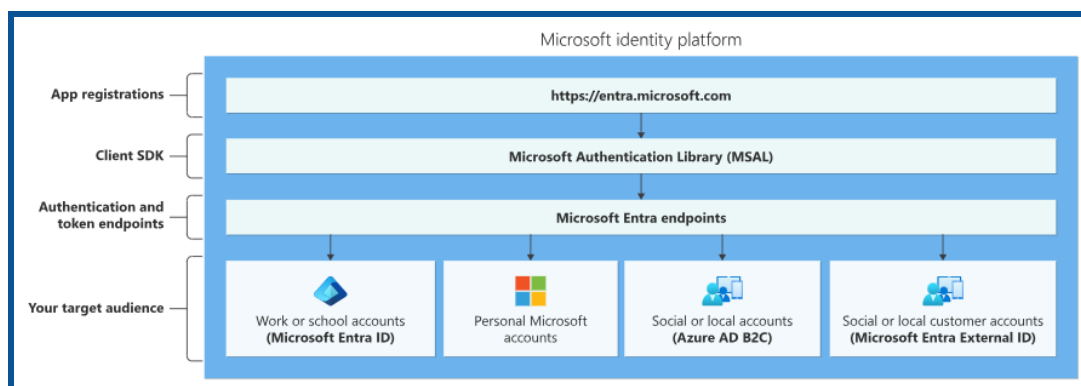


Source: [What is application management? - Microsoft Entra ID](#)

- Applications configured for federated single sign-on (SSO) with SAML-based authentication
- Application proxy applications that use Microsoft Entra Pre-Authentication
- Applications that are built on the Microsoft Entra Application Platform use OAuth 2.0/OpenID Connect authentication after a user or administrator has provided consent for that application.
- Some enterprise applications offer more control over who is allowed to sign in.

Manage Microsoft Entra app registrations

- When you register a new app with Microsoft Entra ID, a service principal is automatically created for the app registration.
- The service principal is the identity of the app in the Microsoft Entra tenant. Access to resources is restricted by roles assigned to the service principal, giving you control over which resources can be accessed and at what level.
- For security reasons, it is always recommended to use service principals with automated tools rather than allowing them to sign in with user credentials.



[Source: Microsoft Documentation]

Configure app registration permission scopes

- By registering your Web API and exposing it through scopes, assigning an owner and app role, you can provide permissions-based access to its resources to authorized users and client apps accessing your API.
- Roles and access scopes must be configured to access APIs. Set up roles and access scopes for your resource application web APIs if you wish to make them available to client applications. Set up permissions for a client application to access the web API during app registration if you want it to do so.
- The Microsoft identity platform must first register your web API before you can grant scoped access to its resources.

Manage app registration permission consent

- Managing app registration permission consent involves overseeing the process by which users grant or deny permission for an application to access their data or perform certain actions.
- This includes designing user interfaces that present permission requests, ensuring compliance with privacy regulations, such as GDPR or CCPA, tracking and storing consent preferences, and providing users with options to modify or revoke their consent settings as needed.
- Effective management of app registration permission consent is crucial for maintaining user trust and adhering to legal requirements regarding data privacy and security.

Types of Permissions

1. **Delegated permissions** are used in the Delegated Access scenario. They are permissions that allow applications to act on behalf of the user.

The application will never be able to access anything that the signed-in user could not access himself. For example, imagine an application that has been granted the `Files.Read.All` delegated permission on behalf of the user, Tom.

The application will only be able to read files that Tom can personally access

2. **Application permissions**, sometimes called app roles, are used in the app-only scenario, without a signed-in user present. The application will be able to access any data that the permission is associated with. For example, an application granted the Files.Read.All application permissions will allow you to read any file in the tenant. Only an administrator or owner of the service principal can consent to application permissions.

Manage and use service principals

If you register an application, an Application object and a Service Principal object are automatically created in your home tenant. If you register/create an application using the Microsoft Graph API, creating a service principal object is a separate step.

Service principal object

- To access resources protected by a Microsoft Entra tenant, the entity that requires access must be represented by a security principal.
- This requirement applies to users (user principals) and applications (service principals).
- The security principal defines the access policy and permissions for the user or application in the Microsoft Entra tenant.
- It enables core features such as authentication of the user or application during sign-in and authorization during resource access.

There are three types of service principals:

1. Application
2. Managed identity
3. Legacy

Manage managed identities for Azure resources

- Managed Identity Microsoft Entra automatically assigns a managed identity, the Microsoft Entra ID, to applications to use when connecting to resources that support authentication.
- Applications can use managed identity to obtain a Microsoft Entra token without managing any credentials.

There are two types of managed identities:

1. System-assigned
2. User-assigned

Benefits of using Managed Identities

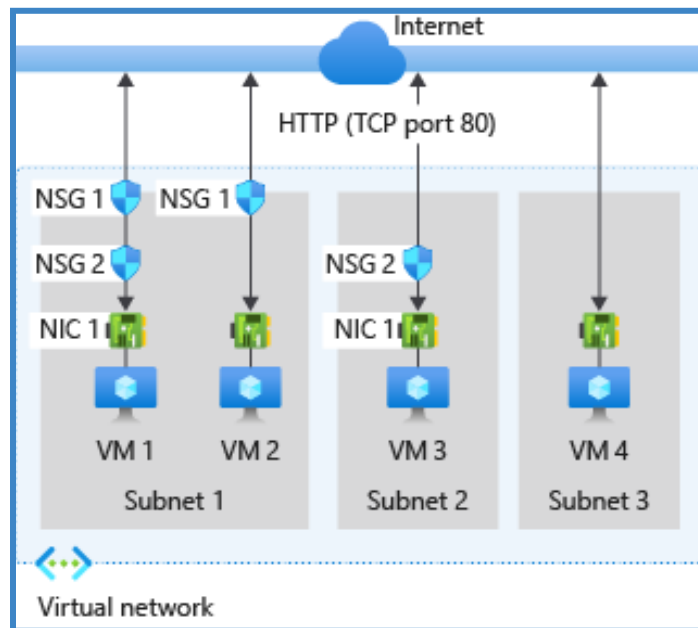
- Keeping track of credentials is not required. Credentials are inaccessible to you.
- Managed identities can authenticate against any resource that supports Microsoft Entra authentication, including your applications.
- Managed identities are free to use.

Secure networking

Plan and implement security for virtual networks

Network Security Groups (NSGs):

- A network security group contains security rules that allow or deny inbound network traffic or outbound network traffic from multiple types of Azure resources.
- For each rule, you can specify the source and destination, port, and protocol.
- NSG controls inbound and outbound traffic.
- The rules are like traffic rules for data packets.

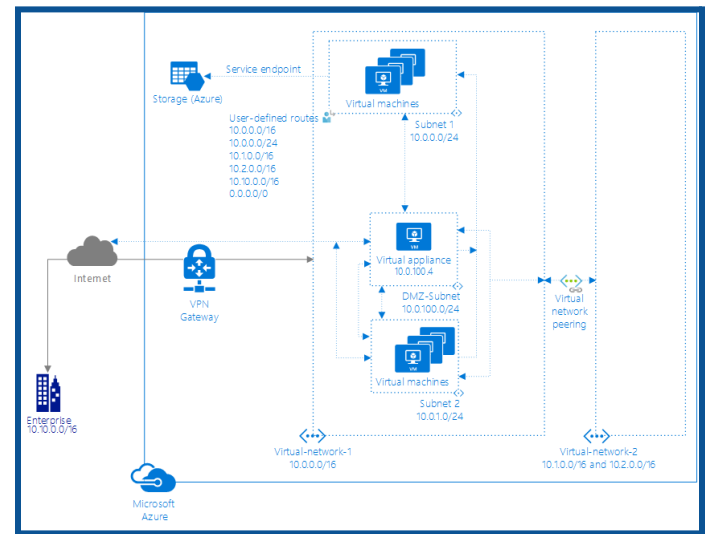
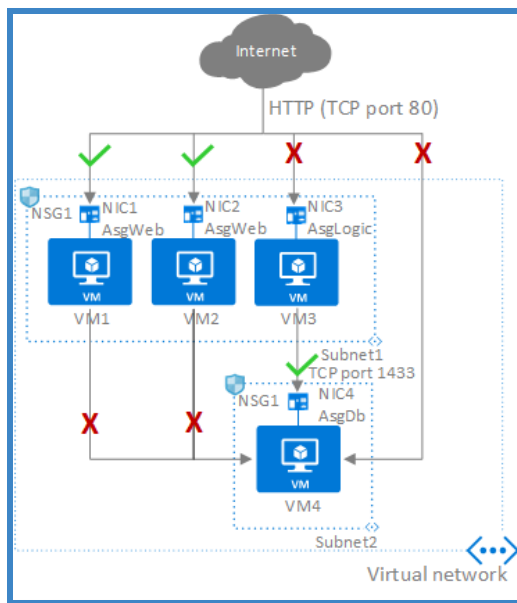


[Source: Microsoft Documentation]

Application Security Groups (ASGs):

- It enables you to configure network security as a natural extension of an application's structure, allowing you to group virtual machines and define network security policies based on those groups.
- You can reuse your security policy at scale without manual maintenance of explicit IP addresses.
- ASGs organize security rules based on applications.
- This grouping makes it easier to manage and apply rules to required applications.

[Source: Microsoft Documentation]



[Source: Microsoft Documentation]

Inbound and Outbound Security Rules:

- NSG defines both inbound and outbound security rules. Inbound rules control traffic coming into the resource, while outbound rules control traffic leaving the resource.
- Specific rules can be created for different scenarios, such as allowing SSH traffic for administration while preventing unauthorized access.
- Inbound rules control incoming traffic.
- Outbound rules manage outgoing traffic.

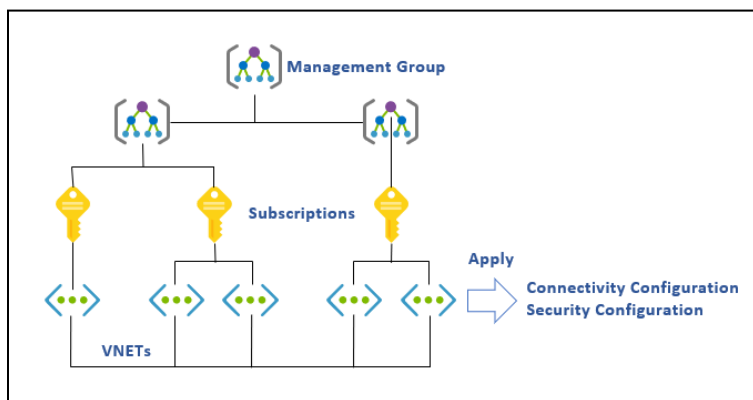
Plan and implement user-defined routes (UDRs)

User-Defined Routes (UDRs):

- User-Defined Routes (UDRs) play a pivotal role in shaping the flow of network traffic.
- Essentially, UDRs allow users to customize and define the paths that data takes within a virtual network.
- UDRs enable users to exert control over the routing decisions within a virtual network.
- By defining specific routes, users can optimize traffic flow, enhance network performance, and bolster security measures.

Azure Virtual Network Manager (AVNM)

Azure Virtual Network Manager (AVNM) is a centralized management solution that enables organizations to efficiently configure, monitor, and secure their virtual networks at scale. It simplifies network management by allowing users to apply **global policies, security rules, and connectivity configurations** across multiple virtual networks in an Azure environment.



Source: [What is Azure Virtual Network Manager? | Microsoft Learn](#)

Key Features of AVNM:

1. **Centralized Network Management** – Manage multiple virtual networks across different regions from a single interface.
2. **Automated Connectivity** – Establish seamless communication between virtual networks using mesh or hub-and-spoke topologies.
3. **Security and Compliance** – Apply security rules and policies across networks to enforce compliance.
4. **Policy-Based Management** – Define and deploy network policies without manually configuring each virtual network.
5. **Scalability** – Simplifies large-scale network management for enterprises with multiple Azure subscriptions.

By using Azure Virtual Network Manager, organizations can streamline **network operations**, **improve security posture**, and **enhance connectivity** across their cloud infrastructure.

How to manage virtual networks using Azure Virtual Network Manager

Feature	Description
Group Networks	Create network groups to organize and manage multiple virtual networks collectively.
Define Connectivity	Establish connectivity rules to define how network traffic should flow between virtual networks.
Apply Security Policies	Enforce security policies consistently across all managed networks for compliance and threat protection.
Deploy Configurations	Consistently apply network and security settings to all virtual networks within a group.
Monitor and Update	Track network performance, make adjustments, and ensure security over time.

Plan and implement Virtual Network Peering/VPN gateway

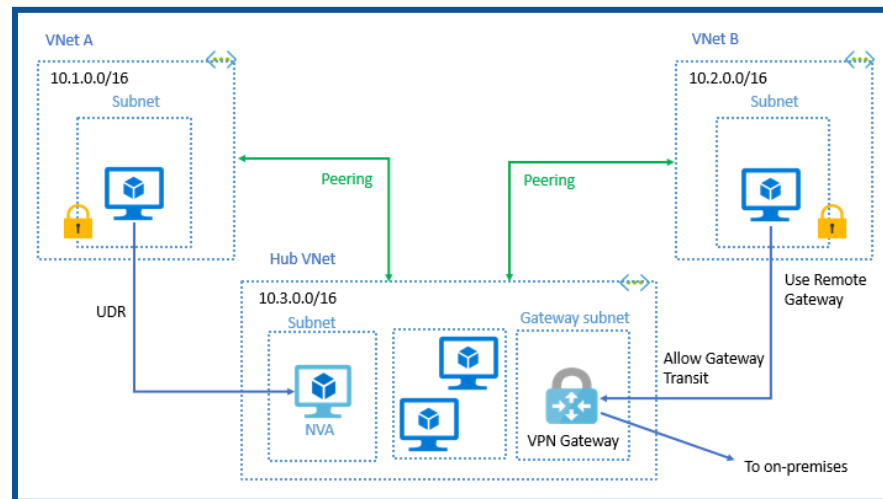
Virtual Network Peering:

- It enables you to seamlessly connect two or more virtual networks in Azure.
- It appear as one for connectivity purposes. Traffic between virtual machines in peer-to-peer virtual networks uses the Microsoft Backbone infrastructure.
- Like traffic between virtual machines on the same network, the traffic is routed only through Microsoft's private network.

Azure supports the following types of peering:

- Virtual network peering: connecting virtual networks within the same Azure region.
- Global virtual network peering: connecting virtual networks across Azure regions.

Item	Virtual network peering	VPN Gateway
Limits	Offers up to 500 virtual network peerings per virtual network	Offers up to one VPN gateway per virtual network. The maximum number of tunnels per gateway depends on the gateway SKU.
Pricing model	Ingress/Egress	Hourly + Egress
Encryption	Software-level encryption	A custom IPsec/IKE policy can be applied to new or existing connections.
Bandwidth limitations	There are no bandwidth limitations.	Varies based on SKU.
Private	Yes. Routed through the Microsoft backbone and private. No public internet is involved.	Public IP is involved but routed through the Microsoft backbone if the Microsoft global network is enabled.
Transitive relationship	Peering connections are non-transitive. Transitive networking can be achieved using NVAs or gateways in the hub virtual network.	If virtual networks are connected via VPN, gateways, and BGP is enabled in the virtual network connections, transitivity works.
Initial setup time	Fast	~30 minutes



[Source: Microsoft Documentation]

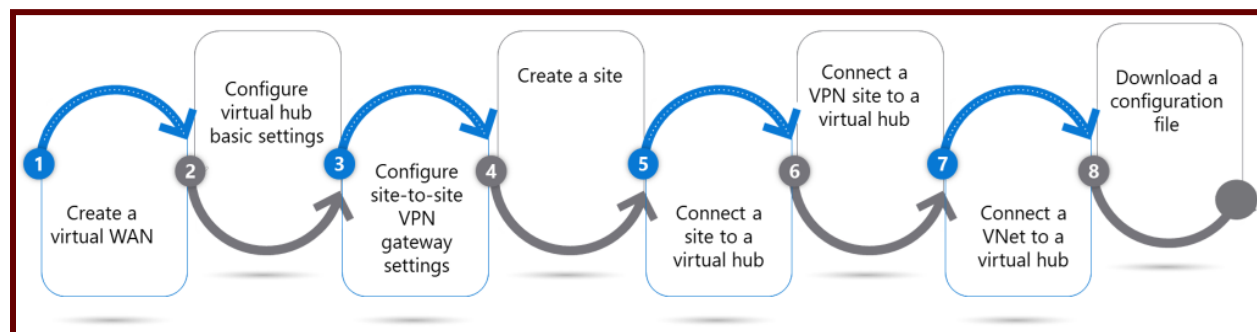
VPN Gateway:

- Azure VPN Gateway is a service that uses a specific type of virtual network gateway to send encrypted traffic between the Azure virtual network and on-premises locations over the public Internet.
- You can also use a VPN gateway to send encrypted traffic between Azure virtual networks and Microsoft networks.
- Multiple connections can be made to the same VPN gateway.
- When you create multiple connections, all VPN tunnels share the available gateway bandwidth.

Plan and implement Virtual WAN, including a secured virtual hub

What is a virtual WAN?

A virtual WAN is a collection of hubs and services provided inside a hub. The user can deploy as many virtual WANs as needed. Virtual WAN Hub has many services like VPN, ExpressRoute, etc.



[Source: Microsoft Documentation]

What is a Secured Virtual hub?

- A secure virtual hub is an Azure virtual WAN hub with associated security and routing policies configured by Azure Firewall Manager.
- Use Secure Virtual Hubs to easily create hub-and-spoke and transitive architectures with native security services for traffic administration and security.
- Multiple secure hubs can be deployed in the same region or in different regions of the same virtual WAN resource.

Secure VPN connectivity, including point-to-site and site-to-site

What is the Azure VPN Gateway?

A VPN gateway is a type of virtual network gateway.

A virtual network gateway is composed of two or more Azure-managed VMs that are automatically configured and deployed on a specific subnet you create called a *GatewaySubnet*. Gateway VMs contain routing tables and run specific gateway services.

1. Point-to-site VPN

- Point-to-site (P2S) VPN gateway connections let you create a secure connection to your virtual network from an individual client computer.
- A P2S connection is established starting from the client's computer. This solution is useful for telecommuters who want to connect to Azure VNets from a remote location, such as a home or a conference.
- Using a P2S VPN instead of a S2S VPN is also a useful solution when you only have a few clients that need to connect to the VNet.

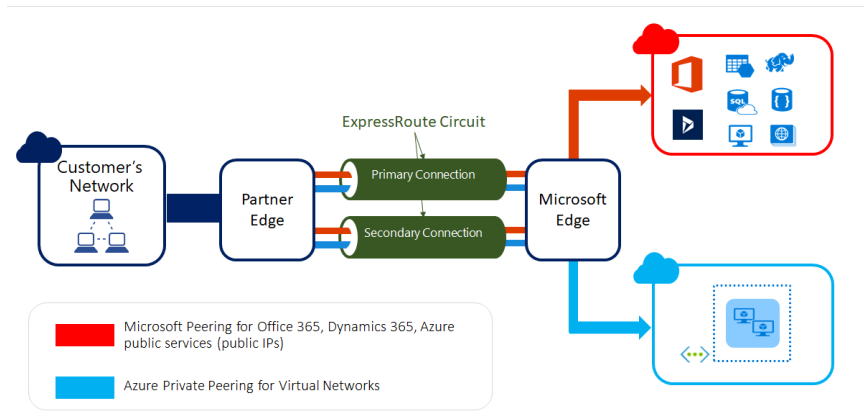
2. Site-to-site VPN

- A site-to-site (S2S) VPN gateway connection is a connection over an IPsec/IKE (IKEv1 or IKEv2) VPN tunnel.
- S2S connections can be used for cross-premises and hybrid configurations.
- S2S connections require a VPN device located on the premises that has been assigned a public IP address.

Implement encryption over ExpressRoute

What is ExpressRoute?

ExpressRoute is an Azure service that lets you create private connections between Microsoft data centers and infrastructure located on your premises or in a co-location facility.



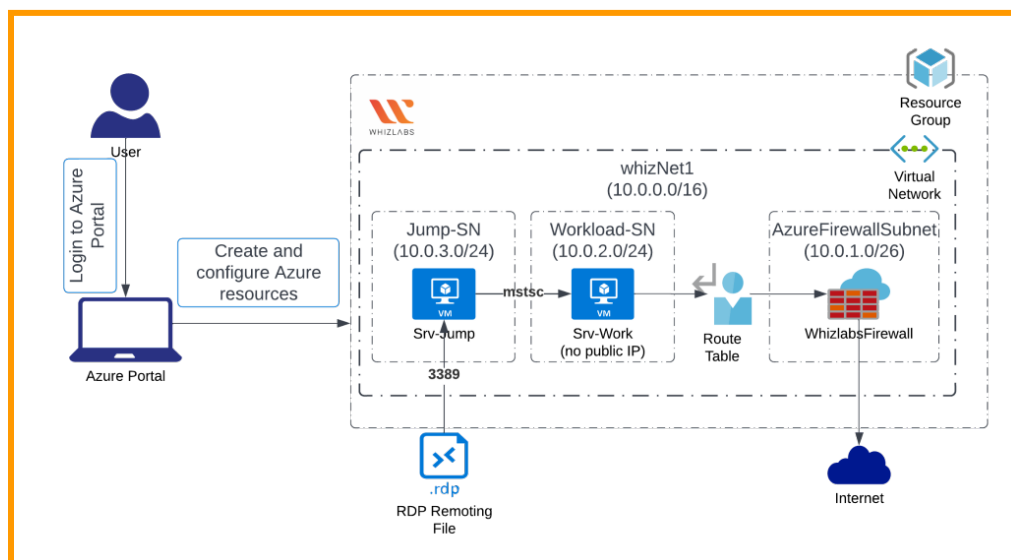
[Source: Microsoft Documentation]

Configure firewall settings on PaaS resources

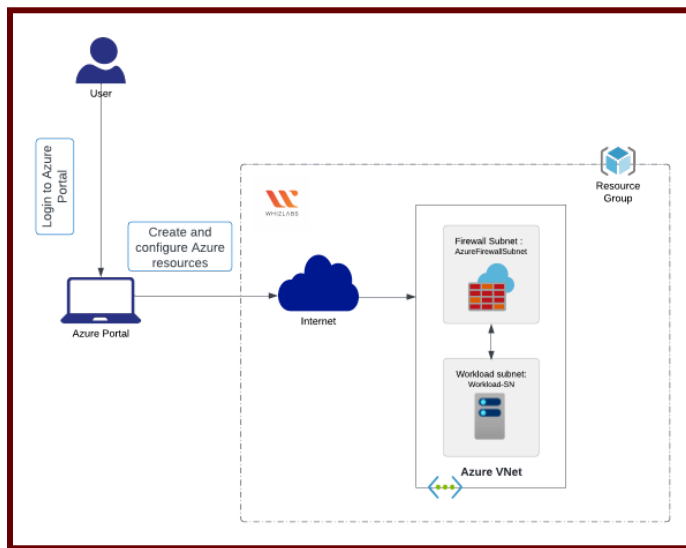
What is the Microsoft Azure Firewall service?

- A completely managed cloud-based network security solution is an Azure Firewall.
- It can be applied to safeguard your Azure Virtual Network resources.
- This service allows you to set up and manage application and network connectivity policies.
- Depending on demand, this service can automatically scale up.
- It is employed to regulate network access leaving an Azure subnet.

Architecture Diagram



- PaaS resources include the **Azure SQL database**, which is a fully managed platform as a service (PaaS) database engine that handles most database management tasks such as upgrades, patching, backups, and monitoring without user involvement.
- Firewall rules can provide access to logical SQL servers, single databases, and elastic pools and their databases.
- Firewall rules are also required to connect on-premises and other Azure resources to the database.
- Server-level firewall rules do not apply to Azure SQL Managed Instances.



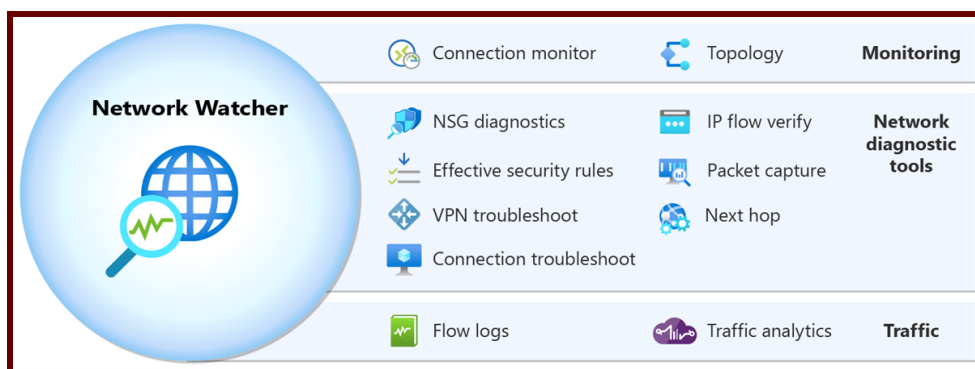
Network Security Monitoring

What is the Azure Network Watcher?

Azure Network Watcher offers a set of tools for monitoring, diagnosing, viewing metrics, and enabling or disabling logs for Azure IaaS (Infrastructure as a-Service) resources.

Network Watcher lets you monitor and repair the network health of IaaS products like Virtual Machines (VMs), Virtual Networks (VNETs), Application Gateways, Load Balancers, and more.

- ❖ Network Watcher includes three major sets of tools and capabilities:
 - Monitoring
 - Network Diagnostic tools
 - Traffic
- ❖ **Flow logs:** Flow Logs lets you log information about your Azure IP traffic and store the data in Azure storage.



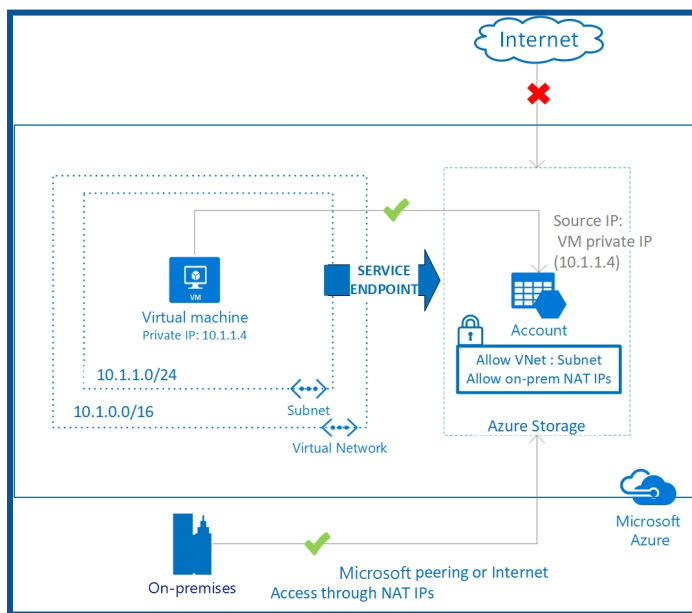
[Source: Microsoft Documentation]

An Azure Network Watcher feature called "network security group flow logging" lets you record IP traffic passing through a network security group.

Plan and implement Security for private access to Azure resources

Plan and implement virtual network Service Endpoints

Virtual Network (VNET) service endpoints provide secure and direct connectivity to Azure services over an optimized route over the Azure Backbone network. Endpoints allow you to secure your critical Azure service resources only on your virtual network. Service Endpoint enables private IP addresses in a VNet to reach an Azure service endpoint without requiring a public IP address on the VNet.



[Source: Microsoft Documentation]

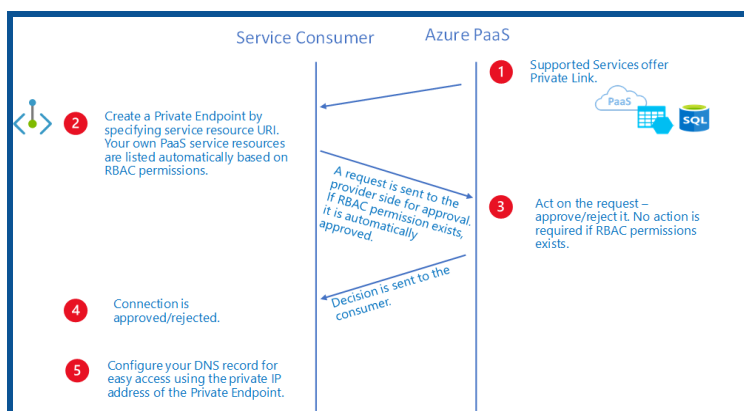
Advantages:

Service endpoints provide the following benefits:

- Better security for your Azure service resources
- Optimal routing for Azure service traffic from your virtual network
- Easy to set up with low management overhead

Plan and implement Private Endpoints

The private endpoint is a network interface that uses a private IP address from your virtual network. This network interface connects you privately and securely to the service that Azure Private Link powers. By enabling a private endpoint, you are bringing the service into your virtual network.



[Source: Microsoft Documentation]

That service can be an Azure service, like:

1. Azure storage
2. Azure Cosmos DB
3. Azure SQL Database
4. Your service is using the Private Link service.

❖ When you're creating private endpoints, consider the following:

→ Private endpoints enable connectivity between clients:

- ◆ Virtual Network
- ◆ Regional Peer virtual network
- ◆ Globally Peer Virtual Network
- ◆ On-premises environments that use VPN or ExpressRoute
- ◆ Services powered by Private Link

→ A private-endpoint connection allows a private-link resource owner to:

- ◆ Examine the details of each private endpoint connection.
- ◆ Permit a private endpoint connection. Traffic to the private-link resource can be sent via the corresponding private endpoint.
- ◆ Turn down a connection to a private endpoint. The status is updated on the associated private endpoint.
- ◆ In any state, delete a private endpoint connection.
- ◆ The action is reflected in the corresponding private endpoint, which is updated with a disconnected state. At this point, the resource can only be deleted by the owner of the private endpoint.

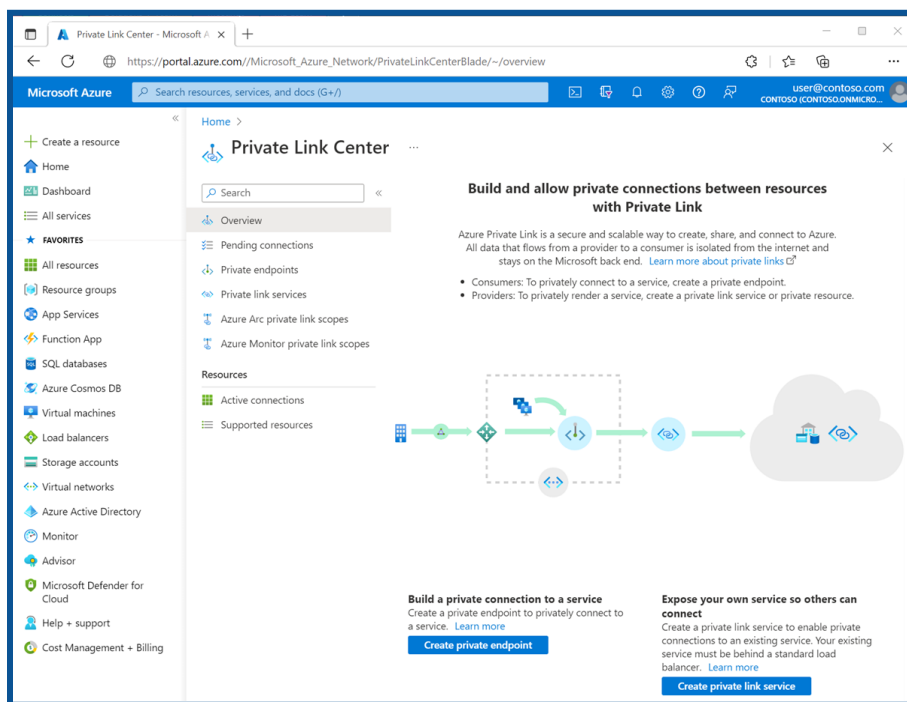
Plan and implement Private Link services

What is an Azure Private Link?

Azure Private Link enables you to access Azure PaaS services (for example, Azure Storage and SQL Database) and customer-owned/partner services hosted by Azure on a private endpoint in your virtual network.

Advantages:

- **Access services privately on the Azure platform:** Using private endpoints, connect your virtual network to all services that can be used as application components in Azure. Service providers can provide their services on their virtual networks, and consumers can access those services on their local virtual networks. The Private Link platform will handle connectivity between consumers and services on the Azure Backbone network.
- **On-premises and peer networks:** Access services running in Azure from on-premises using ExpressRoute private peering, VPN tunnels, and private endpoints. There is no need to configure ExpressRoute Microsoft or cross the Internet to access the service. Private Link provides a secure way to migrate workloads to Azure.



[Source: Microsoft Documentation]

- **Protection against data leakage:** A private endpoint is mapped to an instance of the PaaS resource rather than the entire service. Consumers can connect only to a specific resource. Access to any other resources in the service is blocked. This mechanism protects against the risks of data leakage.

- **Global reach:** Connect privately to services running in other regions. A subscriber's virtual network may be in Area A and connect to services behind a private link in Area B.
- **Extend your services:** Enable the same experience and functionality to privately deliver your service to consumers in Azure. By placing your service behind a standard Azure load balancer, you can enable private links.

The consumer can then connect directly to your service using a private endpoint in their virtual network. You can manage connection requests using the approval call flow. Azure Private Link works for consumers and services belonging to various Microsoft Entra tenants.

Network integration for Azure App Service and Azure Functions

With Azure Virtual Network, you can place multiple of your Azure resources on a non-Internet-routable network.

The App Services Virtual Network integration feature enables your apps to access resources in or through virtual networks.

- There are two forms of app service:
 - ◆ Dedicated compute pricing tiers include Basic, Standard, Premium, Premium v2, and Premium v3.
 - ◆ App Service environment, deployed directly into your virtual network with dedicated supporting infrastructure and using separate and distinct v2 pricing tiers.
- This feature is used in Azure App Service Dedicated Compute pricing tier.
- Virtual network integration gives your app access to resources in your virtual network, but it does not provide inbound private access to your app from the virtual network.
- Feature of Virtual Network Integration:
 - ◆ A supported basic or standard, premium, premium v2, premium v3, or elastic premium app service pricing tier is required.
 - ◆ Supports both TCP and UDP.
 - ◆ Compatible with app service apps, function apps, and logic apps.
- When using virtual network integration, you can use the following Azure networking features:

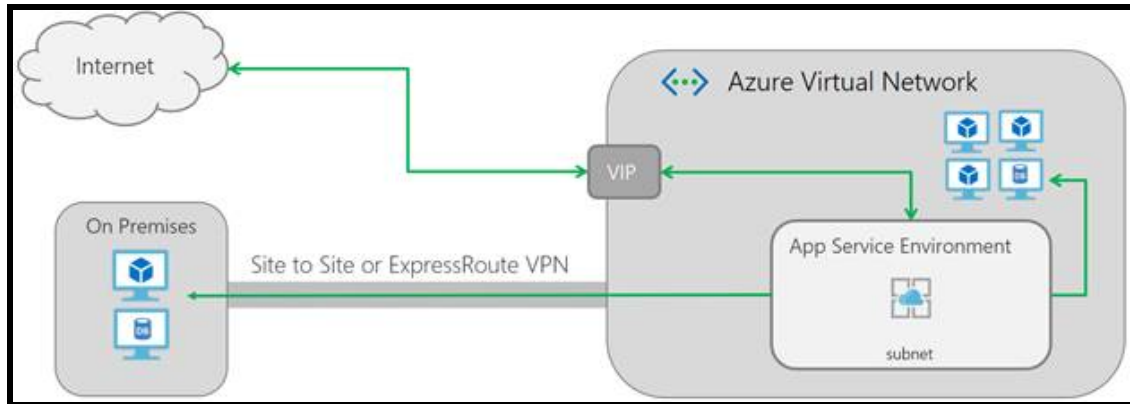
Network Security Groups (NSGs): You can limit outgoing traffic by setting up an NSG on your integration subnet. The inbound rules are not applicable since virtual network integration cannot be used to allow inbound access to your application.

Route tables (UDRs): To direct outgoing traffic to the desired destination, a route table can be placed on the integration subnet.

NAT gateway: To obtain a dedicated outbound IP address and prevent SNAT port exhaustion, you can use a NAT gateway.

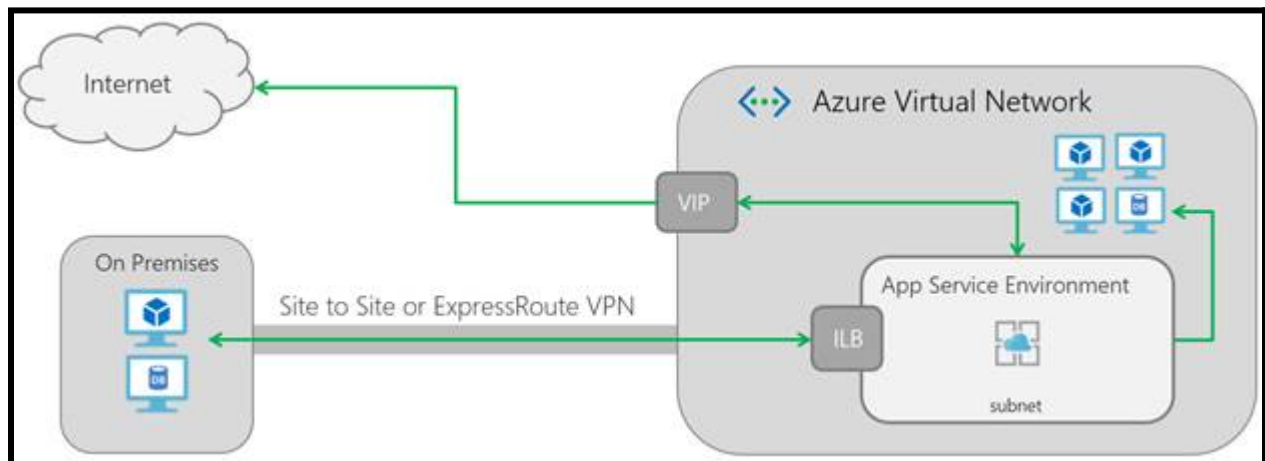
App Service Environment (ASE) - Network Security Configurations

- An App Service environment is a single-tenant deployment of Azure App Service that hosts Windows and Linux containers, web apps, API apps, logic apps, and function apps.
- When you set up an App Service environment, you choose the Azure virtual network on which you want to deploy it.
- All inbound and outbound application traffic occurs inside the virtual network you specify.
- You deploy to a single subnet in your virtual network, and nothing else can be deployed to that subnet.



[Source: Microsoft Documentation]

If you have an App Service environment with external deployment, the public VIP is also the endpoint to which your apps resolve the following: HTTP/S, FTP/S, Web Deployment & Remote Debugging

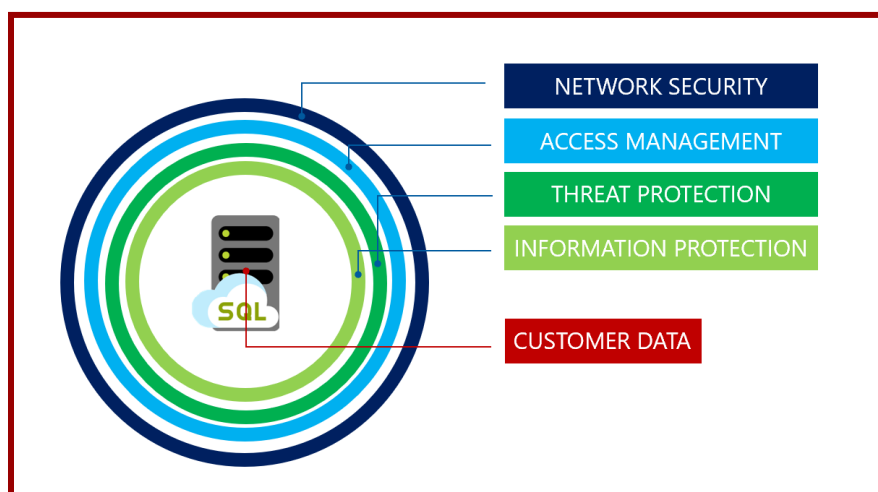


[Source: Microsoft Documentation]

Network security configurations for an Azure SQL Managed Instance

Azure SQL is a family of managed, secure, and intelligent products that use the SQL Server database engine in the Azure cloud.

Azure SQL is built on the familiar SQL Server engine, so you can easily migrate applications and continue to use the tools, languages, and resources you are familiar with.



[Source: Microsoft Documentation]

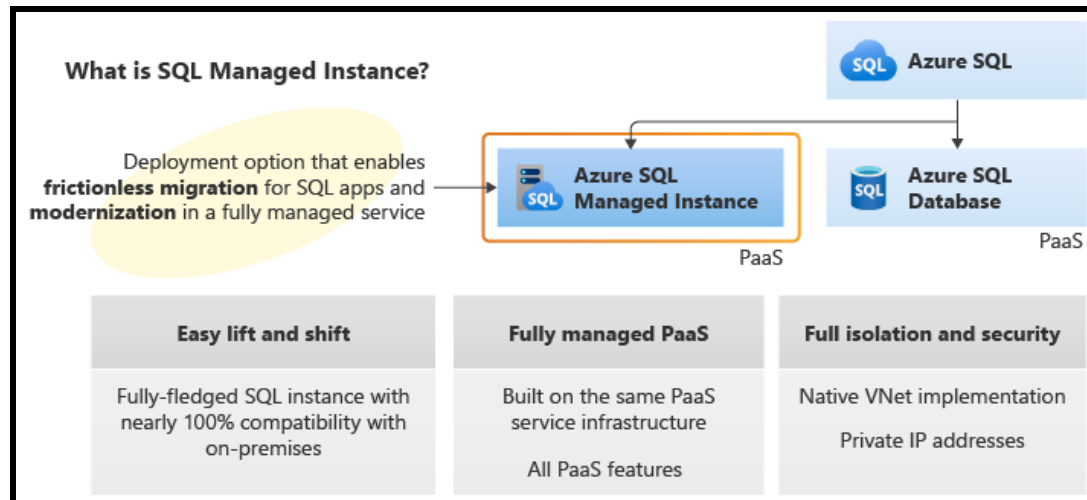
- Microsoft Azure SQL Database, Azure SQL Managed Instance, and Azure Synapse Analytics offer relational database services for cloud and enterprise applications.
- To help protect customer data, firewalls block network access to servers unless explicitly granted access based on IP address or Azure Virtual Network traffic origin.

❖ **Azure SQL Database secures data by allowing you to:**

- Limit access using firewall rules
- Use authentication mechanisms that require identification
- Use authorization with role-based membership and permissions
- Enable security features

What is an Azure SQL Managed Instance?

A fully managed platform as a service (PaaS) database engine that handles most database management tasks such as upgrades, patching, backups, and monitoring without user involvement.



[Source: Microsoft Documentation]

Plan and implement security for public access to Azure resources

Transport Layer Security (TLS) to applications

What does TLS do in App Service?

- Transport Layer Security (TLS) is a widely used security protocol that encrypts connections and communications between servers and clients.
- App Service allows customers to secure incoming requests to their web apps with TLS/SSL certificates.
- App Service currently supports a variety of TLS features to help customers secure their web applications.
- Planning and implementing TLS encryption in Azure applications is essential to ensuring data security in transit.

Here's a six-point summary for enhancing TLS in Azure App Service and API management:

Network segmentation with VNet: Deploy Azure applications, including App Service and API Management, within a private Virtual Network (VNet). Assign private IPs to services, refraining from using public IPs unless explicitly needed.

Network Security Group (NSG) Configuration: Use network security groups to control inbound and outbound traffic. Leverage Azure Virtual Network Service Tags to define access controls on NSGs, ensuring exclusive and secure communication paths.

Take advantage of Azure Private Link: Deploy private endpoints of Azure Private Link to Azure services, and establish a private connectivity mechanism, thus ensuring secure access and data privacy.

Disabling public network access: To strengthen security, ensure that public network access to Azure resources, including Azure SQL Managed Instance, is disabled. Limit access to services through private endpoints or virtual networks.

Centralized Identity Management with Microsoft Entra ID: Implement Microsoft Entra ID authentication for data plane access, ensuring centralized identity management. Limit or avoid the use of local authentication methods primarily changes to Microsoft Entra ID.

Monitor with Microsoft Defender for Cloud: Monitor configurations using Microsoft Defender for the Cloud. Use the built-in Azure policy definitions to ensure best practices are followed, such as provisioning Microsoft Entra IDs.

Plan, implement, and manage an Azure Firewall

Azure Firewall:

It's a cloud-native and intelligent network firewall security service that provides best-of-breed threat protection for your cloud workloads running in Azure. It is a completely stateful firewall as a service with built-in high availability and unrestricted cloud scalability. It provides both east-west and north-south traffic monitoring.

Azure Firewall is offered in three SKUs: Standard, Premium, and Basic.

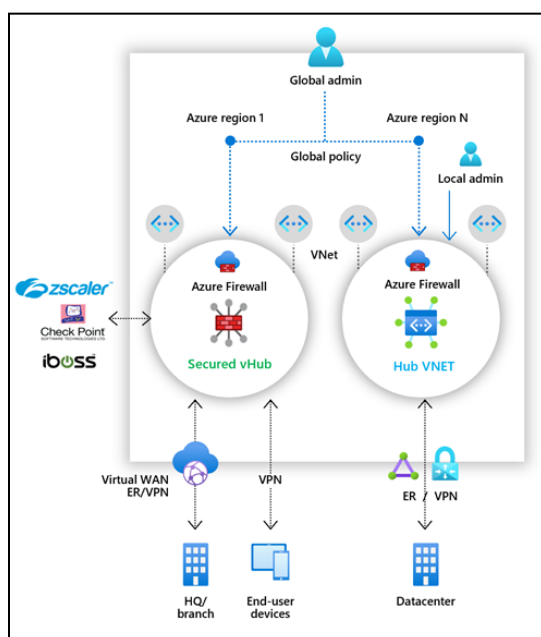
Azure Firewall Manager

Azure Firewall Manager is a security management service that provides centralized security policy and route management for a cloud-based security perimeter.

Firewall Manager can provide security management for two network architecture types:

Secured Virtual Hub: Azure Virtual WAN Hub is a Microsoft-managed resource that lets you easily create hub and spoke architectures. When security and routing policies are associated with such a hub, it is called a secure virtual hub.

Hub Virtual Network: This is a standard Azure virtual network that you create and manage yourself. When security policies are associated with such a hub, it is called a hub virtual network.



[Source: Microsoft Documentation]

Azure Web Application Firewall (WAF) Policy:

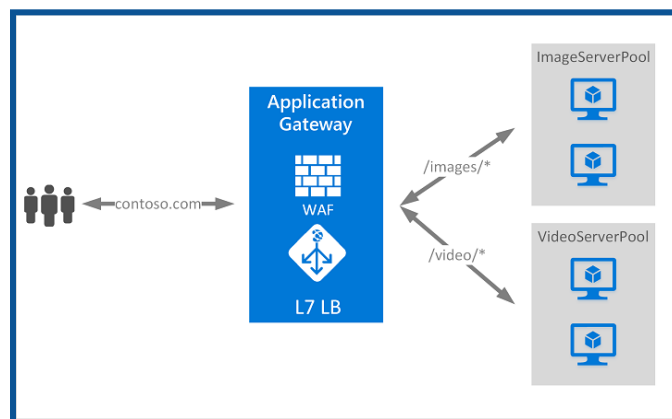
Web Application Firewall policies contain all WAF settings and configurations. This includes exclusions, custom rules, managed rules, etc. These policies are then tied to an application gateway (global), a listener (per-site), or a path-based rule (per-URI) to take effect.

Plan and implement an Azure Application Gateway

What is Azure Application Gateway?

Azure Application Gateway is a web traffic load balancer (OSI Layer 7) that allows you to manage traffic to your web applications.

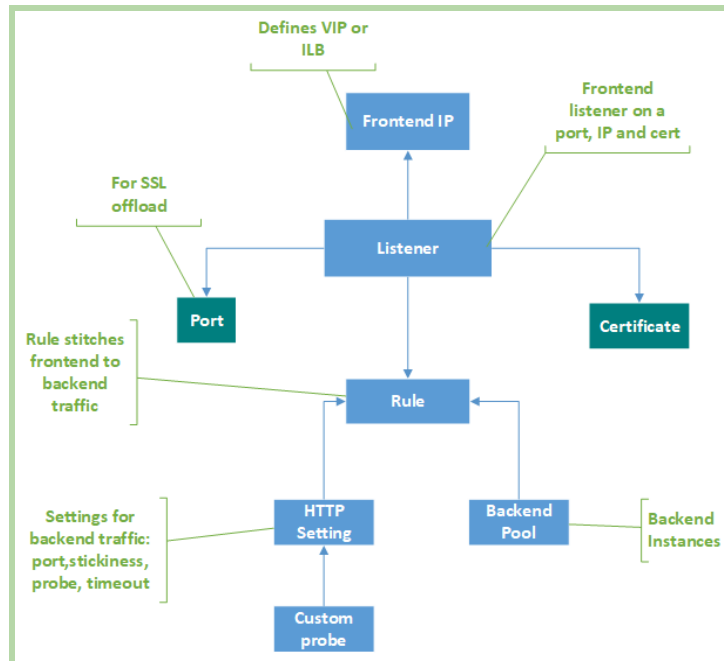
- The Application Gateway may make routing decisions based on additional characteristics of the HTTP request, for example, the URL path or host header.
- For example, you can route traffic based on the incoming URL.
- So if /images are in the incoming URL, you can route the traffic to a specific set of servers (known as a pool) configured for images.
- If /video is in the URL, that traffic is sent to another pool that is optimized for video.



[Source: Microsoft Documentation]

This type of routing is known as application layer (OSI Layer 7) load balancing. Azure Application Gateway can do URL-based routing and more.

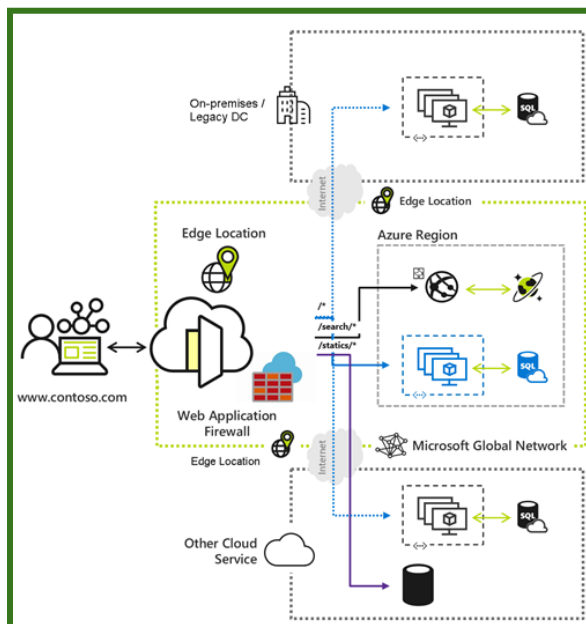
Application Gateway includes the following features: • Secure Sockets Layer (SSL/TLS) termination • Autoscaling • Zone redundancy • Static VIP	Application Gateway Components 1. Frontend IP 2. Listener 3. Port 4. HTTP setting 5. Backend pool 6. Custom Probe 7. Certificate 8. Rule
---	---



[Source: Microsoft Documentation]

Plan and implement an Azure Front Door

- Azure Front Door is a cloud content delivery network (CDN) that provides fast, reliable, and secure access between your users worldwide and your applications' static and dynamic web content.
- Azure Front Door delivers your content to both your enterprise and consumer end users using Microsoft's global edge network with hundreds of global and local points of presence (POPs) distributed around the world.



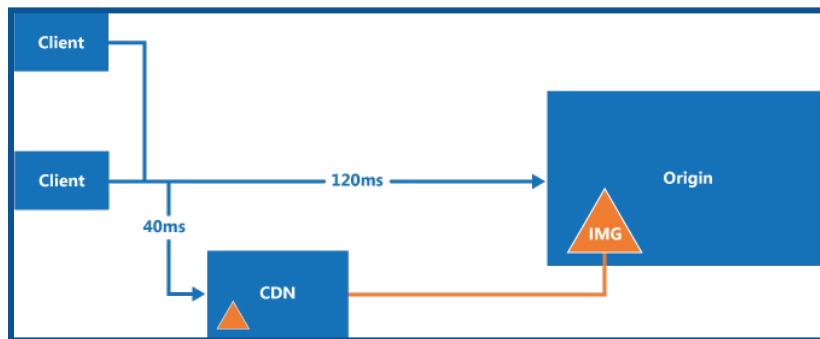
[Source: Microsoft Documentation]

Azure Front Door enables internet-facing applications to:

1. Construct and manage cutting-edge internet-first architectures with highly automated, secure, and dependable platforms that offer dynamic, excellent digital experiences.
2. Accelerate and expand your app and content to millions of users globally, no matter where they are. This will enable you to stay competitive, quickly adapt to changing circumstances, and satisfy the demands of new markets and customers.
3. Use intelligent security that utilizes a Zero Trust framework to protect your digital estate from known and unknown threats.

What is a CDN?

A content delivery network (CDN) is a distributed network of servers capable of efficiently delivering web content to customers. CDNs store cached content on edge servers that are closer to end users to reduce latency.



[Source: Microsoft Documentation]

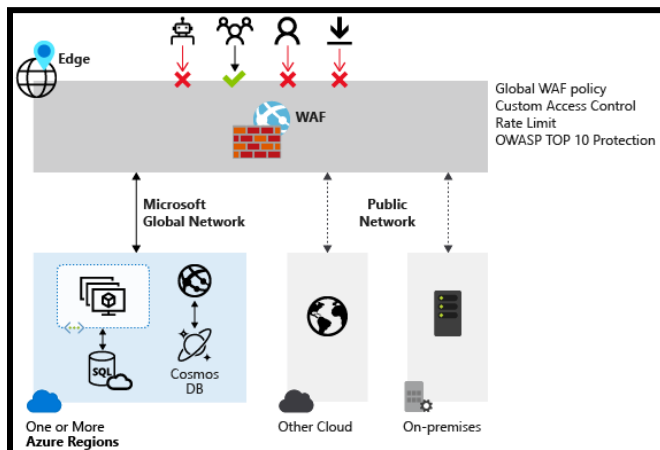
Comparison between Azure Front Door and Azure CDN services

- Azure Front Door and Azure CDN are both Azure services that provide global content delivery with intelligent routing and caching capabilities at the application layer.
- Both offer global content delivery with intelligent routing and caching capabilities at the application layer.

Plan and implement a Web Application Firewall (WAF)

What is Azure Web Application Firewall?

A Web Application Firewall (WAF) provides centralized protection for your web applications against common exploits and vulnerabilities.



[Source: Microsoft Documentation]

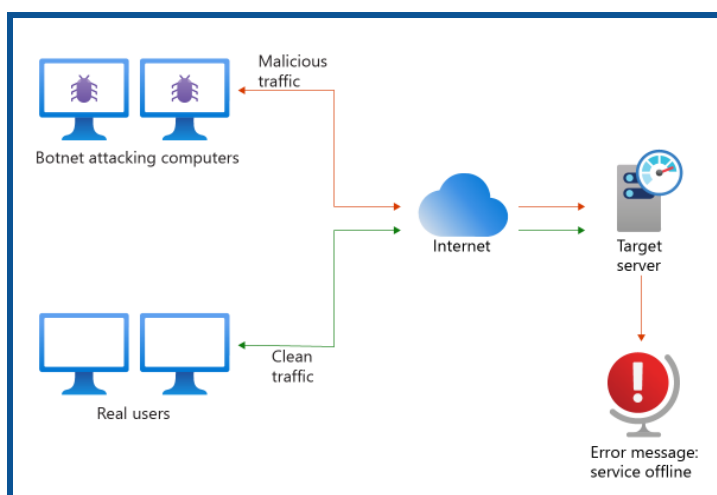
SQL injection and cross-site scripting are among the most common attacks.

A centralized web application firewall helps make security management much simpler. WAF also gives application administrators better assurance of security against threats and intrusions.

Recommend when to use Azure DDoS Protection Standard

What is Azure DDoS Protection?

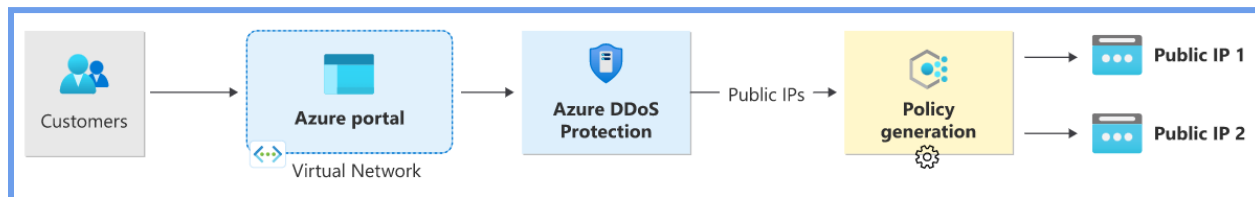
Distributed denial of service, or DDoS, is a type of attack where an attacker sends more requests to an application than the application can handle. As a result, resources are being exhausted, impacting the availability of applications and the ability to serve customers.



[Source: Microsoft Documentation]

DDoS Protection:

When enabling DDoS protection, the first step is to add the virtual network or IP address to DDoS protection. Only services with public IP addresses are secure on a virtual network. For example, the public IP of the Azure Web Application Firewall that is available in the Azure Application Gateway and deployed for Layer 7 security is secure.



[Source: Microsoft Documentation]

Azure DDoS Protection Features:

- Always-on Traffic Monitoring: Azure DDoS Protection monitors actual traffic usage and constantly compares it against the limits defined in the DDoS policy. When the traffic limit is exceeded, DDoS mitigation is automatically triggered. When traffic returns below the threshold, mitigation is stopped.
- During mitigation, traffic sent to the protected resource is redirected by the DDoS protection service, and several checks are performed, such as:
 - ◆ Ensure that packets conform to Internet specifications and are not distorted.
 - ◆ Interact with the client to determine if the traffic is potentially a spoofed packet (for example, SYN Auth or SYN Cookie, or by dropping a packet for the source to retransmit it).
 - ◆ Rate-limit packets if no other enforcement method can be performed.
- Azure DDoS Protection removes attack traffic and forwards the remaining traffic to its intended destination. Within minutes of an attack being detected, you are notified using Azure Monitor metrics.
- By configuring logging on DDoS Protection Telemetry, you can write logs to the available options for future analysis.

Secure compute, storage, and databases

Plan and implement advanced security for compute

Plan and implement remote access to Public Endpoints

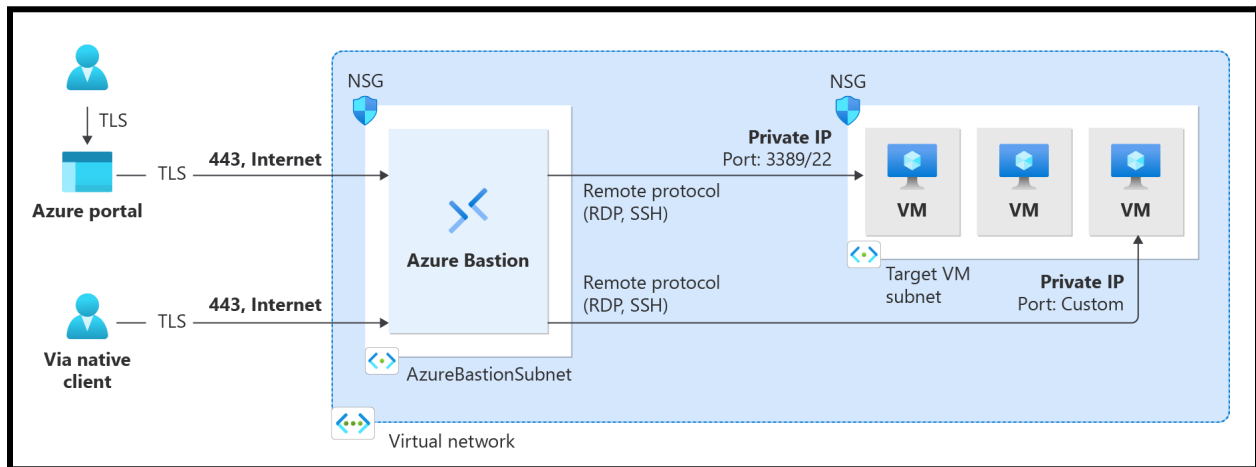
Just-in-Time Access[JIT]

You can limit incoming traffic on specific ports in Azure by enabling JIT VM access.

- By using the Internet, JIT offers remote SSH/RDP access without the need to set up extra infrastructure.
- Virtual machines (VMs) protected by Azure Firewall and managed by Azure Firewall Manager are not eligible for JIT access.
- Some of the factors that influence the best remote access solution are topology, scale, and security requirements.

How do you define Azure Bastion?

Azure Bastion is a fully managed PaaS service that you set up to securely connect to virtual machines via a private IP address.



(Source: Microsoft Documentation)

It provides secure and seamless RDP/SSH connectivity to your virtual machines via TLS from the Azure portal or through a native SSH or RDP client already installed on your local computer. When you connect through Azure Bastion, your virtual machines don't need a public IP address, an agent, or special client software.

- With Azure Bastion, a fully managed PaaS solution, virtual machines can be securely connected via private IP addresses.
- It provides secure and seamless RDP/SSH connectivity to your virtual machines via a pre-installed native SSH or RDP client on your local computer, or via TLS to the Azure portal.

Set up network isolation for Azure Kubernetes Service (AKS).

Managing Azure Kubernetes Service (AKS) clusters requires dividing tasks and teams frequently. You have total control over resource allocation and multi-tenant cluster management with AKS. To maximize your Kubernetes investment, it is critical to comprehend AKS's isolation and multi-tenancy features.

- ❖ Plan for **multi-tenancy** and resource separation.
- ❖ Implement **logical or physical isolation** in your AKS cluster.

Multiple Tenancy:

- ★ **Best practices for cluster isolation:** Multi-tenancy involves logical isolation with core components and namespaces.
- ★ **Best practices for basic scheduler features:** This includes the use of resource quotas and pod interruption budgets.
- ★ **Best practices for advanced scheduler features:** This includes using stains and tolerances, node selectors and affinity, and inter-pod affinity and anti-affinity.
- ★ **Best Practices for Authentication and Authorization:** This includes integration with Microsoft Entra ID, using Kubernetes RBAC, Azure RBAC, and Pod Identity.

Logically Isolated Cluster:

Reduces the number of physical AKS clusters you deploy across different teams or applications. With logical isolation, you can use a single AKS cluster for multiple workloads, teams, or environments. Kubernetes namespaces create a logical separation boundary between workloads and resources.

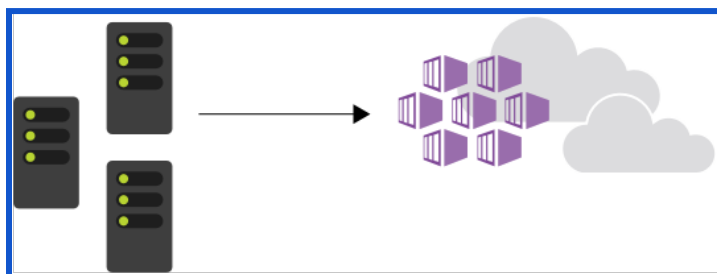
Physically Separated Group:

In this isolation model, each team or workload is assigned its own AKS cluster. While physical separation may appear to be the simplest way to divide workloads or teams, it incurs additional management and financial costs. With physically separated groups, you must maintain multiple groups and grant access and permissions on an individual basis.

Secure and Monitor AKS

Azure Kubernetes Service (AKS):

AKS makes it easier to deploy managed Kubernetes clusters on Azure by shifting operational overhead to Azure. As a hosted Kubernetes service, Azure handles critical tasks such as health monitoring and upkeep.



[Source: Microsoft Documentation]

- A control plane is automatically generated and configured when you create an AKS cluster.
- This control plane is provided free of charge to the user as a separately managed Azure resource. You only pay for and manage the nodes connected to the AKS cluster.
- It helps you with four main aspects of container security:
 - Environmental hardening
 - Vulnerability Assessment
 - Run-time threat protection for nodes and clusters
 - Agentless Search for Kubernetes

Run-time security for Kubernetes nodes and clusters

- Defender for Containers provides real-time threat protection for supported containerized environments and generates alerts for suspicious activities.
- The Defender Agent and analysis of Kubernetes audit logs provide threat protection at the cluster level. This means that security alerts are only triggered for actions and deployments that occur after you enable Defender for Containers on your subscription.
- Examples of security incidents that Microsoft Defenders for Containers monitor include:
 - ◆ Exposed Kubernetes dashboard
 - ◆ Creation of high-privileged roles
 - ◆ Building a sensitive mountain

Configure Authentication for AKS

As you deploy and manage a cluster in Azure Kubernetes Service (AKS), you implement mechanisms for managing resource and service access. Without these controls:

- Accounts may gain access to unnecessary resources and services.
- It may be difficult to find the credentials used to make the change.

There are several ways to secure, manage, approve, and verify access to a Kubernetes cluster:

- You can limit access to the resources required for users, groups, and service accounts by utilizing Kubernetes role-based access control, or RBAC.
- By utilizing Microsoft Entra ID and Azure RBAC, you can further improve security and permissions architecture with Azure Kubernetes Service (AKS).

★ **Microsoft Entra ID:**

- Set up AKS clusters with Microsoft Entra integration.
- The identity management layer is consolidated by using Microsoft Entra ID.
- Any change made to a user account or group status automatically updates access to the AKS cluster.
- Use Bindings, ClusterRoles, or Roles to limit the minimum amount of permissions for users or groups.

★ **Kubernetes RBAC**

- Kubernetes RBAC provides granular filtering of user actions. With this control system:
- You allow users or user groups to create and modify resources or view logs from running application workloads.
- You can scope permissions to a single namespace or an entire AKS cluster.
- You create roles to define permissions, and then assign those roles to users with role bindings.

★ **Azure RBAC**

- Azure RBAC to define the minimum required user and group permissions for AKS resources in one or more subscriptions.
- An AKS cluster requires two levels of access to operate fully.
- This access level allows you to:
 - Control the scaling or upgrades of your cluster using the AKS API.
 - Pull your kubeconfig.
 - Access AKS resources with your Azure subscription.

Configure security for Azure Container Instances (ACIs)

Azure Container Instances provide the fastest and simplest way to run containers in Azure without having to manage any virtual machines or adopt a high-level service.

Azure Container Instances are a great solution for any scenario that can run in separate containers, including simple applications, task automation, and the creation of jobs.

Security recommendations for Azure container instances:

★ **Use a private registry:**

- a. Containers are created from images that are stored in one or more repositories. These repositories may belong to a public registry, such as Docker Hub, or a private registry.

- b. A publicly available container image does not guarantee security.
- c. Container images contain multiple software layers, each of which may contain vulnerabilities.
- d. To help reduce the risk of attacks, you should store and retrieve images from a private registry, such as the Azure Container Registry or the Docker Trusted Registry.

★ Monitor and scan container images

- a. Use the solutions in the private registry to scan container images for potential vulnerabilities.
- b. It is important to know what level of threat detection different solutions offer.
- c. For example, Azure Container Registry optionally integrates with Microsoft Defender for the Cloud to automatically scan all Linux images sent to the registry.

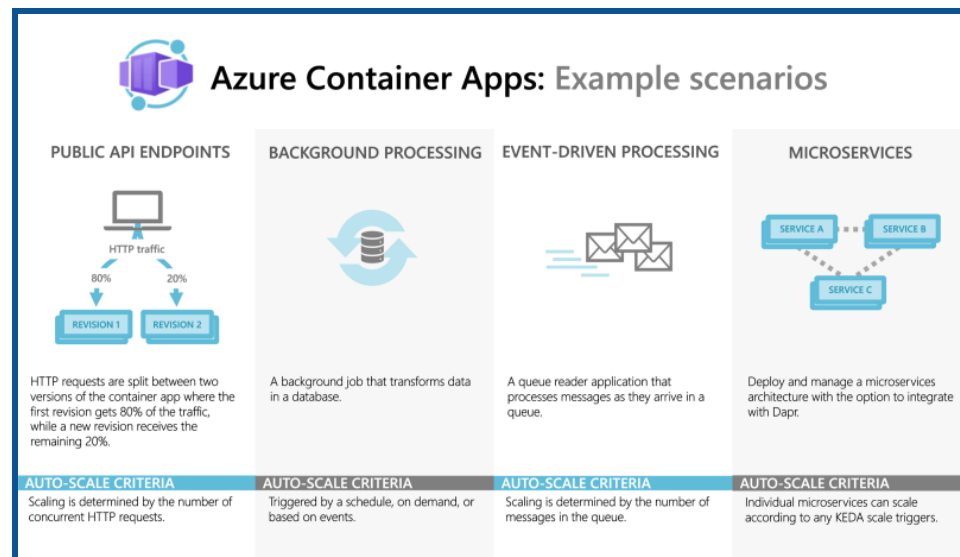
★ Protect credentials

- a. Containers are cross-regional and cross-clustered.
- b. As a result, you need to protect the login or API access credentials, like tokens and passwords.
- c. Ensure that, during transit and rest, those containers are only accessible to privileged users.
- d. List all credential secrets, and then developers will need to use emerging secrets-management tools that are designed for container platforms.

Configure security for Azure Container Apps (ACAs)

What are Azure Container Apps (ACAs)?

Azure Container Apps (ACAs) is a fully managed serverless platform built on Kubernetes that simplifies deploying and managing modern applications and microservices. It abstracts away the complexity of container orchestration, allowing you to focus on your code and business logic.



Source: Microsoft Documentation

Key Features:

- **Serverless containers:** Scale automatically based on traffic or events, eliminating the need to manage infrastructure.
- **Multiple languages and frameworks:** Supports various languages and frameworks like Python, Node.js, .NET, Java, and more.
- **Flexible deployment options:** Deploy from code, pre-built containers, or container images stored in the Azure Container Registry.
- **Built-in networking and observability:** Includes load balancing, traffic routing, and application insights for monitoring.
- **Integrated with Azure services:** Leverages other Azure services like Azure Functions, Azure Storage, and Azure Key Vault for additional functionality.
- **Security:** Offers various security features like role-based access control (RBAC), managed identities, and secret management.

Benefits:

1. Reduces the time and effort required to deploy and manage containerized applications.
2. Eliminates the need to manage Kubernetes clusters or virtual machines.

3. Pay only for the resources your applications use, thanks to the serverless model.
4. Automatically scale apps up or down based on demand, ensuring high availability.
5. This allows developers to focus on writing apps logic instead of infrastructure concerns.

Use Cases:

- **Microservices:** Ideal for building and deploying individual components of larger applications.
- **Event-driven applications:** Respond to events from various sources, like Azure Queue Storage or Event Hubs.
- **Serverless batch jobs:** Run background tasks like data processing or image manipulation.
- **API endpoints:** Expose APIs for mobile apps, web applications, or other services.

→ Here are some important ways to configure security for your ACAs.

1. Use a Private Registry:

Containers are created from images that are stored in one or more repositories. These repositories may belong to a public registry, such as Docker Hub, or a private registry.

2. Monitor and scan container images

Utilize the private registry's solutions to scan container images and find any potential security holes. Knowing the level of threat detection that various solutions offer is crucial.

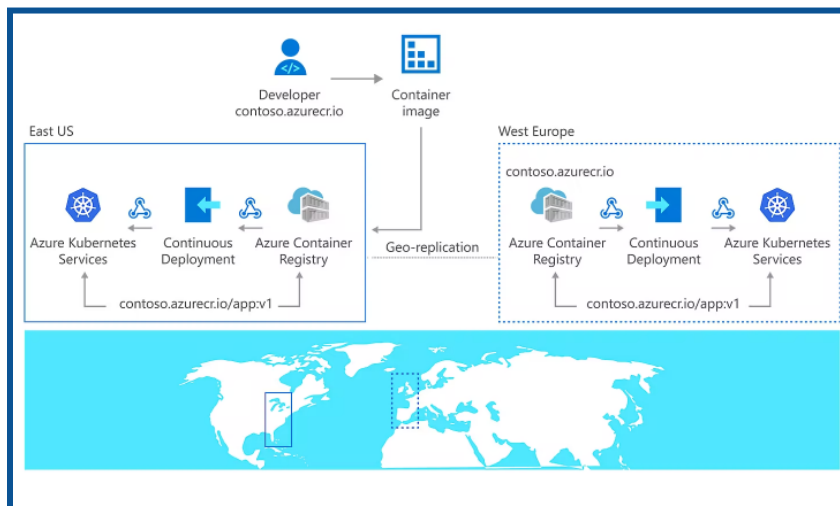
3. Protect Credentials:

Containers are cross-regional and cross-clustered. As a result, you need to protect the login or API access credentials, like tokens and passwords. Ensure that those containers are only accessible by privileged users, both in transit and at rest. Developers will then need to use newly developed secrets-management tools made specifically for container platforms after listing all credential secrets.

Manage access to Azure Container Registry (ACR)

What is Azure Container Registry?

Azure Container Registry allows you to create, store, and manage container images and artifacts in a private registry for all types of container deployments. Azure container registries are used with your existing container development and deployment pipelines.



Source: Microsoft Documentation

Azure **role-based access control** (Azure RBAC) grants specific permissions to users, service principals, or other identities that need to interact with the registry, for example, to pull or push container images.

Azure Container Registry utilizes two primary access control layers:

1. **Role-Based Access Control (RBAC):** This layer governs overall registry access permissions for users, groups, and service principals. It offers predefined roles like AcrPull (pull images) and AcrPush (push and pull images). You can also create custom roles with granular permissions.
2. **Repository Scoped Permissions:** This layer controls access to specific repositories within the registry. You can grant read, write, or delete permissions to individual users or groups using access tokens or Azure RBAC assignments.

Key Access Management Mechanisms:

1. **Azure RBAC:** Assigning Azure RBAC roles to users, groups, or service principals defines their interaction level with the registry (e.g., pulling, pushing, and managing).
2. **Access Tokens:** Tokens can be generated with specific repository-level permissions (read, write, delete) for temporary access without managing user accounts.
3. **Service Principals:** Used for headless authentication from applications or services requiring registry access.
4. **Managed Identities:** Leverage system or user-assigned managed identities within VMs or Azure services for seamless registry access without manual credentials.

5. **Public Network Access:** Optionally enable public network access to specific IP addresses or ranges for limited scenarios, adhering to strict security practices.

Best Practices for Secure Access Management:

- **Principle of Least Privilege:** Grant only the min required permissions for each user or entity.
- **Regularly Review and Update Permissions:** Ensure permissions remain aligned with evolving needs and access requirements.
- **Leverage Managed Identities:** Utilize managed identities whenever possible for enhanced security and reduced credential management overhead.
- **Disable Public Network Access:** Avoid public network access unless necessary, and implement robust security measures if enabled.
- **Monitor and Audit Access:** Monitor registry access and audit logs for suspicious activity.

Disk Encryption

Configure disk encryption, including Azure Disk Encryption (ADE), encryption as host, and confidential disk encryption

Disk Encryption Fundamentals:

- **Protecting data at rest, in transit, and use:** Disk encryption safeguards sensitive information while it's stored (rest), transferred (transit), and accessed (use).
- **Key management:** encryption keys control access to data. Use platform-managed keys (PMKs) for convenience or customer-managed keys (CMKs) for enhanced control (stored in Azure Key Vault).
- **Ciphertext:** Encrypted data, unreadable without the decryption key.
- **Key encryption key (KEK):** Encrypts and protects the data encryption key (DEK).

Encryption Methods:

1. Azure Disk Encryption (ADE):

- Encrypts OS and data disks within VMs using native OS tools like BitLocker (Windows) or DM-Crypt (Linux).
- Managed by Azure Key Vault for key management.
- Supports PMKs and CMKs.
- Use cases: General-purpose disk encryption for various VM scenarios.

2. Encryption as Host:

- Extends ADE to encrypt temporary disks and disk caches (typically stored on the VM host).
- Encryption occurs within the VM host itself.
- Leverages platform-managed keys only.
- Use cases: Enhanced protection for temp/cache data on Azure VMs.

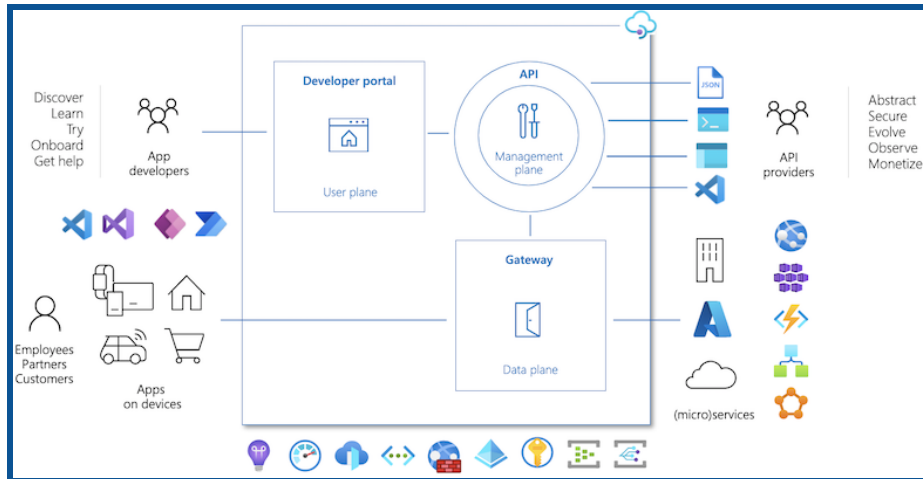
3. Confidential Disk Encryption (CDE):

- Binds DEKs to the virtual machine's Trusted Platform Module (TPM) for max security.
- Requires supported Azure VM types and TPM versions.
- Encryption keys never leave the TPM, even during VM creation or reboot.
- Use cases: Critical workloads requiring the highest level of data protection.

Recommends security configurations for Azure API Management

What is Azure API Management?

Azure API Management provides a gateway for securing, managing, and transforming APIs.



[Source: Microsoft Documentation]

Azure API management is composed of an API gateway, a management plane, and a developer portal. These components are Azure-hosted and fully managed by default.

API management is available in different tiers, varying in capabilities and features.

→ Key areas include **Authentication, Authorization, Data Encryption, Network Security, Vulnerability Management, and Monitoring.**

Security Recommendations:

1. Authentication and Authorization:

→ Implement strong authentication:

- ◆ OAuth 2.0/OpenID Connect: For fine-grained access control and identity management.
- ◆ API keys: Use for less sophisticated scenarios with limited scopes.
- ◆ Mutual TLS: For machine-to-machine communication with strong PKI infrastructure.

→ Apply authorization policies:

- ◆ Use policies like `validate-jwt` or `validate-oauth2` to enforce rules based on claims, scopes, or groups.
- ◆ Granularly determine user or application access to specific operations or data.
- ◆ Integrate with Microsoft Entra ID
- ◆ Leverage AAD for centralized identity management and single sign-on for secure access.

2. Data Encryption:

→ HTTPS Enforcement:

- ◆ Enforce HTTPS for all API traffic to protect data in transit from eavesdropping or tampering.
- ◆ Use strong TLS protocols and ciphers, adhering to industry best practices.

→ Data at Rest Encryption:

- ◆ If storing sensitive data in API Management policies or responses, store it securely encrypted with Azure Key Vault.
- ◆ Implement a Bring Your Own Key (BYOK) approach for maximum control.
- **Double Encryption:** Consider double encryption for compassionate data: encrypt first in the application and then again in API Management with separate keys.

3. Network Security:

- **Virtual Networks:** Restrict API Management access to a secure virtual network to control inbound and outbound traffic. Use Network Security Groups (NSGs) within the virtual network for further filtering.
- **Private Endpoints:** For enhanced security, use private endpoints to access backend services within the same virtual network, eliminating exposure to the public internet.
- **Web Application Firewall (WAF):** Deploy a WAF in front of API Management to protect against common web attacks like SQL injection, cross-site scripting, and DDoS.
- **Vulnerability Management:**
 - **Regular Updates:** Keep API Management, Microsoft Entra ID, and any other related services updated with the latest security patches to address known vulnerabilities.
 - **Penetration Testing:** Conduct periodic penetration testing to identify and address potential security weaknesses in your API Management deployment.
 - **Security Scanning:** Regularly scan API Management policies and configurations for vulnerabilities using Microsoft Defender for Cloud or dedicated tools.
- **Monitoring and Logging:**
 - **Enable diagnostic logging:**
 - Log API requests, responses, and errors for auditing and troubleshooting.
 - Integrate with Azure Monitor for centralized analysis and alerting.
 - **Monitor security events:**
 - Use Azure Monitor and Security Center to track security events and identify suspicious activity.
 - Configure alerts to notify you of potential security incidents.

Plan and Implement Security for storage

Configure access control for storage accounts

What is a Storage Account?

It's a fundamental building block for cloud storage within Microsoft Azure. It provides a unique namespace to store and manage various data objects across different services, including:

- Blobs: Unstructured data like text, images, videos, and binary files.
- Files: Hierarchical file shares are for traditional file storage needs.
- Queues: Messaging for asynchronous communication between applications.
- Tables: NoSQL data stores schema-less data organized as tables.

Key Features:

- Scalability: Seamlessly scale storage up or down based on your data needs.
- Durability: Data is replicated across multiple servers for fault tolerance and high availability.
- Security: Fine-grained access control mechanisms to ensure data privacy and integrity.
- Accessibility: Data is accessible from anywhere in the world over HTTP or HTTPS.
- Integration: Integrates seamlessly with other Azure services and offerings.

Types of Storage Accounts:

- General-purpose v2 (recommended for most scenarios): Supports all Azure Storage services (blobs, files, queues, tables).
- Blob storage: Optimized for storing massive amounts of unstructured data (blobs).
- File storage: Designed for traditional file storage needs with hierarchical file shares.

Managing Storage Account Access:

- Access keys: Shared secrets are used to programmatically access data in the account.
- SAS: Grant temporary access to specific resources without sharing access keys.
- Microsoft Entra ID : Provides superior security & ease of use over Shared Key authorization.

Understanding Storage Account Resources:

- **Storage account:** Foundational container for all storage services (blobs, files, queues, tables).
- **Containers:** Logical groupings within a storage account for specific data types (e.g., blob container).
- **Blobs:** Individual files within blob containers.
- **Files:** Individual files within file shares.

NOTE: A storage account provides a unique namespace in Azure for your data. Every object that you store in Azure Storage has an address that includes your unique account name. The combination of the account name and the blob storage endpoint creates the base address for objects in your storage account.

Authorization Methods:

1. Azure Role-Based Access Control (RBAC):

- Assigns specific permissions (read, write, delete) to users, groups, or applications through built-in or custom roles.
- Granular control at various scopes (subscription, resource group, storage account, container, or blob).
- It is recommended for most scenarios due to its flexibility and security.

2. Shared Access Signatures (SAS):

- Grant temporary access to specific resources with fine-grained control over permissions, expiry, and IP restrictions.
- It is useful for granting limited access to external parties or applications.
- Exercise caution due to potential misuse if compromised.

3. Account Keys:

- Grant full access to the storage account and its data.
- Avoid using them directly due to security risks. Leverage the Azure Key Vault for secure storage and rotation.

4. Microsoft Entra ID: Microsoft Entra is Microsoft's cloud-based identity and access management service. Microsoft Entra ID integration is available for Blob, File, Queue, and Table services. With Microsoft Entra ID, you can grant granular access to users, groups, or applications through role-based access control (RBAC).

5. Microsoft Entra Domain Services authorization for Azure Files: Azure Files supports identity-based authorization over Server Message Block (SMB) through Microsoft Entra Domain Services. You can use RBAC to control client access to Azure file resources in a storage account.

6. Microsoft Entra ID authorization for Azure Files: Azure Files supports identity-based authorization over SMB through Microsoft Entra ID. Your Domain Service can be hosted on on-premises machines or Azure VMs. SMB access to files is supported using Microsoft Entra ID credentials from domain-joined machines, either on-premises/Azure.

7. Anonymous access to containers and blobs: You can optionally make blob resources public at the container or blob level. A public container or blob is accessible to any user with read access. Read requests for public containers and blobs do not require authorization.

❖ Key Considerations:

- **Principle of Least Privilege:** Grant only the minimum permissions required for users and applications to perform their tasks.
- **Default Authorization:** Choose between Microsoft Entra ID (RBAC) or Shared Key as the default for data access operations.
- **Fine-Grained Access Control:** Utilize RBAC or ACLs (for Azure Data Lake Storage Gen2) to define permissions at various resource levels.
- **Logging and Monitoring:** Track access attempts and resource modifications for auditing and security purposes.

Manage life cycle for storage account access keys

Managing the lifecycle of your storage account access keys is crucial for maintaining the security of your Azure Storage data. Access keys grant full control over your storage account, so it's essential to handle them carefully.

Key practices:

- **Rotate keys regularly:** Don't treat access keys like static passwords. Change them periodically to minimize the risk of unauthorized access, especially if you suspect a compromise.
- **Disable shared key authorization whenever possible:** This method relies on access keys, which is less secure than other options. Use Microsoft Entra ID (Microsoft Entra ID) based authorization for granular access control instead.
- **Use Shared Access Signatures (SAS) judiciously:** SAS tokens provide temporary access to specific resources without revealing full access keys. However, use them with caution and set appropriate expiration times and permissions.
- **Leverage Azure Key Vault:** This secure service helps you store, manage, and rotate access keys. Integrate it with Microsoft Entra ID for enhanced security and access control.
- **Implement lifecycle management policies:** Automate key rotation and deletion based on defined rules. This streamlines security practices and ensures compliance.

Points to Remember:

- Treat access keys like passwords: Never share them publicly, and avoid hardcoding them in applications.
- Grant only the necessary permissions to users and applications.
- Keep track of who is accessing your storage account and why.

Additional Resources:

- [Manage account access keys - Azure Storage | Microsoft Learn](#)
- [Configure a lifecycle management policy - Azure Storage | Microsoft Learn](#)
- [Enable AD DS authentication for Azure file shares | Microsoft Learn](#)
- Shared Access Signatures (SAS): <https://learn.microsoft.com/en-us/azure/storage/blobs/>
- Azure Key Vault documentation: <https://learn.microsoft.com/en-us/azure/key-vault/>

Select and configure an appropriate method for accessing Azure Files

The best way to access files stored on Azure depends on several things, such as your security needs, desired level of control, and environment.

- Compared to Shared Key authorization, Microsoft Entra ID authorization offers more security and convenience of use.
- To ensure that users have access to your blob applications with the least amount of privileges necessary, Microsoft advises using Microsoft Entra authorization whenever it can.

- For all general-purpose and Blob storage accounts across all public regions and national clouds, authorization via Microsoft Entra ID is available.
- Microsoft Entra authorization is supported only for storage accounts that are created using the Azure Resource Manager deployment model.
- Moreover, shared access signatures (SAS) signed with Microsoft Entra credentials can be created using blob storage.

Authentication Methods:

- **Microsoft Entra Domain Services (AD DS)**: This is the most secure authentication method for Azure Files. It provides a managed domain service that is fully compatible with Active Directory. This means that you can use your existing Active Directory users and groups to access Azure Files.
- **Microsoft Entra ID**: This is a cloud-based identity and access management service. It is a good option if you do not have an on-premises Active Directory environment. Microsoft Entra ID can be used to authenticate users and groups to Azure Files.
- **Storage account access keys**: This is the least secure authentication method for Azure Files. It should only be used for temporary scenarios or applications that do not support identity-based authentication.

Authorization:

- **Share-level permissions**: You can assign roles (Reader, Contributor, etc.) to users and groups for basic access control. For example, you can grant a user the Reader role to allow them to read files in a share, but not modify them.
- **Directory and file-level ACLs**: You can configure granular permissions at the directory and file level using Windows ACLs or Linux/macOS.
This allows you to control who can access specific files or directories.

Access Protocols:

- **SMB**: This is the standard Windows file-sharing protocol. It is widely supported by different operating systems and applications.
- **REST API**: This is a programmatic interface that allows you to access Azure Files from applications or scripts. This can be used for automation or integration with other services.
- **Azure Files Storage Explorer**: This is a graphical user interface (GUI) that allows you to browse and manage Azure Files. This can be useful for manual operations.

Built-in roles for blobs in Azure

In Azure RBAC, there are pre-built roles that can be used to grant access to blob data using Microsoft Entra ID and OAuth.

The following roles in Azure Storage provide access to data resources:

- To set ownership and manage POSIX access control for Azure Data Lake Storage Gen2, use the Storage Blob Data Owner feature.
- By using the Storage Blob Data Contributor technique, resources in Blob storage can be read, written, and removed.
- Use Storage Blob Data Reader to grant read-only permissions to Blob storage resources.
- Obtain a user delegation key in Storage Blob Delegator using your Microsoft Entra credentials to sign a shared access signature for a blob or container.

Appropriate method for accessing Azure Blob Storage

There are two main methods to access Azure Blob Storage:

1. Using your Microsoft Entra account:

- **Security:** It is more secure, and avoids sharing sensitive account keys.
- **Permissions:** Requires an Azure RBAC role with access to blob data (Storage Blob Data Reader, Storage Blob Data Contributor, etc.) and an Azure Resource Manager Reader role for basic navigation.
- **Authorization:** The portal checks for assigned roles first. If access is granted, use your Entra account.

2. Using the storage account access key:

- **Security:** Less secure should be avoided unless necessary.
- **Permissions:** Requires an Azure RBAC role with *Microsoft.Storage/storageAccounts/listkeys/action* (e.g., Storage Account Contributor, Azure Resource Manager Contributor).
- **Authorization:** If there is no Entra role with key access, the portal defaults to this method.

Choosing the Best Method:

Prioritize using your Microsoft Entra account for improved security.

Use the storage account access key only if Entra access is unavailable or for temporary scenarios. Consider using stored access policies for fine-grained control over blob access without sharing account keys.

- Azure Resource Manager ReadOnly lock prevents key access, forcing Entra authentication.
- You can specify the authentication method for individual blobs in the Azure portal.

Feature	Microsoft Entra Account	Storage Account Access Key
Security	More secure	Less secure
Permissions	Requires Entra and Resource Manager roles	Requires specific RBAC role with key access
Authorization	Preferred method, used if granted roles	Used as a fallback or for temporary access
Best Usage	Default option for most scenarios	Use only when Entra access is unavailable

Appropriate methods for protecting against Data Security Threats

Basic Data Protection:

- **Azure Resource Manager Lock:** Apply this lock to all storage accounts to prevent accidental or malicious deletion/modification.

- **Container Soft Delete:** Enable it for recovering deleted containers (including contents) within a set period.
- **Blob Versioning:** Automatically save previous versions of blobs for restoration when overwritten.
- **Blob Soft Delete:** Recover temporarily deleted blobs within the retention interval.

Advanced Data Protection:

1. Immutability Policy:

- a. **Blob Version:** Protect specific versions of critical blobs from deletion and metadata modification.
- b. **Container:** Lock entire containers (and blobs within) against all changes/deletion for compliance or long-term preservation.

2. Snapshots: Manually capture a point-in-time snapshot of a blob for later recovery.

3. Roll-Your-Own Solution: Use Azure Storage object replication or tools like AzCopy/Data Factory to automatically copy data to a secondary account for disaster recovery.

Additional Recommendations:

- **Regular Backups:** Implement a separate backup strategy for critical data beyond built-in features.
- **Secure Authentication:** Use Microsoft Entra ID or Entra AD DS for granular access control and avoid less secure access keys.
- **Encryption:** Enable Microsoft-managed encryption for data at rest and in transit for added security.
- **Audit Logging:** Monitor access attempts and resource changes for potential threats.

Restoring Deleted/Overwritten Data:

The recovery method depends on the affected resource and enabled protection options.

Disaster Recovery:

Azure Storage offers redundancy to protect against various failures. For further protection, consider geo-redundant storage accounts with customer-managed failover (except for hierarchical namespaces).

Configure Bring your own key (BYOK)

What do you mean by Azure Key Vault?

Azure Key Vault is a cloud-based security service that helps you securely store and manage your sensitive data, such as API keys, passwords, certificates, and cryptographic keys. It serves as the central hub for safeguarding your secrets, protecting them from unauthorized access, and ensuring their confidentiality, integrity, and availability.

● Basic Terms:

- **Secret:** Any sensitive data requiring strict control and protection, like passwords, certificates, or tokens.
- **Key:** A cryptographic key used for encryption and decryption of data.
- **Vault:** A secure container within Azure Key Vault to store your secrets and keys.
- **Managed HSM:** Hardware Security Module (HSM) provided by Microsoft for enhanced security for highly sensitive keys.
- **Access Policy:** Controls who can access your secrets and keys in the Vault.
- **Key Rotation:** Regularly changing cryptographic keys to mitigate security risks.
- **Auditing:** tracking access attempts and actions performed on your secrets and keys.

Benefits of using Azure Key Vault:

1. Centralized Management
2. Enhanced Security
3. Improved Compliance
4. Simplified Integration

Types of Objects Stored in Key Vault:

- **Secrets:** Passwords, API keys, connection strings, etc.
- **Keys:** Cryptographic keys for encryption and decryption (RSA, EC, and AES).
- **Certificates:** SSL/TLS certificates for website authentication.

Key Vault Access Methods:

- **Microsoft Entra ID:** cloud-based identity and access management.
- **Managed Identities:** Automated authentication for Azure services.
- **Service Principals:** Applications accessing Key Vault without human intervention.
- **Storage Account Access Keys:** least secure (for temporary scenarios).

Additional Features:

1. **Key Rotation:** Automated rotation of cryptographic keys for enhanced security.
2. **Backup and Restore:** Back up your secrets and keys for disaster recovery.
3. **HSM-Protected Keys:** Increased security for highly sensitive keys using dedicated HSMs.

Key Name	Key Type	Origin	Description
KEK	RSA	Azure Key Vault HSM	HSM-backed RSA key generated in Azure Key Vault
Wrapping Key	AES	Vendor HSM	Ephemeral AES key generated by

			on-premises HSM
Target Key	RSA, EC, AES (Managed HSM only)	Vendor HSM	Key to be transferred to Azure Key Vault HSM

1. Key Exchange Key (KEK):

- Generate an HSM-backed RSA key pair (4096, 3072, or 2048 bits) within the Key Vault where the Target Key will be imported.
- Set its **key_ops** to **import** only, limiting its use to BYOK operations.
- Ensure it resides in the same vault as the target key.

User Steps:

- **Generate KEK:** Use `az keyvault key create` command with `key_ops` set to `import`.
Note: Services may have specific KEK length requirements.
- **Retrieve KEK Public Key:** Download and store the public key portion of the KEK as a PEM file.
- **Generate Key Transfer Blob:** Use the HSM vendor's BYOK tool with the KEK public key (PEM file) to create a Key Transfer Blob (".byok" file).

2. Key Transfer Blob:

- Microsoft is transitioning to PKCS#11 CKM_RSA_AES_KEY_WRAP for transferring the Target key. This mechanism produces a single blob and keeps the intermediate AES key ephemeral within the HSMs.
- Currently, some HSMs may not support this. As an alternative, use a combination of CKM_AES_KEY_WRAP_PAD and CKM_RSA_PKCS_Optimal Asymmetric Encryption Padding (OAEP) to achieve a similar result.

Target Key Plaintext:

- RSA: ASN.1 DER encoded private key wrapped in PKCS#8.
- EC: ASN.1 DER encoded private key-pair wrapped in PKCS#8.
- Octet Key: Raw bytes of the key.

Encrypting Plaintext Key:

- Generate an ephemeral AES key.
- Encrypt the AES key with the wrapped RSA key using RSA-OAEP with SHA1.
- Encrypt the encoded plaintext key with the AES key using AES Key Wrap with Padding.
- Concatenate the encrypted AES key and encrypted plaintext key to form the final ciphertext blob.

Transfer Blob Format:

- The transfer blob uses JSON Web Encryption compact serialization (RFC7516) to deliver the required metadata for decryption.

Uploading the Key Transfer Blob:

- Transfer the Key Transfer Blob (".byok" file) to an online workstation.
- Use the **az keyvault key import** command to import the blob as a new HSM-backed key in Key Vault.

HSM Constraints:

- Your on-premises HSM may require specific configurations for key exports, such as:
 - Enabling key wrap-based export
 - Marking the Target Key as CKA_EXTRACTABLE
 - Marking the KEK and wrapping the key as CKA_TRUSTED (if applicable)

Enable double encryption at the Azure Storage infrastructure level

What is Double Encryption?

When two or more independent layers of encryption are enabled to guard against compromises of any one layer of encryption, this is known as double encryption. The risks associated with encrypting data are reduced when two layers of encryption are used.

For example:

- Incorrect data encryption configuration
- Implementation mistakes in the encryption algorithm
- A single encryption key was compromised.
- Azure supports double encryption for both data at rest and data in transit.

When is Double Encryption Necessary?

While standard service-level encryption suffices for most needs, consider double encryption in specific scenarios:

- **Strict Compliance Requirements:** Regulatory mandates demand additional security measures.
- **Highly Sensitive Data:** Protecting crucial information with an extra layer of encryption.
- **Enhanced Peace of Mind:** Seeking the ultimate data security assurance.

Enabling Double Encryption:

Azure provides two ways to implement double encryption:

1. **Creating a Storage Account with Infrastructure Encryption:** Configure this option during account creation, ensuring all data within the account benefits from double encryption. This option is irreversible, so choose wisely.
2. **Creating an Encryption Scope with Infrastructure Encryption:** If double encryption is not enabled at the account level, you can activate it for specific data compartments called encryption scopes. This offers targeted protection for sensitive data sections.

Key Considerations:

- Double encryption incurs a slight performance impact due to the additional encryption layer.
- Only general-purpose v2 and premium block blob storage accounts support infrastructure encryption.
- Carefully evaluate your needs and weigh the benefits against potential performance implications before opting for double encryption.

Plan and implement security for Azure SQL Database and Azure SQL Managed Instance

Authentication verifies a user's identity, while authorization determines their access and actions within the database. Database security relies on two pillars:

1. **Authentication**
2. **Authorization**

Authentication Methods:

Azure SQL offers two primary authentication methods:

- **SQL authentication:** Users provide a username and password directly stored in the master database or individual databases.
- **Microsoft Entra ID authentication:** Users leverage their Entra ID credentials for secure, centralized management.

Benefits of Microsoft Entra ID Authentication:

1. **Enhanced security:** Leverages Entra ID's robust authentication mechanisms and multi-factor authentication (MFA) support.
2. **Centralized management:** Simplify user management and lifecycle across your cloud resources.

3. **Reduced password fatigue:** Eliminate the need for individual database passwords, improving the user experience.
4. **Improved compliance:** align with stringent data security and privacy regulations.

Logins and Users:

Logins: Master database accounts linked to user accounts in various databases.

Users: Individual accounts within specific databases, potentially linked to a login.

Contained Database Users:

For enhanced security and portability, consider creating a **contained database**. These users authenticate directly to the database, eliminating reliance on server-level logins.

Enabling Entra ID Authentication:

1. **Create Entra administrator:** Establish a dedicated Entra user account authorized to manage Entra authentication for your SQL server/managed instance.
2. **Configure server/instance:** Enable "Support only Microsoft Entra authentication" and set the Entra administrator. Select specific databases if you want to enable Entra ID for a subset. Choose user mapping option:
 - ◆ **Automatic:** Users directly map to contained database users with the same name.
 - ◆ **Manual:** Manually create contained database users and map them to Entra users.
3. **Create contained database users (optional):** If using manual mapping, create users in each affected database with the same name as their Entra counterparts.
4. **Test and verify:** Use Entra credentials to connect to your database and ensure successful authentication.

Enable database auditing

Database auditing is a crucial security feature in Azure SQL Database and Azure Synapse Analytics. It tracks database events and records them in an audit log stored in your Azure storage account, Log Analytics workspace, or Event Hubs.

This data provides valuable insights for

- **Regulatory compliance:** Auditing helps you adhere to industry regulations and internal security policies.
- **Security monitoring:** Analyze audit logs to identify suspicious activity, detect potential breaches, and understand your database usage patterns.
- **Troubleshooting:** Audit logs can aid in diagnosing issues, investigating discrepancies, and pinpointing performance bottlenecks.

Configuration Overview

Here's an overview of enabling and monitoring database auditing:

1. **Define Auditing Events:** Choose the specific database events you want to track, such as logins, DDL statements, DML statements, and schema changes.

2. **Set Retention Period:** Specify how long you want to retain audit logs. Options range from 1 to 365 days.
3. **Choose Storage Destination:** Select where to store the audit logs:
 - a. **Azure Storage Account:** A cost-effective option for long-term archiving.
 - b. **Log Analytics Workspace:** Enables real-time analytics and visualizations.
 - c. **Event Hubs:** For streaming analysis and integration with external systems.
4. **Configure Retention Period:** Set the desired retention period for the chosen destination.
5. **Enable Auditing:** Activate the audit policy at either the server or database level:
 - a. **Server-level policy: applies to all existing and newly created databases on the server.**
 - b. **Database-level policy:** This applies only to the specific database where it's enabled.
Note: You can enable auditing at both levels and in such cases, the database will be audited twice (once by each policy).

Monitoring and Analysis

Once auditing is enabled, you can access and analyze the audit logs using several methods,

- **Azure Portal:** View basic event details and download logs for offline analysis.
- **Log Analytics Workspace:** Analyze logs using built-in queries and create custom dashboards for deeper insights.
- **Microsoft Sentinel:** Leverage security information and event management (SIEM) capabilities for advanced threat detection and incident response.

By enabling and monitoring database auditing, you gain valuable insights into your database activity, improve your security posture, and ensure compliance with regulations. Remember to regularly review and adjust your audit settings to align with your security requirements and data retention policies.

Identify use cases for the Microsoft Purview governance portal

The Microsoft Purview governance portal offers a unified platform for data governance across your on-premises, multi-cloud, and SaaS environments. This versatility unlocks various use cases, catering to different roles within your organization:

Data Discovery and Mapping:

1. **IT Administrators:** Gain a comprehensive view of your entire data landscape through automated discovery and classification. Identify and understand the data you have, regardless of its location.
2. **Data Stewards:** Efficiently manage metadata and descriptions of data assets, enriching the data map for better governance.
3. **Compliance Officers:** Easily locate sensitive data and ensure it adheres to regulations through classification and lineage tracking.

Data Catalog and Curation:

1. **Data Analysts:** Quickly find relevant data using intuitive search, filters, and business glossaries. Understand data context and lineage for informed analysis.
2. **Data Scientists:** Explore the data landscape, identifying datasets for machine learning and AI initiatives. Track data lineage to ensure data quality and reliability.
3. **Data Owners:** Collaborate with data stewards to document and curate data assets. Manage business glossaries and enrich data assets with relevant tags.

Data Governance Insights:

1. **Chief Data Officers:** Get a high-level overview of your data estate, including data distribution, quality, and compliance. Identify potential governance gaps and prioritize remediation efforts.
2. **Data Governance Board:** Gain data-driven insights into governance effectiveness and make informed decisions about improving data management practices.

Data Sharing and Collaboration:

1. **Business Units:** Securely share data internally or with external partners, streamlining collaboration and data-driven decision-making.
2. **Marketing Teams:** Share customer data across departments for targeted campaigns and personalized experiences, while maintaining data privacy.
3. **Research Teams:** Collaborate on research projects by securely sharing data across institutions, accelerating discovery and innovation.

Data Policy and Access Control:

1. **Security Administrators:** Centrally manage data access across diverse data sources from a single pane of glass. Implement fine-grained policies to enforce security and compliance.
2. **Data Owners:** Define clear access control rules for their data assets, ensuring authorized users can access the data they need.

3. **IT Architects:** Integrate data access policies with existing identity and access management solutions for streamlined governance.

Important Terms:

- **Cloud Migration:** Manage data discovery, classification, and governance during cloud migration projects for a smooth and secure transition.
- **Regulatory Compliance:** Leverage data lineage and classification capabilities to demonstrate compliance with data privacy regulations like GDPR and CCPA.
- **Data Monetization:** Identify and share appropriate data assets for monetization opportunities while maintaining data security and privacy.

Plan and implement dynamic masking

What is Dynamic Data Masking?

DDM is a security feature that works with your databases to safeguard sensitive information by selectively hiding it from unauthorized users. This improves data compliance and stops sensitive information from inadvertently becoming public.

Why Plan and Implement DDM?

- **Minimize exposure:** By only disclosing information that is required based on user permissions, DDM lowers the risk of data breaches.
- **Compliance control:** By hiding PII and other sensitive data, it aids in complying with data privacy laws like the CCPA and GDPR.
- **Enhanced application security:** DDM reduces the possibility of data leakage even in the event of an application vulnerability.

Planning for DDM:

1. Identify Sensitive Data:

- Analyze your database schema to identify fields containing sensitive information like PII, financial data, or healthcare records.
- Consider your organization's data classification policies and regulatory requirements.

2. Define the masking strategy:

- Determine the desired level of exposure for each sensitive field.
- Select appropriate masking functions based on data type and requirements (e.g., email masking, partial masking, random value generation).
- Consider granular masking permissions (UNMASK) to allow specific users to access unmasked data even if masked by the policy.

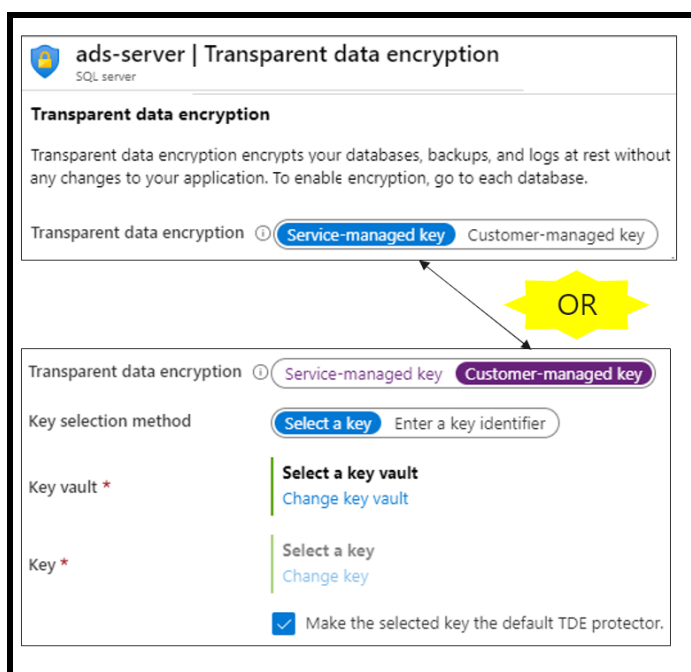
3. Choose the implementation method:

- Azure Portal: A user-friendly interface for creating and managing DDM policies and rules.
- PowerShell cmdlets: programmatic management for automation and integration with scripts.
- REST API: Enables DDM integration into custom applications and workflows.

4. Consider HSM protection: For susceptible data, use Azure Key Vault HSMs for enhanced key storage and management.

Implement Transparent Database Encryption (TDE)

Transparent Data Encryption (TDE) safeguards your data at rest in the Azure SQL Database, Azure SQL Managed Instance, and Synapse SQL by encrypting it in real time. This adds an extra layer of security against unauthorized access, even if intruders gain physical access to the storage devices.



Source: Microsoft Documentation

Key Benefits:

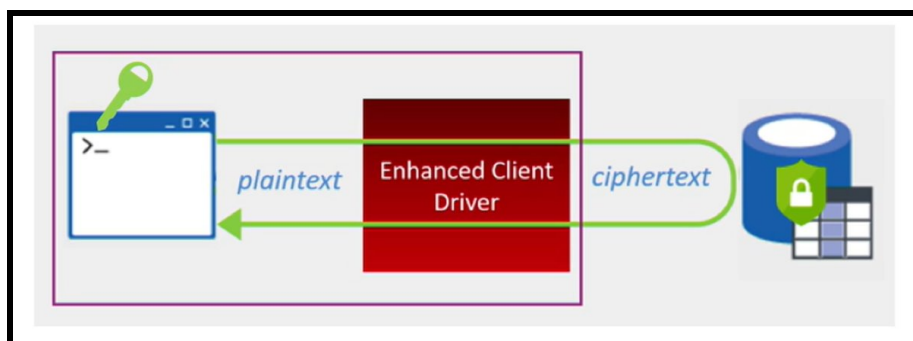
- **Enhanced Data Security:** Protects sensitive data, like PII and financial information, from unauthorized access, even in offline scenarios.
- **Compliance Adherence:** Helps meet data security and privacy regulations like GDPR and HIPAA.
- **Simplified Management:** Automatic encryption and decryption without application code changes.

Deployment Options:

- **Service-managed TDE (default):** Microsoft manages the encryption keys, offering ease of use.
- **Customer-managed TDE (BYOK):** You manage the keys in Azure Key Vault, providing greater control and compliance flexibility.

Recommend when to use Azure SQL Database Always Encrypted

Azure SQL Database Always Encrypted (Always Encrypted) provides a powerful tool for protecting highly confidential data within your SQL databases. It achieves this by encrypting data client-side before it even reaches the database engine, ensuring it remains encrypted at rest and in transit.



Source: Microsoft Documentation

Key Benefits:

1. **Stronger Confidentiality:** Always Encrypted encrypts sensitive data like PII (personally identifiable information), health records, or financial data, offering an additional layer of security beyond database access controls.
2. **Compliance Adherence:** By demonstrating data encryption at rest and in transit, Always Encrypted helps organizations comply with data privacy regulations such as HIPAA, PCI DSS, and GDPR.
3. **Granular Access Control:** Even if users have database access, they cannot view plaintext sensitive data encrypted with Always Encrypted unless they possess the decryption keys.
4. **Client-Side Control:** Keys are managed on the client side, providing organizations greater control over their sensitive data compared to server-side encryption options.

Considerations:

- **Performance Impact:** Encryption and decryption introduce some overhead. Evaluate the impact on your specific workload to ensure acceptable performance.
- **Limited Functionality:** Depending on the encryption type chosen (deterministic or randomized), certain operations like searching or joining on encrypted data might be restricted.
- **Complexity:** Implementing and managing Always Encrypted requires additional configuration and expertise.

Best suited for:

- Scenarios demand strong confidentiality for sensitive data.
- Organizations need to comply with data privacy regulations.
- Situations where granular access control over sensitive data is critical.

Secure Azure using Microsoft Defender for Cloud & Sentinel

Plan, implement, and manage governance for security

Create, assign, and interpret security policies and initiatives in Azure Policy

Empowering Compliance and Control:

- When utilizing Azure, it is crucial to make sure that organizational standards and service-level agreements are followed.
- You can accomplish this by using Azure Policy, which allows for creating, assigning, and interpreting security policies and initiatives.

Benefits:

- Simplified compliance with organizational standards and regulations.
- Enhanced security posture through automated enforcement of best practices.
- Improved visibility and control over resources within your Azure environment.
- Streamlined resource management and reduced risks.
- By effectively utilizing Azure Policy, you can secure your Azure infrastructure, streamline compliance, and empower your organization to leverage the cloud with confidence.

Configuring Azure Key Vault network settings

1. **Open Azure Portal:**
 - Start by signing in to the Azure portal.
2. **Navigate to Key Vault:**
 - In the search bar, type **Key Vaults** and select the one you wish to configure from the list.
3. **Access Networking Settings:**
 - Once inside your Key Vault, go to the **Settings** section in the left-hand menu and select **Networking**.
4. **Set Network Rules:**
 - Under the **Firewalls and virtual networks** tab, you will see options for configuring network access.
5. **Allow Access from:**
 - Choose between **All networks** or **Selected networks**.
 - If you choose **All networks**, your Key Vault will be accessible from any IP address.
 - For **Selected networks**, continue to the next steps to specify allowed networks.
6. **Add Virtual Networks:**
 - Click on **+ Add existing virtual network**.
 - In the blade that opens, select your subscription, virtual network, and subnet. Ensure that the virtual network has **service endpoints** enabled for Key Vault.
7. **Add IP Addresses:**

- Scroll down to the **IP Addresses** section to add specific IP addresses or address ranges in CIDR notation.
8. **Allow Trusted Microsoft Services:**
- Optionally, you can enable access for trusted Microsoft services by toggling the option **Allow trusted Microsoft services to bypass this firewall?**
9. **Save Changes:**
- Once you have configured the desired settings, click on **Save** at the top of the Networking page.

Implementing Security Controls for Asset Management

Asset management involves tracking, monitoring, and securing an organization's IT assets, including hardware, software, and cloud resources. Implementing security controls ensures that assets are **protected against unauthorized access, loss, or misuse**, while also maintaining compliance with industry regulations.

How to implement security controls to protect backups:

1. **Access Controls:** Implement strict access controls to ensure only authorized personnel can access backup data. Use multi-factor authentication and role-based access controls.
2. **Encryption:** Encrypt backup data both in transit and at rest to protect against unauthorized access. Use strong encryption standards like AES-256.
3. **Regular Audits:** Conduct regular audits and reviews of backup processes and security measures to identify and address vulnerabilities.
4. **Offsite Storage:** Store backups in an offsite location or use cloud storage to protect against physical threats like theft, fire, or natural disasters.
5. **Backup Testing:** Regularly test backup restoration processes to ensure data can be recovered successfully in case of an incident.
6. **Employee Training:** Train employees on best practices for handling backups and recognizing potential security threats.

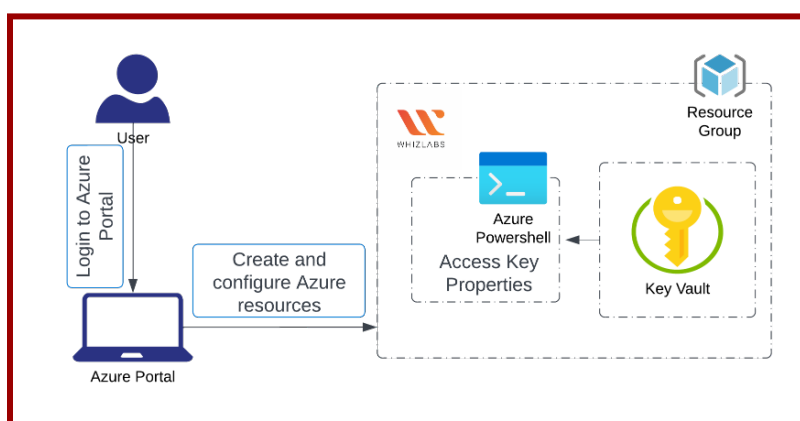
Security Control	Description
Asset Discovery & Inventory	Maintain a real-time inventory of all IT assets, including hardware, software, and cloud resources.
Access Control & RBAC	Enforce role-based access control (RBAC) to restrict asset access to authorized users only.
Encryption & Data Protection	Apply encryption at rest and in transit to protect sensitive asset data from unauthorized access.
Endpoint Security	Deploy antivirus, firewalls, and endpoint detection & response (EDR) tools to secure IT assets.
Patch Management	Regularly update and patch software and hardware to fix vulnerabilities and prevent exploits.
Monitoring & Logging	Use SIEM (Security Information and Event Management) solutions to monitor asset activities and detect threats.
Asset Lifecycle Management	Implement policies for secure onboarding, usage, and decommissioning of assets.
Compliance & Auditing	Conduct regular security audits and compliance checks to ensure adherence to industry standards.

Create and configure an Azure Key Vault

What is Azure Key Vault?

Azure Key Vault is a cloud service from Microsoft that provides a secure and centralized storage facility for your cryptographic keys and secrets. Just like a safe deposit box safeguards your valuables, Key Vault protects essential information such as:

- **Encryption keys:** used for encrypting and decrypting sensitive data.
- **Secrets:** passwords, connection strings, API keys, and other confidential information that applications need to function.
- **Certificates:** Used for digital signing and verifying the identity of applications and users.



Benefits of using Azure Key Vault:

- **Enhanced security:** Key Vault employs robust encryption techniques to safeguard your sensitive information, both at rest and in transit.
- **Centralized management:** Manage all your keys and secrets in a single location, simplifying access control, auditing, and rotation processes.
- **Granular access control:** Define who can access specific keys and secrets within the vault, ensuring only authorized users have the necessary permissions.
- **Compliance:** Key Vault simplifies adherence to various security regulations and best practices by keeping your sensitive data secure.

Use Cases for Azure Key Vault:

- Protecting application secrets
- Managing encryption keys
- Issuing and managing certificates
- Enhancing regulatory compliance

Features of Azure Key Vault:

1. **High Availability:** Ensure continuous access to your keys and secrets, even during service disruptions.

2. **Logging and Auditing:** Track access attempts and user activity for enhanced security monitoring.
3. **Key Rotation:** Regularly rotate keys to minimize the risk of compromise.
4. **Integration with Azure services:** Seamlessly integrates with other Azure services for enhanced security and manageability.

Configure access to Key Vault, including vault access policies and Azure Role-Based Access Control

What is Access Control in Azure Key Vault?

Azure Key Vault provides robust access control mechanisms to ensure your sensitive information, like keys, secrets, and certificates, remain secure. It allows you to define who can access the vault and what they can do within it.

Benefits of Configuring Access Control:

- **Enhanced Security:** Granular control prevents unauthorized access and minimizes the risk of data breaches.
- **Reduced Attack Surface:** Limiting access to specific users and applications based on their needs strengthens overall security posture.
- **Compliance Adherence:** Configure access controls to meet specific industry regulations and internal security policies.

Use Cases for Configuring Access Control:

- Granting developers access to specific secrets required for application development.
- Allowing security administrators to manage and audit access to the vault.
- Restricting access to sensitive keys used for encryption purposes only to authorized personnel.

Key Features for Configuring Access Control:

1. Vault Access Policies (Legacy):

- Define specific permissions (e.g., get, set, list) for users, groups, or service principals (applications).
- Limited: Only works for specific Key Vault versions, and are being phased out.

2. Azure Role-Based Access Control (RBAC):

- **Recommended Approach:** More granular and flexible access control system.
- Assign predefined roles (e.g., Key Vault Reader, Contributor) or create custom roles with specific permissions.
- Supports defining access at different scopes (subscription, resource group, or individual vault).

Manage certificates, secrets, and keys

- Managing certificates, secrets, and keys refers to the practice of securing, storing, controlling access to, and utilizing these digital assets.

- It involves utilizing dedicated tools and services to ensure the confidentiality, integrity, and availability of these critical elements for applications and infrastructure.

Benefits:

1. Enhanced Security
2. Centralized Control
3. Improved Lifecycle Management
4. Compliance Adherence

Use Cases:

- ◆ **Securing application secrets:** Store passwords, connection strings, and API keys securely, preventing unauthorized access.
- ◆ **Managing SSL/TLS certificates:** Secure websites and applications by generating, storing, and renewing digital certificates.
- ◆ **Encrypting data at rest and in transit:** Utilize cryptographic keys for secure data encryption, protecting sensitive information.
- ◆ **Managing code signing certificates:** Digitally sign executables and scripts to ensure authenticity and prevent tampering.

Features:

- Secure Storage
- Granular Access Control
- Automated Lifecycle Management
- Auditing and Logging

Configure Key Rotation

What is Key Rotation?

In cryptography, key rotation refers to the practice of periodically changing cryptographic keys. This is important because it mitigates the risks associated with a key being compromised. Even if an attacker gains access to an old key, they cannot use it to decrypt information protected by newer keys.

Benefits of Key Rotation in Azure Key Vault:

- Enhanced security
- Compliance
- Improved risk management

Use cases for key rotation:

1. Protecting sensitive data:

This includes encryption keys used for encrypting data at rest and in transit, such as customer information, financial data, and intellectual property.

2. **Securing access to resources:**

Key Vault stores keys used to control access to other resources, like cloud storage accounts and Azure VMs. Rotating these keys strengthens access security.

3. **Meeting compliance requirements:**

Industries like healthcare and finance often have regulations mandating periodic key rotation.

Configuring key rotation in Azure Key Vault:

- You can configure key rotation policies to automatically generate new versions of keys at specific intervals.
- You can set the expiry dates for new key versions, ensuring they are automatically deactivated after a certain period.
- Key Vault supports two types of rotation policies:
 - **Automatically renew at a given time after creation:** Creates a new key after a specified time has passed since its initial creation.
 - **Automatically renew at a given time before expiry:** Creates a new key before the existing key reaches its set expiration date.

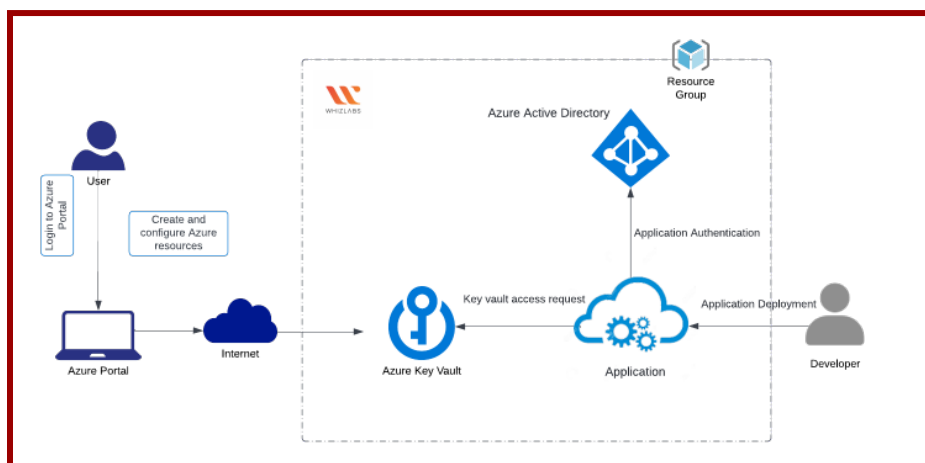
Features of Key Rotation:

- **Flexible configuration:** Choose the optimal rotation interval and expiry times based on your security needs.
- **Non-disruptive:** New key versions are created in the background without interrupting access to existing versions.
- **Integration with Azure services:** Integrates with other Azure services like Azure Functions and Event Grid for automated workflows and notifications.

Configure backup and recovery of certificates, secrets, and keys

What is Backup and Recovery in Key Vault?

Azure Key Vault offers a built-in feature that lets you backup individual items like certificates, secrets, and keys. This backup creates a point-in-time snapshot of the item, allowing you to restore it to a previous state if needed.



Benefits:

- **Disaster recovery:** Recover from accidental deletions, data corruption, or security incidents.
- **Compliance:** Meet regulatory requirements that mandate data backup and restoration capabilities.
- **Peace of mind:** Ensure you have a fallback mechanism to retrieve your critical information.

Use Cases:

- **Accidental deletion:** Recover accidentally deleted keys, secrets, or certificates.
- **Security incident:** Restore data if it's compromised or corrupted due to a security breach.
- **Testing and development:** Roll back changes to previous states for testing and development purposes.

Features:

- **Individual backups:** You can download backups for specific certificates, secrets, or keys, not the entire vault.
- **Encrypted backups:** Backups are encrypted at rest and in transit using industry-standard algorithms.

- **Manual download:** You can download backups to a secure location outside of Azure.
- **Restore to any point in time:** Restore any backed-up item to its original state as of the backup timestamp.

Note: Azure Key Vault itself offers built-in redundancy and high availability within the chosen region. This backup and restore functionality provides an additional layer of protection against accidental or malicious actions, independent of Azure's redundancy features.

Manage security posture by using Microsoft Defender for Cloud

Microsoft Defender for Cloud Secure Score and Inventory - Security Risks

What is Microsoft Defender for the Cloud?

It's a cloud security service from Microsoft that helps you identify, prioritize, and remediate security risks in your cloud environment. It protects workloads across Microsoft Azure, Amazon Web Services (AWS), Google Cloud Platform (GCP), and Azure DevOps.

Benefits:

- Improved security posture: Enhance your overall cloud security with prioritized recommendations.
- Reduced risk of breaches: Identify and address vulnerabilities before they can be exploited.
- Simplified security management: centrally manage security across different cloud platforms.
- Compliance readiness: Help meet compliance requirements by ensuring a secure cloud environment.

Use Cases:

1. **Identify misconfigurations:** Detect and fix security misconfigurations in your cloud resources.
2. **Vulnerability management:** scan for vulnerabilities in your cloud workloads and prioritize remediation.
3. **Threat detection and response:** Detect potential threats and take action to prevent attacks.
4. **Compliance management:** Ensure your cloud environment meets security and compliance requirements.

Features:

- Secure Score
- Inventory
- Recommendations
- Threat detection
- Automated remediation

Note: By utilizing Secure Score and Inventory within Microsoft Defender for Cloud, you gain valuable insights into your security posture, enabling you to:

- **Identify and prioritize security risks:** Analyze both your overall score and individual resource details to pinpoint areas needing the most attention.

- **Focus on the most critical issues:** First, address high-risk vulnerabilities and misconfigurations to significantly improve your security posture.
- **Track progress over time:** Monitor your Secure Score and see the impact of your remediation efforts on your overall security posture.

Assess compliance against security frameworks

The process of comparing your cloud environment to established security guidelines and regulations to identify gaps and ensure compliance. This involves analyzing your cloud resources for potential vulnerabilities, misconfigurations, and compliance violations.

Benefits:

- **Reduced security risks:** Identify and address potential security weaknesses before they can be exploited.
- **Improved regulatory compliance:** Demonstrate conformity with industry standards and regulations, such as HIPAA, PCI DSS, or SOC 2.
- **Enhanced trust and transparency:** Build trust with stakeholders by demonstrating your commitment to secure practices.
- **Streamlined security management:** centralize and automate compliance assessments for consistent and efficient monitoring.

Use Cases:

1. **Demonstrating compliance with regulations:** For organizations subject to data privacy or security regulations.
2. **Meeting contractual requirements:** When contracts with third parties require specific security controls.
3. **Maintaining a strong security posture:** means actively identifying and addressing security weaknesses in the cloud.

Features of Microsoft Defender for Cloud:

- Compliance assessments and Continuous monitoring
- Security recommendations
- Regulatory compliance dashboard

Add custom initiatives to Microsoft Defender for Cloud

Adding custom initiatives in Microsoft Defender for Cloud allows you to define your security policies and recommendations beyond the built-in options. This enables you to tailor your security posture to address specific threats or compliance requirements relevant to your organization.

Benefits:

- **Enhanced security:** Create custom policies addressing specific security concerns or industry regulations.

- Improved focus: Prioritize your security focus by creating custom initiatives for critical security areas.
- Streamlined reporting: Easily track and report on the compliance status of your custom initiatives.

Use Cases:

1. Implementing internal security policies that go beyond the default recommendations offered by Microsoft Defender for Cloud.
2. Monitoring compliance with specific industry regulations like PCI-DSS or HIPAA.
3. Identifying and addressing security risks specific to your organization's environment.

Features:

- Define custom policies: Use Azure policy definitions to specify desired security configurations and behaviors.
- Create custom recommendations: Develop KQL queries to identify security issues and suggest remediation actions.
- Organize with custom standards: Group-related custom recommendations within custom standards for easier management.
- Monitor compliance: Track the compliance status of your custom initiatives and the resources within them.

Note: Creating custom initiatives requires familiarity with Azure Policy and KQL. For detailed instructions and a deeper understanding, refer to the official Microsoft documentation: <https://learn.microsoft.com/en-us/azure/defender-for-cloud/custom-security-policies>

Connect hybrid cloud and multi-cloud environments to Microsoft Defender for Cloud

Microsoft Defender for Cloud is a cloud-based security platform that helps organizations manage and improve the security posture of their cloud environments. It offers a unified experience for securing:

- **Azure:** Native integration for comprehensive security controls.
- **AWS and Google Cloud:** multi-cloud support with native security capabilities for these platforms.
- **Hybrid environments:** On-premises workloads can be connected through Azure Arc for security assessments and monitoring.

Benefits:

- Unified security management
- Improved threat detection and prevention
- Simplified compliance
- Reduced operational costs

Use Cases:

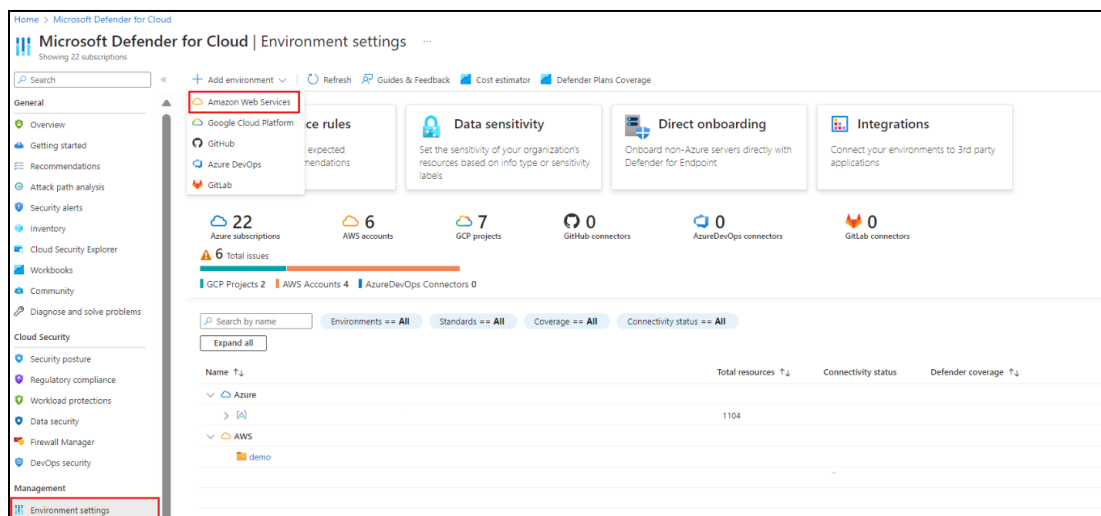
- **Centralized security management:** Organizations with resources spread across various cloud platforms can manage their security posture from a single console.
- **Improved security for on-premises workloads:** Extending Defender for Cloud to on-premises environments through Azure Arc offers additional security controls, insights.
- **Meeting compliance requirements:** Helps organizations meet various security and compliance regulations by providing essential security assessments & reporting.

Features for Connecting Hybrid and Multi-Cloud:

- **Azure Arc:** Enables connecting on-premises workloads to Azure for security assessments and vulnerability scanning.
- **Multi-cloud support:** Provides native Defender for Cloud capabilities for AWS and Google Cloud environments.
- **Centralized logging and monitoring:** aggregate security data from all connected environments for holistic visibility and analysis.
- **Automated threat detection and response:** Leverage advanced security analytics across all environments to detect and respond to threats promptly.

Connect hybrid cloud and multi-cloud environments to Microsoft Defender for Cloud [AWS and GCP]

To connect hybrid cloud and multi-cloud environments to Microsoft Defender for Cloud, including Amazon Web Services (AWS) and Google Cloud Platform (GCP), follow these steps:



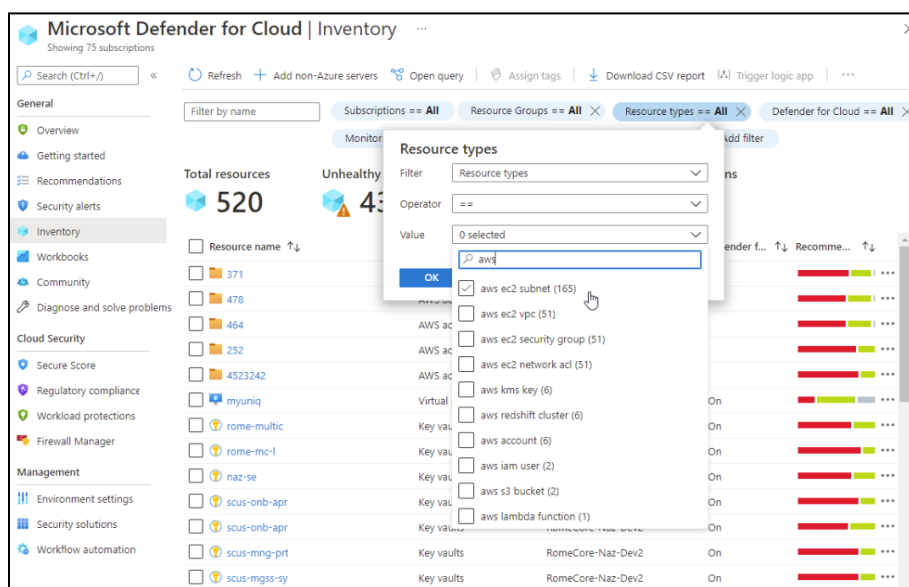
Azure Subscription: Ensure you have a Microsoft Azure subscription. If you don't have one, you can sign up for a free subscription¹.

Enable Microsoft Defender for Cloud: Set up Microsoft Defender for Cloud on your Azure subscription.

Centralized Dashboard: Once connected, you can use the centralized dashboard of Microsoft Defender for Cloud to manage and monitor security across your hybrid and multi-cloud environments.

Connect AWS:

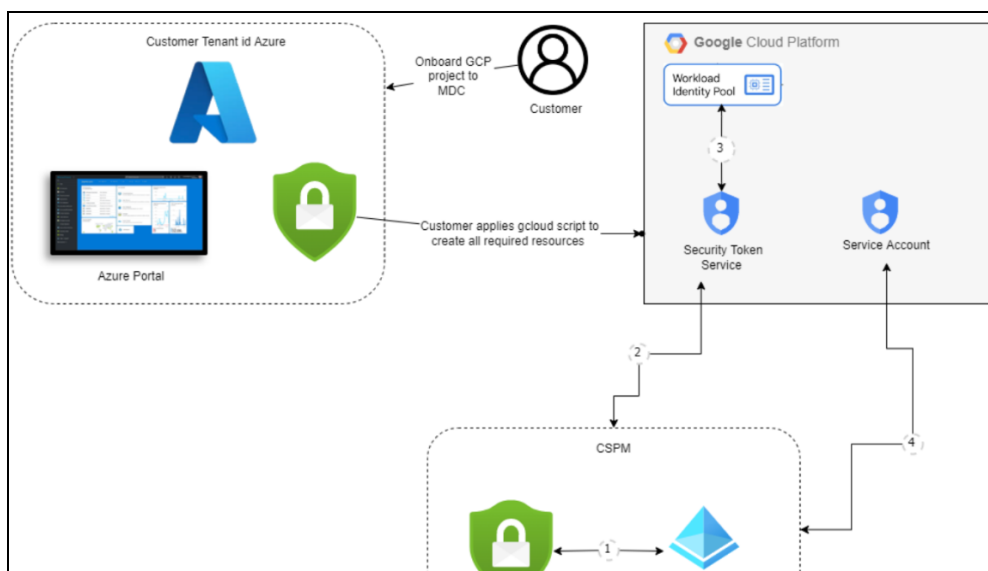
- Use the **AWS Connector** to integrate your AWS account with Microsoft Defender for Cloud.
- Ensure your AWS account has the necessary permissions and that EC2 instances are managed by AWS Systems Manager.
- Follow the onboarding process to connect your AWS account and start monitoring for security threats.



[Source: Microsoft Docs]

Connect GCP:

- Use the **GCP Connector** to integrate your Google Cloud Platform project with Microsoft Defender for Cloud.
- Ensure your GCP project has the necessary permissions and that Kubernetes clusters are enabled.
- Follow the onboarding process to connect your GCP project and start monitoring for security threats.



[Source: Microsoft Docs]

Steps to Connect AWS and GCP to Microsoft Defender for Cloud

Step	Description
1. Enable Defender for Cloud	Activate Microsoft Defender for Cloud in the Azure portal to begin managing multi-cloud security.
2. Configure Cloud Connectors	Use native connectors to integrate AWS and GCP with Defender for Cloud.
3. Grant Required Permissions	Assign necessary permissions in AWS (via IAM roles) and GCP (via IAM service accounts) to enable security monitoring.
4. Enable Security Policies	Apply security recommendations and policies to AWS and GCP resources.
5. Monitor & Detect Threats	Use Defender for Cloud's threat intelligence to identify and mitigate security risks across cloud environments.
6. Automate Response Actions	Set up automated security responses and alerts for detected threats.

Benefits of Connecting AWS & GCP to Defender for Cloud

Benefit	Description
Centralized Security Management	Monitor security across Azure, AWS, and GCP from a single dashboard.

Advanced Threat Protection	Detect and respond to multi-cloud threats using AI-driven security analytics.
Compliance & Governance	Ensure compliance with industry standards (CIS, NIST, ISO 27001) across multiple cloud platforms.
Improved Visibility	Gain insights into security risks across hybrid and multi-cloud environments .

- [Quickstart: Connect your AWS accounts to Microsoft Defender for Cloud](#)
- [Quickstart: Connect your GCP projects to Microsoft Defender for Cloud](#)

Implementing and Managing Agentless Scanning for Virtual Machines in Microsoft Defender for Servers

Microsoft Defender for Servers provides **agentless scanning** to enhance security for virtual machines (VMs) running in **Azure, AWS, and Google Cloud Platform (GCP)**. This **lightweight approach** allows organizations to **detect vulnerabilities, misconfigurations, and malware** without deploying traditional agents, reducing performance impact.

Steps to Implement Agentless Scanning for VMs:

Step	Description
1. Enable Microsoft Defender for Servers	Activate Defender for Servers Plan 2 in the Microsoft Defender for Cloud to access agentless scanning.
2. Configure Cloud Connectors	Ensure Azure Arc is enabled for managing AWS and GCP virtual machines.
3. Grant Necessary Permissions	Assign read-only access to Defender for retrieving VM metadata and scanning disk snapshots.
4. Enable Agentless Scanning	Use Defender for Servers settings to activate agentless scanning for all virtual machines.
5. Review Security Findings	Analyze vulnerability assessments and threat detections in the Microsoft Defender portal .
6. Automate Threat Response	Configure security alerts, automated remediation, and integrations with Microsoft Sentinel.

Benefits of Agentless Scanning for VMs

Benefit	Description
No Performance Impact	Scans are performed on disk snapshots, avoiding CPU or memory usage on live VMs.
Cross-Cloud Protection	Supports Azure, AWS, and GCP virtual machines without installing agents.
Automated Threat Detection	Identifies vulnerabilities, malware, and misconfigurations in real-time.
Simplified Security Management	Eliminates the need for manual agent deployment and maintenance.

Implementing and Managing Microsoft Defender Vulnerability Management for Azure Virtual Machines

Microsoft Defender Vulnerability Management is a comprehensive solution that helps organizations **identify, assess, and remediate security vulnerabilities** in Azure virtual machines (VMs). It provides **real-time visibility, risk-based prioritization, and automated remediation recommendations** to strengthen VM security.

Steps to Implement Microsoft Defender Vulnerability Management for Azure VMs

Step	Description
1. Enable Defender for Servers	Activate Microsoft Defender for Servers Plan 2 to access vulnerability management features.
2. Configure VM Scanning	Ensure vulnerability scanning is enabled for all Windows and Linux VMs in the Azure Security Center .
3. Assign Required Permissions	Grant Reader and Security Reader roles to Defender for accessing VM security configurations.
4. Review Vulnerability Findings	Access the Microsoft Defender portal to analyze detected security gaps and risks.
5. Prioritize & Remediate Threats	Use risk-based prioritization to focus on critical vulnerabilities and apply remediation steps.
6. Automate Security Patching	Enable automatic patching for VMs to reduce security risks.
7. Integrate with SIEM/XDR	Connect Defender Vulnerability Management with Microsoft Sentinel for centralized threat monitoring.

Benefits of Defender Vulnerability Management for Azure VMs

Benefit	Description
Continuous Threat Assessment	Scans and identifies vulnerabilities in real-time.
Risk-Based Prioritization	Focuses on high-risk vulnerabilities that pose the greatest security threats.
Automated Remediation	Provides recommendations and automates patching for quick risk mitigation.
Cross-Platform Support	Works with Windows and Linux VMs across Azure, AWS, and GCP .

Connecting and Configuring Microsoft Defender for Cloud DevOps Security

Microsoft Defender for Cloud DevOps Security provides **comprehensive protection for DevOps environments**, enabling security best practices across **GitHub, Azure DevOps, and GitLab**. It helps organizations identify security vulnerabilities in code, enforce compliance, and prevent supply chain attacks.

To connect and configure settings in Microsoft Defender for Cloud DevOps Security for GitHub, Azure DevOps, and GitLab, follow these steps:

1. **Enable Defender for Cloud:** Ensure Microsoft Defender for Cloud is enabled on your Azure subscription.

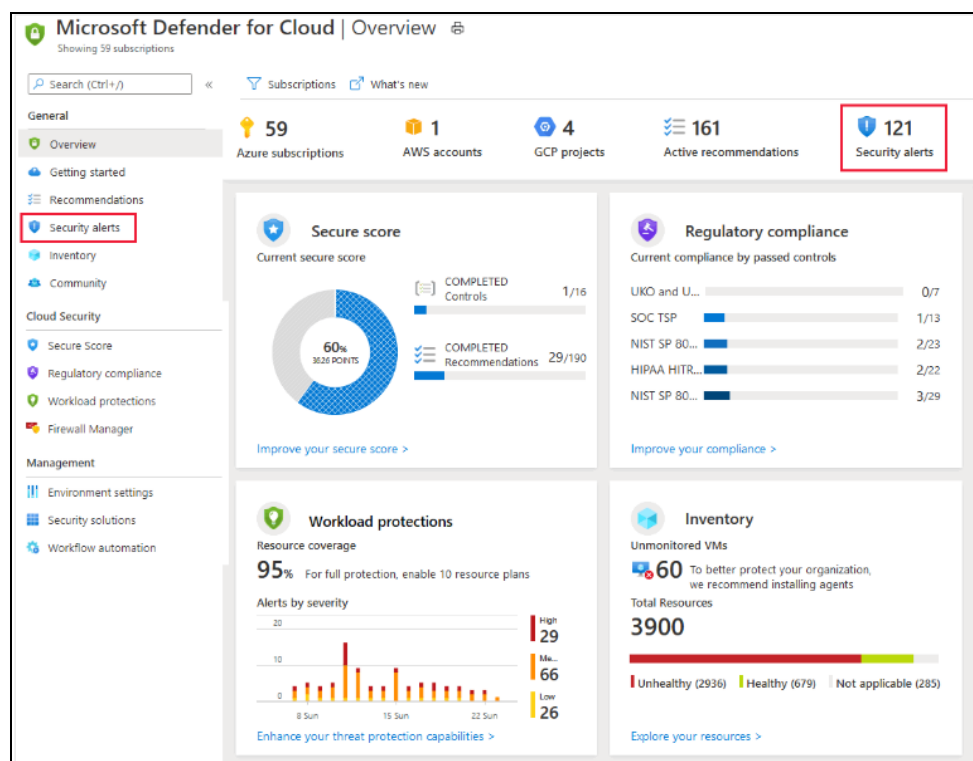
2. **Access DevOps Security Console:** Navigate to the **DevOps security** section in the Microsoft Defender for Cloud portal.
3. **Connect GitHub:**
 - Go to the **Environment settings** page.
 - Select **GitHub** and follow the onboarding process to connect your GitHub repositories2.
 - Enable GitHub Advanced Security for Azure DevOps (GHAzDO) to get findings about secrets, dependencies, and code vulnerabilities.
4. **Connect Azure DevOps:**
 - In the **Environment settings** page, select **Azure DevOps**.
 - Follow the onboarding process to connect your Azure DevOps repositories2.
 - Ensure repositories have secret scanning and code scanning enabled.
5. **Connect GitLab:**
 - Go to the **Environment settings** page and select **GitLab**.
 - Follow the onboarding process to connect your GitLab repositories2.
 - Enable secret scanning and dependency vulnerability scanning for GitLab repositories.
6. **Customize DevOps Workbook:** Customize the DevOps workbook to show desired metrics and view security recommendations.
7. **View and Remediate Findings:** Regularly check the DevOps security console for security findings and follow the remediation steps provided.

Benefits of Defender for Cloud DevOps Security

Benefit	Description
End-to-End DevOps Protection	Secures repositories, pipelines, and infrastructure code from cyber threats.
Seamless Integration	Works with GitHub, Azure DevOps, and GitLab without disrupting workflows.
Automated Code Security	Scans for vulnerabilities, misconfigurations, and exposed secrets in real-time.
Shift-Left Security Approach	Identifies security issues early in the development cycle, reducing risks before deployment.

Manage and respond to security alerts in Microsoft Defender for Cloud

Microsoft Defender for Cloud provides **real-time security alerts** to help organizations **detect, investigate, and respond** to potential threats across their cloud environments. These alerts help security teams take immediate action to **mitigate risks, prevent attacks, and ensure compliance**.



Steps to Manage and Respond to Security Alerts

Step	Description
1. Access Security Alerts	Navigate to Microsoft Defender for Cloud in the Azure portal and open the Security alerts dashboard.
2. Analyze Alert Details	Review alert severity, affected resources, attack timeline, and recommended actions.
3. Classify & Prioritize Alerts	Categorize alerts as High, Medium, or Low severity based on risk impact.
4. Investigate the Threat	Use Defender's security graph and Microsoft Sentinel to analyze attack paths and suspicious activity.
5. Take Remediation Actions	Follow automated recommendations to mitigate risks (e.g., isolating compromised VMs, updating firewall rules).
6. Automate Responses	Set up security automation rules using Azure Logic Apps for rapid incident response.
7. Monitor & Report Findings	Track resolution progress and generate security reports for compliance auditing.

Benefits of Effective Alert Management

Benefit	Description
Faster Threat Detection	Identifies real-time security threats across cloud workloads.
Proactive Incident Response	Automates security responses to reduce remediation time .
Centralized Security Visibility	Provides a single dashboard to monitor alerts across Azure, AWS, and GCP .
Compliance & Risk Reduction	Helps organizations meet security and compliance standards (e.g., CIS, NIST, ISO 27001).

Microsoft Defender External Attack Surface Management - External assets

What is Microsoft Defender External Attack Surface Management (EASM)?

EASM is a cloud-based security service from Microsoft that helps organizations identify and monitor their entire external attack surface.

This includes both managed and unmanaged assets, such as

- Websites and web applications
- Cloud resources (IaaS, PaaS, SaaS)
- Public DNS records
- Mobile applications
- Social media profiles

By providing comprehensive visibility into your digital footprint, EASM empowers organizations:

- Proactively discover and manage shadow IT: uncover hidden resources that may be exposed to security threats and haven't been formally approved by the IT department.
- Identify and prioritize vulnerabilities: Scan external assets for vulnerabilities and misconfigurations that could be exploited by attackers.
- Monitor for threats and suspicious activity: Continuously monitor your attack surface for potential threats and take action to mitigate them before they can cause harm.
- Improve your overall security posture: gain a holistic view of your external attack surface and take steps to reduce your overall risk profile.

Benefits of using Microsoft Defender EASM:

- Enhanced visibility: Gain complete visibility into your entire external attack surface, including known and unknown assets.
- Improved security posture: Proactively identify and remediate vulnerabilities before they can be exploited by attackers.
- Reduced risk: reduce the attack surface that attackers can target and minimize the potential impact of security breaches.
- Streamlined security operations: simplify and automate security processes, freeing up resources for other tasks.

Use Cases for Microsoft Defender EASM:

- Compliance: Meet security compliance requirements that mandate organizations to have a comprehensive understanding of their attack surface.
- Mergers and acquisitions (M&A): Gain visibility into the external attack surface of acquired companies before integration to identify potential security risks.
- Cloud migration: Monitor your attack surface during and after migration to the cloud to ensure proper security posture.

Key Features of Microsoft Defender EASM:

- Continuous discovery and inventory: continuously scans for new assets and updates existing asset information.
- Vulnerability scanning identifies vulnerabilities in web applications, frameworks, and code.
- Exposure detection and prioritization: prioritizes vulnerabilities based on severity and potential impact.
- Attack path analysis maps attack paths to understand the potential impact of vulnerabilities.
- Real-time threat monitoring monitors for suspicious activity and potential threats.
- Integration with other security solutions: Integrates with other Microsoft security solutions for a holistic security posture.

Microsoft Defender for Cloud - Threat protection

Enable workload protection services

Enabling workload protection in Microsoft Defender for Cloud is the process of activating security measures for specific resources within your Azure environment.

This includes services like:

- **Microsoft Defender for Storage:** Protects storage accounts from malware, unauthorized access, and other threats.
- **Microsoft Defender for Databases:** Identifies vulnerabilities, suspicious activities, and potential data exfiltration attempts in your databases.
- **Microsoft Defender for Containers:** Scans container images for vulnerabilities and monitors runtime activities for suspicious behavior.
- **Microsoft Defender for App Service:** Protects web applications hosted in Azure App Service from attacks like SQL injection and cross-site scripting (XSS).
- **Microsoft Defender for Key Vault:** Monitors access attempts and detects anomalies in your Key Vault, where sensitive information like encryption keys and secrets are stored.
- **Microsoft Defender for Resource Manager:** Detects suspicious modifications and access attempts to resources managed through Azure Resource Manager.
- **Microsoft Defender for DNS:** Identifies potential DNS hijacking attempts and unauthorized modifications to DNS records.

Benefits:

- **Enhanced security posture:** Proactively identify and mitigate threats across various workloads.
- **Improved threat detection and response:** Gain insights into suspicious activities and take timely action.
- **Reduced risk of data breaches and unauthorized access:** Secure sensitive information stored in Azure resources.
- **Simplified security management:** Centrally manage security policies and configurations from a single platform.

Use Cases:

- Organizations migrating to the cloud
- Businesses complying with industry regulations
- Companies seeking advanced threat protection

Features:

1. **Vulnerability scanning:** Identifies vulnerabilities in workloads and helps prioritize remediation efforts.
2. **Threat detection and investigation:** Continuously monitors for suspicious activity and provides insights for investigation.

3. **Automatic remediation:** Applies pre-configured actions to respond to detected threats automatically.
4. **Security policy management:** Define and enforce security policies across different workloads.
5. **Centralized reporting and monitoring:** Gain visibility into the security posture of your Azure environment.

Microsoft Defender for Databases

Microsoft Defender for Databases provides **comprehensive security monitoring** for relational and non-relational databases. It helps protect sensitive data from threats such as **SQL injection, brute-force attacks, and data exfiltration**.

Key Features:

- **Advanced Threat Detection** – Identifies suspicious database activities and potential attacks.
- **Vulnerability Assessments** – Scans databases for security misconfigurations and weaknesses.
- **Behavioral Analytics** – Monitors user access patterns to detect anomalies.
- **Compliance Management** – Helps meet security standards like **GDPR, HIPAA, and PCI-DSS**.

Supported databases include **Azure SQL, PostgreSQL, MySQL, Cosmos DB, and SQL Managed Instances**.

Microsoft Defender for Storage

Microsoft Defender for Storage secures Azure Storage accounts against **malware, data breaches, and unauthorized access**. It provides **real-time protection** for files, blobs, and containers.

Key Features:

- **Malware Scanning** – Detects and blocks malicious files uploaded to storage.
- **Access Anomaly Detection** – Identifies unusual access patterns and potential data exfiltration.
- **Integration with Microsoft Sentinel** – Enables centralized security monitoring and automated response.
- **Threat Intelligence** – Uses AI-driven insights to detect **ransomware and insider threats**.

Supported storage types include **Azure Blob Storage, Azure Files, and Data Lake Storage**.

Configure Microsoft Defender for Servers

- ❖ Microsoft Defender for Servers is a cloud-based security solution that provides threat protection and vulnerability management for your on-premises Windows servers and cloud workloads (Azure VMs, AWS instances, GCP projects).
- ❖ It helps you to:
 1. Detects and prevents malware, viruses, and other threats.

2. Identify and prioritize vulnerabilities in your server environment.
3. Remediate vulnerabilities and harden your server configurations.

Benefits:

- Improved security posture: proactive threat detection and vulnerability management minimize the risk of attacks.
- Centralized management: Manage all your server security from a single console, reducing complexity.
- Reduced costs: Identify and address vulnerabilities before they can be exploited, saving time and resources.
- Enhanced compliance: helps meet various security and compliance regulations.

Use Cases:

1. Protecting on-premises Windows servers from malware, ransomware, and other threats.
2. Identifying and patching vulnerabilities in your server environment.
3. Enforcing security policies and configurations across your servers.
4. Gaining insights into your server security posture and threat landscape.

Features:

- Next-generation antivirus and anti-malware: protects against known and unknown threats.
- Vulnerability management identifies and prioritizes vulnerabilities in your server environment.
- Endpoint detection and response (EDR): Provides advanced threat hunting and investigation capabilities.
- Cloud workload security: protects your Azure VMs, AWS instances, and GCP projects.
- Security recommendations: Provides actionable advice to improve your server's security posture.

Manage and respond to security alerts in Microsoft Defender for Cloud

Microsoft Defender for Cloud is a security service that continuously monitors your Azure, hybrid, and multi-cloud resources for potential threats. It analyzes log data, identifies suspicious activity, and generates security alerts to notify you of potential security issues.

Benefits:

- Early detection: alerts you to potential threats and vulnerabilities quickly, allowing for prompt investigation and remediation.
- Prioritization: It focuses your attention on the most critical alerts based on severity, helping you prioritize your security efforts.
- Improved response time: provides detailed information and recommended actions, enabling a faster and more effective response to security incidents.
- Reduced risk: This helps you proactively address security issues and minimize the impact of potential attacks.

Use cases:

1. Identifying unauthorized access attempts
2. Monitoring for malware and vulnerabilities
3. Detecting suspicious network activity
4. Investigating potential security incidents

Features:

- **Security alert dashboard:** Provides a centralized view of all security alerts, along with information about the severity, affected resources, and recommended actions.
- **Alert filtering and searching:** This allows you to filter and search alerts based on various criteria, such as severity, resource type, and date/time.
- **Detailed alert information:** Each alert provides detailed information about the potential threat, including the affected resources, the timeline of events, and potential impact.
- **Recommended actions:** suggests actions you can take to investigate and remediate the security issue, such as isolating affected resources or patching vulnerabilities.
- **Integration with SIEM and SOAR tools:** This can be integrated with Security Information and Event Management (SIEM) and Security Orchestration Automated Response (SOAR) tools for advanced security management.

Configure and manage security monitoring and automation solutions

Monitor security events by using Azure Monitor

What is Azure Monitor?

- The Azure Monitor serves as your central hub for securing your Azure environment.
- By harnessing its activity log, you gain in-depth visibility into subscription-level events, empowering you to identify potential threats and take swift action.
- This comprehensive log records activities like resource modifications and VM startups, providing valuable context for understanding changes within your Azure infrastructure.
- Access it directly in the portal or leverage PowerShell and the Azure CLI for retrieval.

Diagnostic Settings: Customizing Data Delivery

To improve functionality, use diagnostic settings to route the activity log to different destinations based on your specific requirements:

1. **Azure Monitor Logs:** Enable advanced querying, extended alerting, and data retention (up to two years) for more in-depth analysis.
2. **Azure Event Hubs:** Send data beyond Azure for integration with external security tools or SIEMs.
3. **Azure Storage** offers affordable, long-term archiving for compliance purposes.

Ways to Retrieve Information Other Than Through the Portal

- PowerShell: Use the `Get-AzLog` cmdlet.
- Azure CLI: Employ `az monitor activity-log`.
- REST API: Access data programmatically.

Configure data connectors in Microsoft Sentinel

Streamlining Data Ingestion for Enhanced Threat Detection and Response

Microsoft Sentinel serves as a central hub for Security Information and Event Management (SIEM), empowering you to gather logs and security insights from diverse sources.

Advantages of Data Connectors:

- **Unified View:** Gain a consolidated perspective of your security landscape by ingesting data from various sources, including Microsoft services, cloud platforms, on-premises infrastructure, and third-party solutions.
- **Enhanced Threat Detection:** Correlate events across disparate sources to identify emerging threats that might otherwise go unnoticed.
- **Streamlined Investigations:** Reduce investigation time by leveraging readily available data within Microsoft Sentinel, eliminating the need to switch between disparate tools..
- **Simplified Compliance:** Facilitate compliance with regulatory requirements by centralizing security data and simplifying reporting.

Types of Data Connectors:

1. **Built-in Connectors:** Leverage connectors readily available within Microsoft Sentinel for integrating with popular solutions like Microsoft 365 Defender, Microsoft Entra ID, and Azure security services.
2. **Custom Connectors:** Utilize Syslog, Common Event Format (CEF), or REST APIs to connect to non-Microsoft products and platforms.
3. **Solution Connectors:** Deploy pre-packaged solutions from the Microsoft Sentinel Content Hub, combining data connectors with analytics rules, workbooks, and playbooks for specific security scenarios.

Advanced Integrations:

- **REST API Integration:** Integrate with security products offering APIs, either on the provider side or using Azure Functions for custom data formatting and ingestion.
- **Agent-based Integration:** Employ the Syslog protocol or the Log Analytics agent for on-premises data sources or devices supporting CEF-based formatting.
- **Service-to-service integration:** take advantage of pre-built service-to-service connections for Microsoft services and Amazon Web Services.

Create and customize analytics rules in Microsoft Sentinel

Create custom analytics rules in Microsoft Sentinel to enhance threat detection. These rules create incidents for inquiry, sound alarms, and search your environment for unusual activity. Below are the simplified steps:

1. **Navigate:** Go to Analytics > +Create > Scheduled query rule.
2. **Craft your rule:**
 - a. **Name & Describe:** Give your rule a clear name and description.
 - b. **Severity:** Choose the impact level (informational, low, medium, or high).
 - c. **Enable/Disable:** Control when the rule runs.
3. **Write the query:**
 - Use Kusto Query Language (KQL) to define the search logic.
 - Tip: Utilize the Advanced Security Information Model (ASIM) parser for broader compatibility.
4. **Enrich your alerts:**
 - **Entity mapping:** Link query results to Microsoft Sentinel entities for deeper insights.
 - **Custom details:** Extract specific event data for immediate visibility.
 - **Alert Details:** Override default alert properties with relevant query details.
5. **Schedule & set thresholds:**
 - **Run frequency:** Choose how often the query runs (every 5 minutes to every 14 days).

- Lookback period: Define the data time frame covered by the query (past 10 minutes to 14 days).
- Alert threshold: Set the minimum number of query results to trigger an alert.

6. Configure incidents:

- Create incidents: Choose whether and how to generate incidents from alerts.
- Group alerts: Combine similar or recurring alerts into single incidents for efficiency.

7. Automate responses (optional):

- Set automated actions for alerts, incident creation, and updates.

8. Review & create: Double-check your settings and hit "Create" to unleash your rule!

Remember:

- Keep your query length between 1 and 10,000 characters.
- The total alert size cannot exceed 64 KB.
- Adjust query intervals and lookback periods to avoid coverage gaps.

Configure automation in Microsoft Sentinel

Automation Rules and Playbooks:

- **Automation Rules:** Automatically respond to incidents/alerts by assigning personnel, closing false positives, etc. Trigger playbooks.
- **Playbooks:** orchestrate multi-step responses to incidents/alerts. It is built on Azure Logic Apps, offering customizability and templates.

Creating a Playbook:

- Choose a Blank Playbook (standard) or Playbook with a Trigger (consumption).
- Configure details like name, region, and connections.
- Define trigger (incident, alert, entity).
- Add actions using dynamic content and expressions.

Automating Responses:

- Create an automation rule with a trigger (incident created/updated, alert created).
- Add conditions to refine when the rule runs.
- Add the Run playbook action and choose the desired playbook.
- Grant Microsoft Sentinel permissions to run the playbook.

Benefits:

- Faster, more efficient incident response.
- Reduced manual workload for security analysts.
- Consistent and repeatable processes.

Remember:

- Playbooks only run with matching triggers (incident/alert).
- Microsoft Sentinel needs permission to run playbooks.

Key Points:

- Use automation rules and playbooks to automate threat response in Microsoft Sentinel.
- Playbooks offer flexible orchestration of actions based on triggers.
- Configure triggers, conditions, and actions to tailor your response.
- Grant Microsoft Sentinel permissions to run playbooks effectively.

Monitoring Network Security Events

Monitoring network security events involves collecting, analyzing, and responding to potential threats across network traffic. This process ensures that organizations can detect security issues early, mitigate risks, and maintain a secure network environment. Azure provides tools like **Azure Monitor**, **Azure Network Watcher**, and **Microsoft Sentinel** to monitor network events efficiently.

Step	Description
Enable Diagnostic Settings	Configure diagnostic settings on resources (e.g., NSGs, Application Gateways, Azure Firewalls) to send logs to a Log Analytics workspace.
Set Up Log Analytics	Use Log Analytics workspaces to centralize and analyze collected data. Create custom queries to filter and view specific network security events.
Create Alerts	Establish alerts based on Log Analytics queries to notify you of suspicious activities or potential security breaches. Configure alerts to send notifications via email, SMS, or other channels.
Implement Network Watcher	Use Azure Network Watcher for monitoring and diagnostics, enabling you to analyze traffic patterns and detect anomalies in your network.
Enable Traffic Analytics	Utilize Traffic Analytics to gain insights into traffic flow, identify potential threats, and monitor network performance.
Monitor Dashboards	Create custom dashboards in Azure Monitor to visualize network security events and performance data in real-time, keeping you informed about the security status of your network.

To monitor network security events and performance data in Azure Monitor, you can configure Data Collection Rules (DCRs). Here's a brief overview:

1. **Access Azure Monitor:** Navigate to the Azure portal and open **Azure Monitor**.
2. **Create Data Collection Rule:**
 - Go to **Data Collection Rules** and click on **Create**.
 - Provide a name and description for the rule, then select the target resources (e.g., virtual machines, containers).
3. **Define Data Sources:**
 - Specify the data sources you want to collect, such as Windows events, Syslog events, or performance counters.
 - Use filters to select specific event IDs or performance metrics.
4. **Configure Data Transformation:**
 - Apply transformations to filter or modify the collected data before it is sent to the Log Analytics workspace.
 - This helps in reducing noise and focusing on relevant data.
5. **Deploy Data Collection Rule:**
 - Deploy the DCR to the selected resources.
 - Ensure that the Azure Monitor Agent is installed on the target machines to collect the data.

6. Monitor and Analyze Data:

- Use Log Analytics queries to analyze the collected data.
- Create alerts based on specific conditions to get notified about security events or performance issues.

To monitor network security events effectively, you can use a combination of Azure Monitor and other security tools in the Azure ecosystem. Here are the steps you can take:

1. Enable Diagnostic Settings:

- Configure diagnostic settings on your Azure resources (such as Network Security Groups, Application Gateways, and Azure Firewalls) to send logs to a Log Analytics workspace.

2. Create Data Collection Rules (DCRs):

- Define Data Collection Rules in Azure Monitor to specify the logs and metrics you want to collect from your resources.

3. Configure Network Security Solutions:

- Use Microsoft Defender for Cloud, and Microsoft Sentinel to gain insights and advanced threat detection capabilities.

4. Set Up Log Analytics:

- Use Log Analytics workspaces to centralize and analyze your collected data. Create custom queries to filter and view specific network security events.

5. Create Alerts:

- Set up alerts based on your Log Analytics queries to notify you of suspicious activities or potential security breaches. Configure these alerts to send notifications via email, SMS, or other communication channels.

6. Enable Traffic Analytics:

- Utilize Azure Network Watcher and Traffic Analytics to monitor and analyze traffic patterns and detect anomalies in your network.

7. Monitor Dashboards:

- Create custom dashboards in Azure Monitor to visualize network security events and performance data in real-time. Use these dashboards to stay informed about the security posture of your network.

Common Use Cases for Network Security Monitoring with DCRs

Use Case	DCR Configuration
Detect Suspicious Traffic	Collect NSG flow logs to identify unauthorized access attempts.
Monitor Firewall Activity	Track Azure Firewall logs for anomalies and failed connections.
Analyze VPN Performance	Gather Azure VPN Gateway logs to optimize network performance.
Compliance Reporting	Store security event logs in Azure Storage for audit and compliance needs.

Benefits of Using DCRs in Azure Monitor

Benefit	Description
Granular Data Control	Customizes what data is collected, processed, and stored.
Reduced Costs	Filters unnecessary data, lowering Log Analytics ingestion costs.
Enhanced Security Visibility	Provides real-time monitoring for network security threats.
Integration with SIEM/XDR	Sends logs to Microsoft Sentinel or third-party SIEM platforms for deeper threat analysis.

Configuring Workflow Automation in Microsoft Defender for Cloud

Microsoft Defender for Cloud allows organizations to **automate security responses** using **workflow automation**. This feature helps streamline **incident response, alert management, and remediation actions** by integrating with **Azure Logic Apps, Microsoft Sentinel, and third-party tools**.

Common Use Cases for Workflow Automation

Use Case	Automation Action
Incident Notifications	Automatically send security alerts to email, Microsoft Teams, or ServiceNow.
Threat Containment	Isolate compromised VMs, revoke user access, or block malicious IPs.
Remediation Playbooks	Trigger Azure Sentinel playbooks to automatically mitigate threats.
Compliance Enforcement	Enforce security policies by applying patches, updating firewall rules, or disabling non-compliant resources.

Benefits of Workflow Automation in Defender for Cloud

Benefit	Description
Faster Incident Response	Reduces reaction time by automating security actions.
Consistent Security Policies	Ensures standardized responses across Azure, AWS, and GCP environments.
Reduced Manual Effort	Minimizes reliance on manual intervention, improving SOC efficiency.
Enhanced Compliance & Reporting	Automates policy enforcement and auditing for security frameworks like CIS, NIST, and ISO 27001.

To configure workflow automation using Microsoft Defender for Cloud, follow these steps:

- 1. Access Workflow Automation:**
 - In the Microsoft Defender for Cloud portal, go to the sidebar and select **Workflow Automation**.
- 2. Create Automation Rules:**
 - From the Workflow Automation page, create new automation rules, enable, disable, or delete existing ones.
 - Define the scope of the automation, which refers to the subscription where the workflow automation will be deployed.
- 3. Define New Workflow:**
 - Select **Add Workflow Automation** to create a new workflow.
 - Provide a name and description for the automation.

- Specify the triggers that will initiate the workflow, such as security alerts or compliance changes.

4. Specify Logic App:

- Choose the consumption logic app that will run when your trigger conditions are met.
- Use Azure Logic Apps to create and configure the logic app.

5. Deploy and Monitor:

- Deploy the workflow automation and monitor its performance.
- Regularly review the automation rules and make adjustments as needed to ensure they meet your security requirements